Trust Me, I'm a Certificate Authority

PyCon PT 2026 Tutorial

Tiago Montes

What happens when you browse to **https://example.com/**?

What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

Many things must go right, many can go wrong, some badly.

What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

Many things must go right, many can go wrong, some badly.

Is the communication **private** and **untampered with**?

What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

Many things must go right, many can go wrong, some badly.

Is the communication **private** and **untampered with**?

Can you **trust** a device you don't manage yourself?

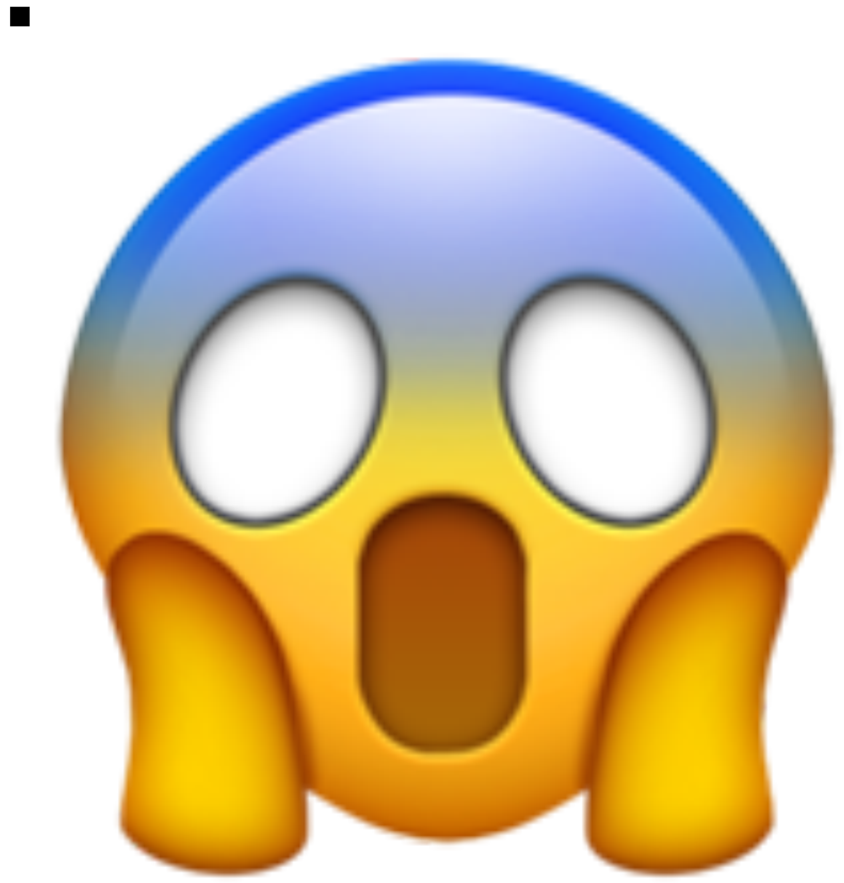
What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

Many things must go right, many can go wrong, some badly.

Is the communication **private** and **untampered with**?

Can you **trust** a device you don't manage yourself?



Trust Me, I'm a Certificate Authority

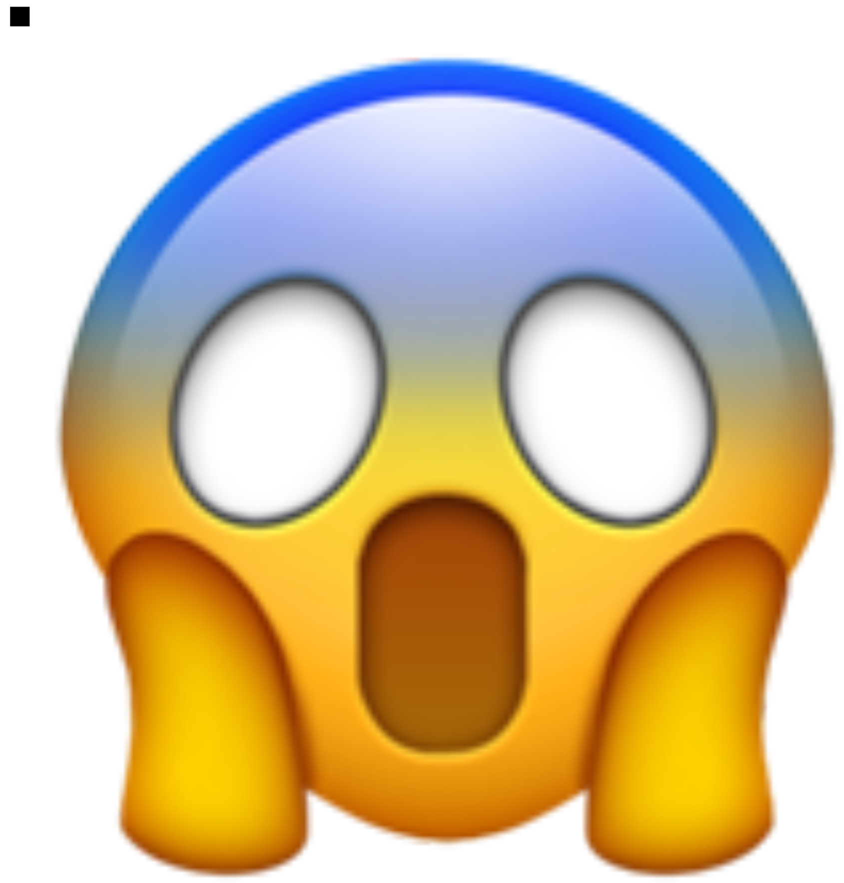
What happens when you browse to **https://example.com/**?

Or when your code interacts with **https://api.example.net/**?

Many things must go right, many can go wrong, some badly.

Is the communication **private** and **untampered with**?

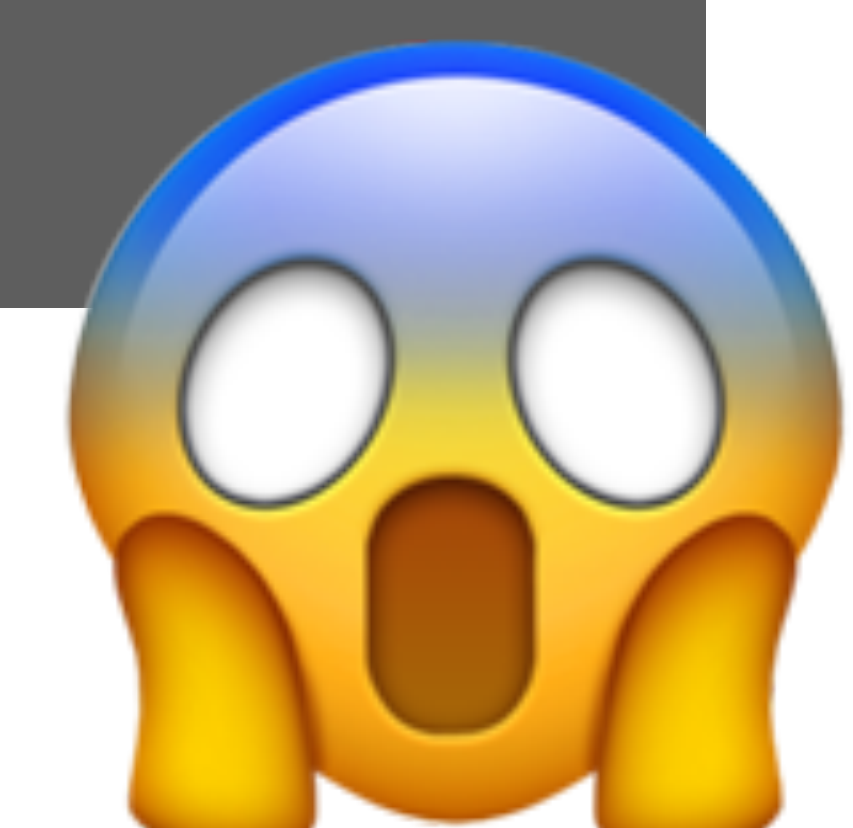
Can you **trust** a device you don't manage yourself?



Trust Me, I'm a Certificate Authority

understand why this shows up in your logs

```
urllib.error.URLError: <urlopen error [SSL:
CERTIFICATE_VERIFY_FAILED] certificate
verify failed: unable to get local issuer
certificate (_ssl.c:1144)>
```



welcome!

Cast of Characters

Cast of Characters

Alice

Cast of Characters

Alice

Bob

Cast of Characters

Alice wants

...to talk to
Bob securely

Bob

Cast of Characters

Alice wants

...to talk to Bob securely

Bob wants

...to respond to Alice.

Cast of Characters

Cast of Characters

Alice wants

...to talk to Bob securely

Eve

Bob wants

...to respond to Alice.

Cast of Characters

Alice wants

...to talk to Bob securely

Eve wants

...to listen to or forge talks.

Bob wants

...to respond to Alice.

Cast of Characters

Alice wants

...to talk to Bob securely

Eve wants

...to listen to or forge talks.

Bob wants

...to respond to Alice.

DISCLAIMER

THIS IS TEACHING MATERIAL, NOT SECURITY SOFTWARE.

IT CUTS CORNERS ON PURPOSE.

SEVERAL EXERCISES ARE DELIBERATELY BROKEN.

REAL SECURITY IS A GREAT DEAL MORE THAN THIS.

USE NONE OF IT FOR ANYTHING THAT MATTERS.

NEVER TRUST A CA YOU BUILT HERE.

Trust Me, I'm a Certificate Authority

RSA	Keys, encryption, and signatures.
Certificates	Binding keys to identities (yay X.509)
CAs and TLS	Certificate Authorities, HTTPS clients/servers
MITM	Interception: where trust actually lives
Break Stuff	Certificates that fail, checks that catch them

Setup

Setup

Python >= 3.12 and 3.15rc2 works

Setup

Python >= 3.12 and 3.15rc2 works

Clone a GitHub repository...

Setup

Python >= 3.12 and 3.15rc2 works

Clone a GitHub repository...

with uv

```
$ uv sync
```

Setup

Python >= 3.12 and 3.15rc2 works

Clone a GitHub repository...

with uv

```
$ uv sync
```

without uv

```
$ python3 -m venv .venv
$ source .venv/bin/activate
$ python3 -m pip install -r requirements.txt
```

Setup

Python >= 3.12 and 3.15rc2 works

Clone a GitHub repository...

with **uv**

```
$ uv sync
```

without **uv**

```
$ python3 -m venv .venv
$ source .venv/bin/activate
$ python3 -m pip install -r requirements.txt
```

windows

- Use **`python.exe`** instead of **`python3`**.
- Activate with **`.venv\Scripts\activate`**, instead.

Setup

Python >= 3.12 and 3.15rc2 works

Clone a GitHub repository...

with uv

```
$ uv sync
```

Optionally activate the virtual environment.

without uv

```
$ python3 -m venv .venv
$ source .venv/bin/activate
$ python3 -m pip install -r requirements.txt
```

windows

- Use **`python.exe`** instead of **`python3`**.
- Activate with **`.venv\Scripts\activate`**, instead.

Setup

Python >= 3.12 and 3.15rc2 works

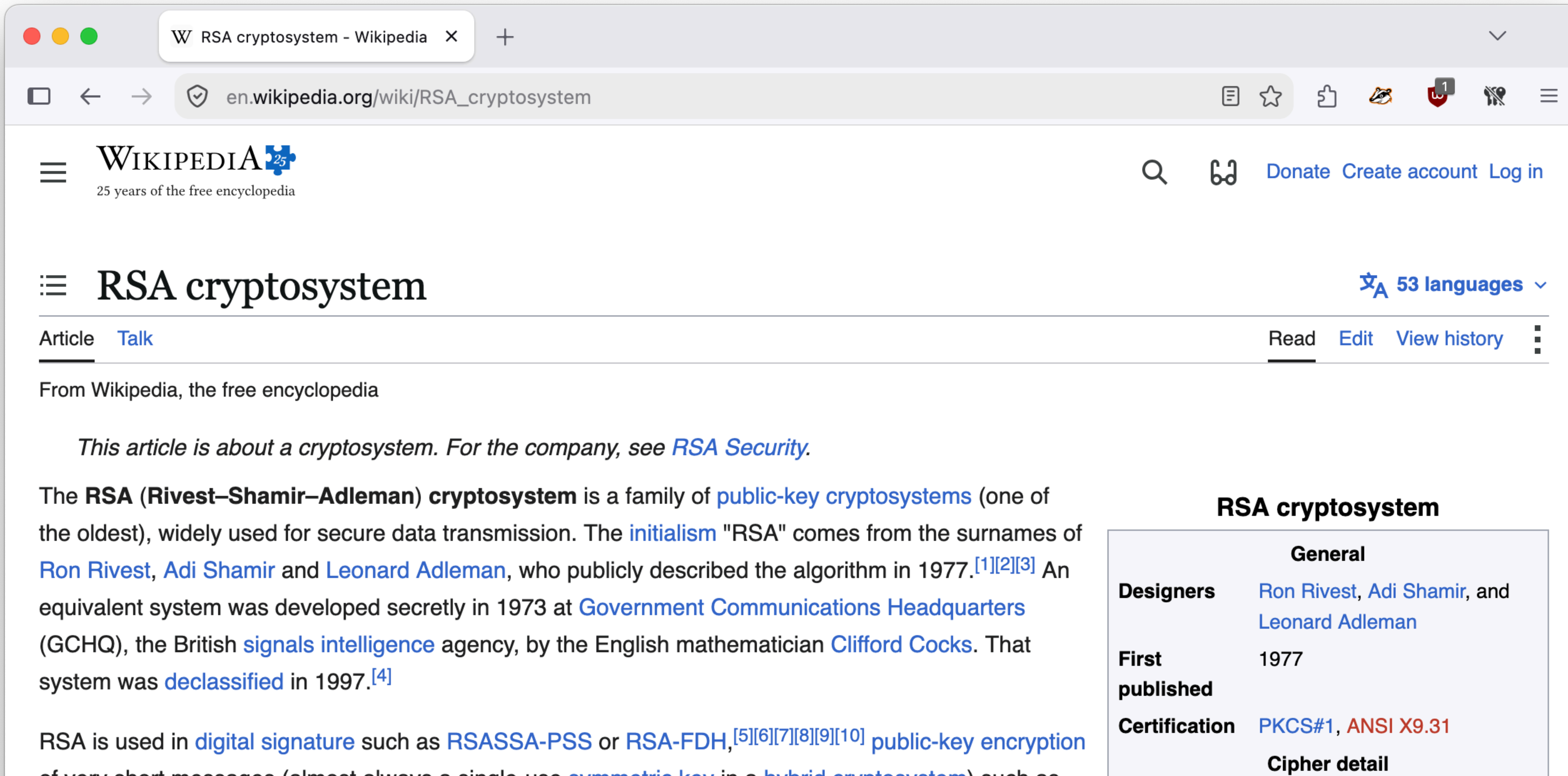
Clone a GitHub repository...

README.md

...no worries, it's all there!

RSA (Rivest–Shamir–Adleman)

RSA (Rivest–Shamir–Adleman)



W RSA cryptosystem - Wikipedia

en.wikipedia.org/wiki/RSA_cryptosystem

WIKIPEDIA
25 years of the free encyclopedia

Donate Create account Log in

RSA cryptosystem

53 languages

Article Talk Read Edit View history

From Wikipedia, the free encyclopedia

This article is about a cryptosystem. For the company, see RSA Security.

The **RSA** (**Rivest–Shamir–Adleman**) **cryptosystem** is a family of public-key cryptosystems (one of the oldest), widely used for secure data transmission. The initialism "RSA" comes from the surnames of Ron Rivest, Adi Shamir and Leonard Adleman, who publicly described the algorithm in 1977.[1][2][3] An equivalent system was developed secretly in 1973 at Government Communications Headquarters (GCHQ), the British signals intelligence agency, by the English mathematician Clifford Cocks. That system was declassified in 1997.[4]

RSA is used in digital signature such as RSASSA-PSS or RSA-FDH,[5][6][7][8][9][10] public-key encryption

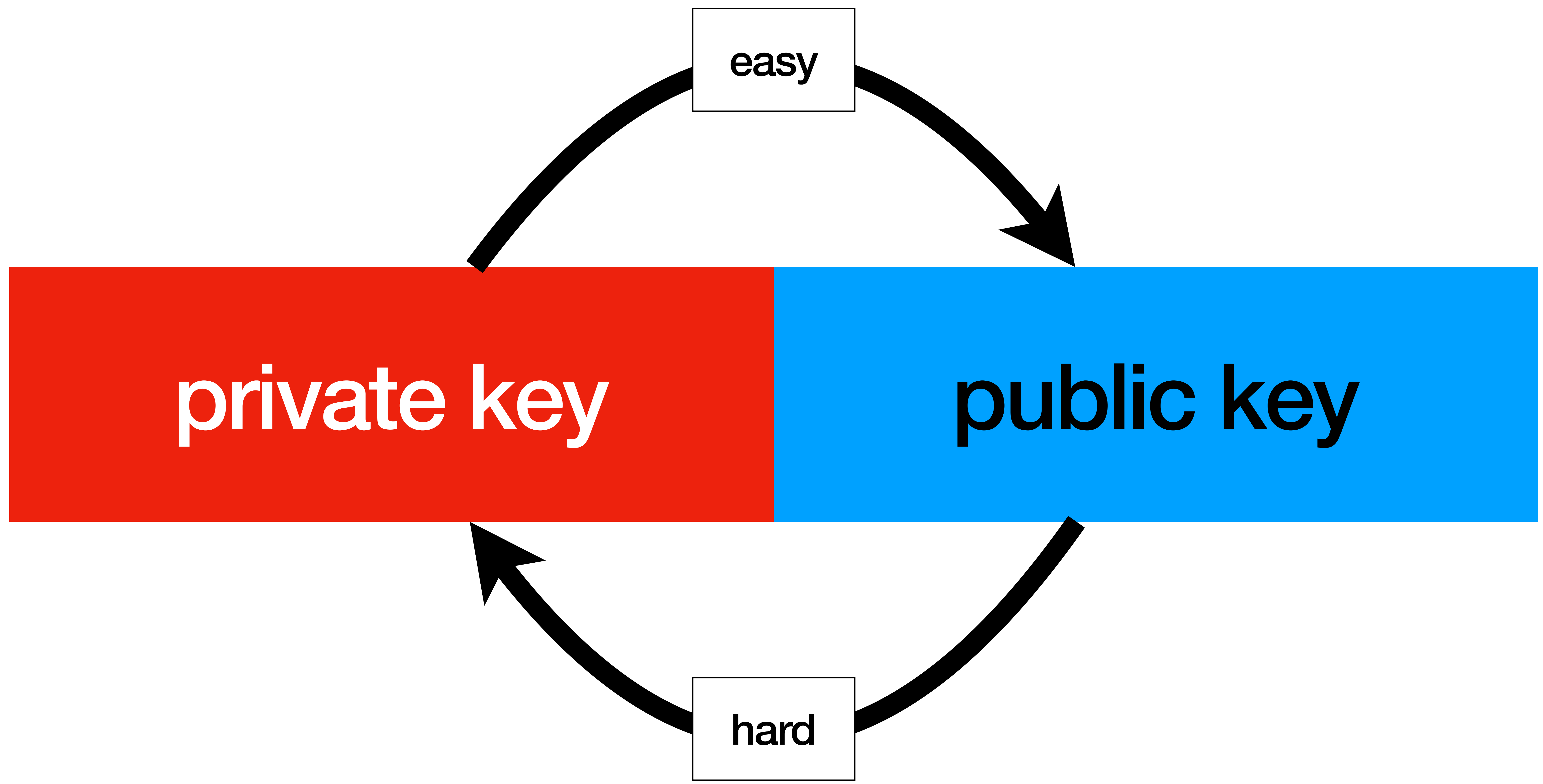
RSA cryptosystem

General	
Designers	Ron Rivest, Adi Shamir, and Leonard Adleman
First published	1977
Certification	PKCS#1, ANSI X9.31
Cipher detail	

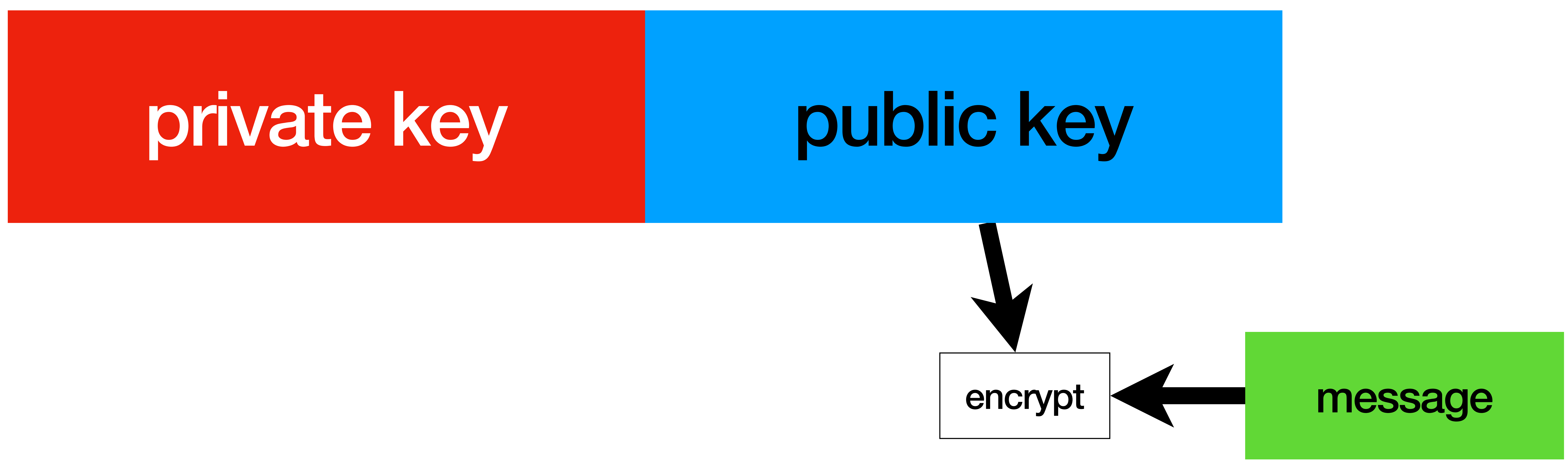
RSA key pair

private key | public key

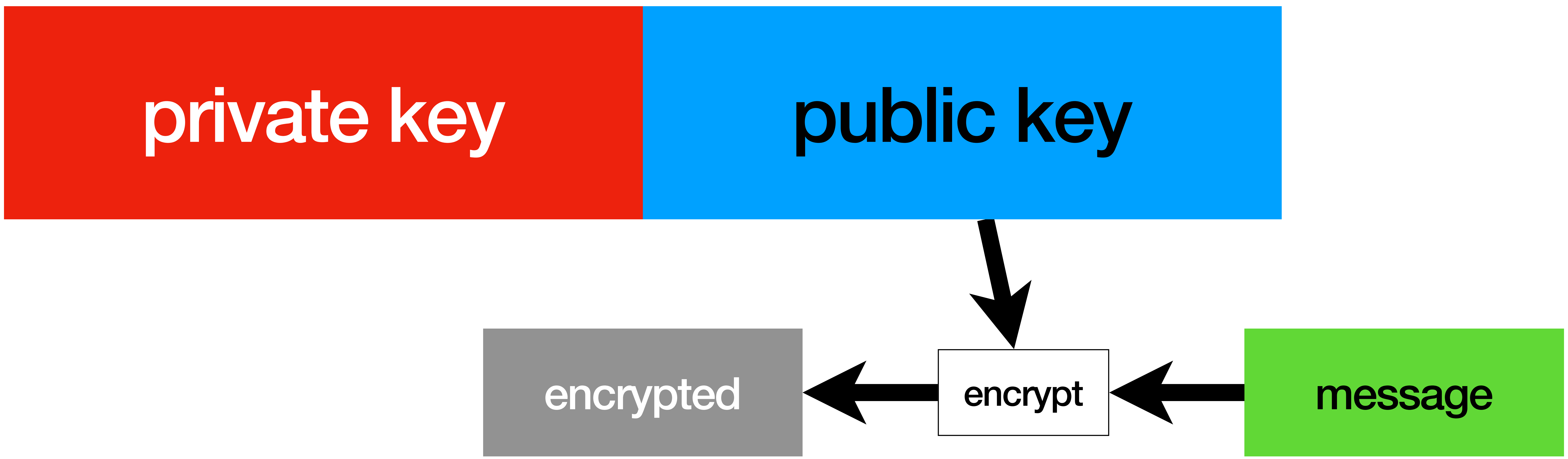
RSA key pair



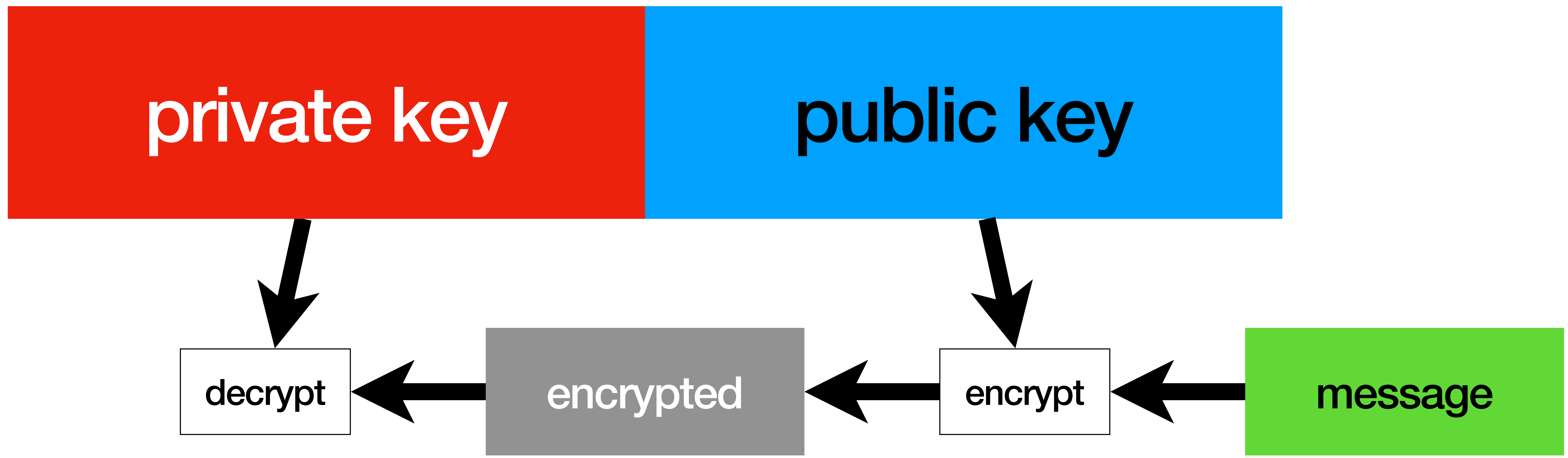
RSA operations



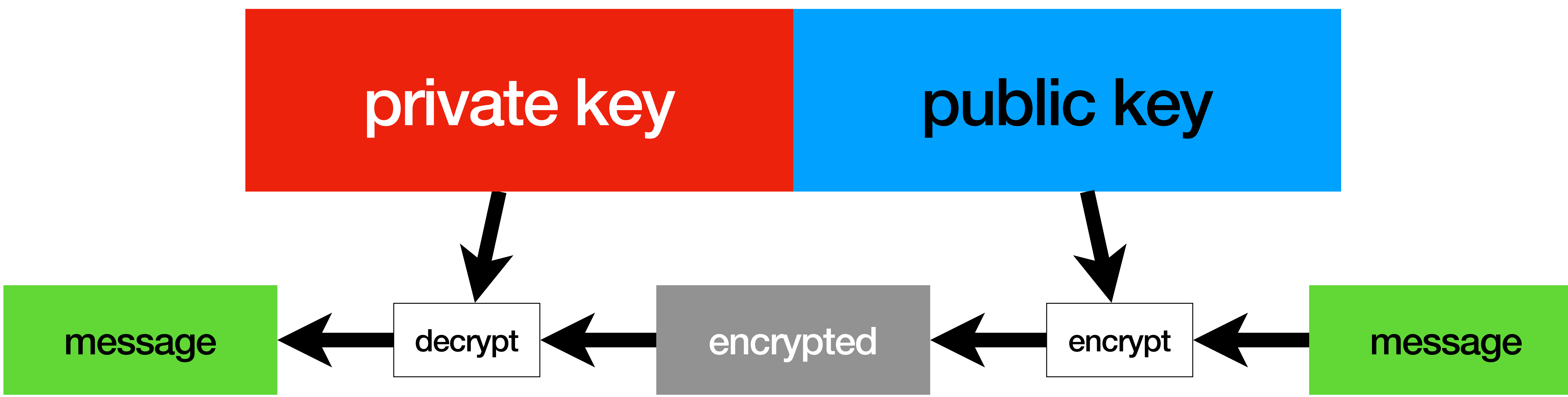
RSA operations



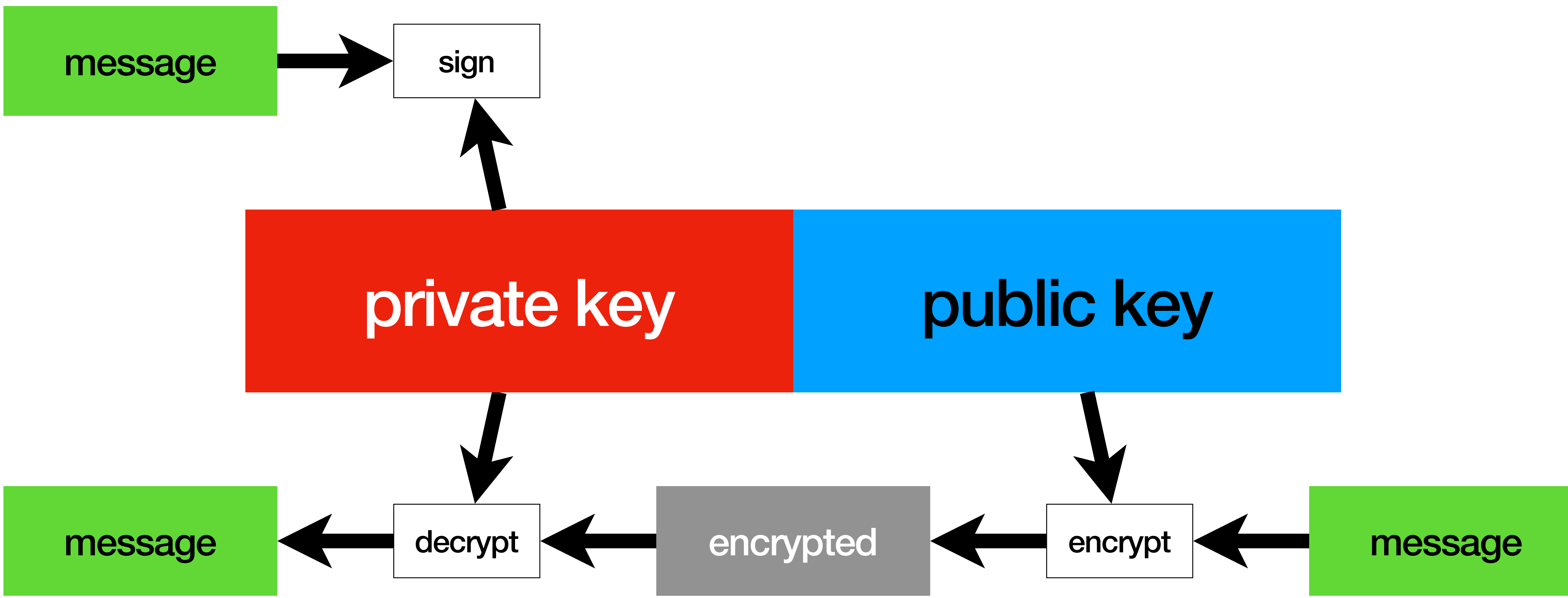
RSA operations



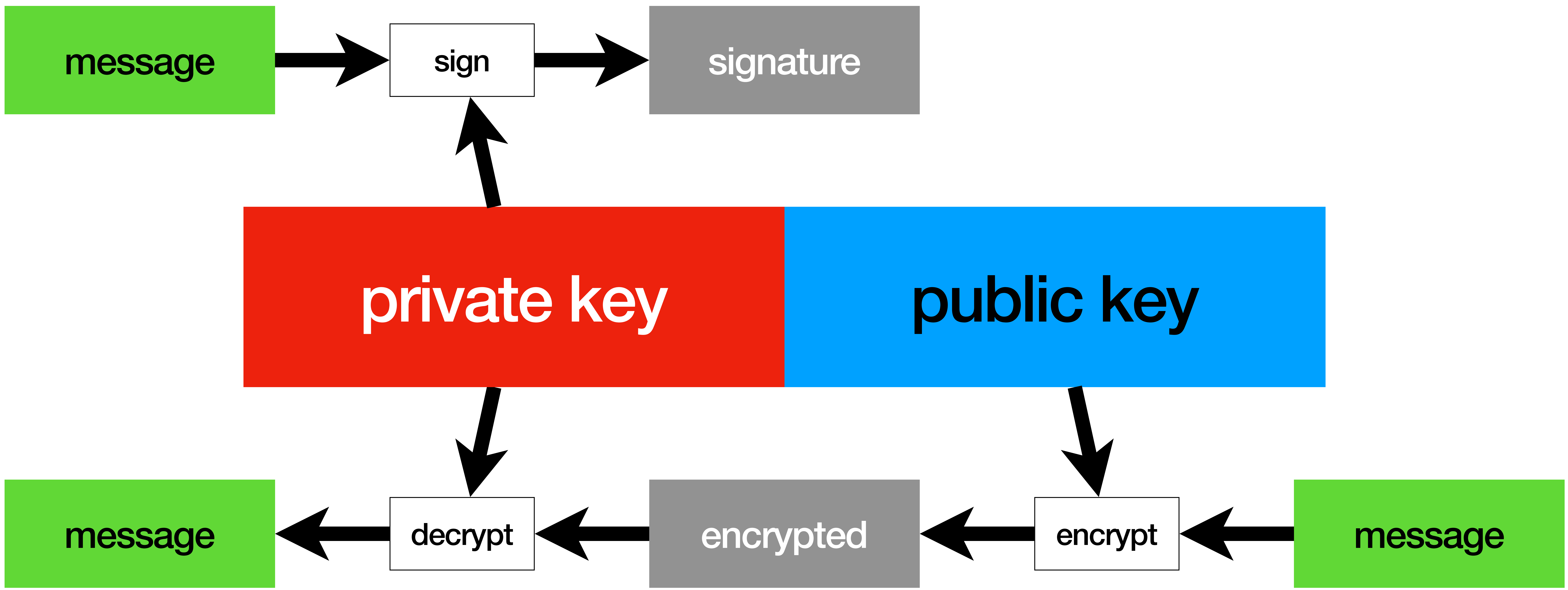
RSA operations



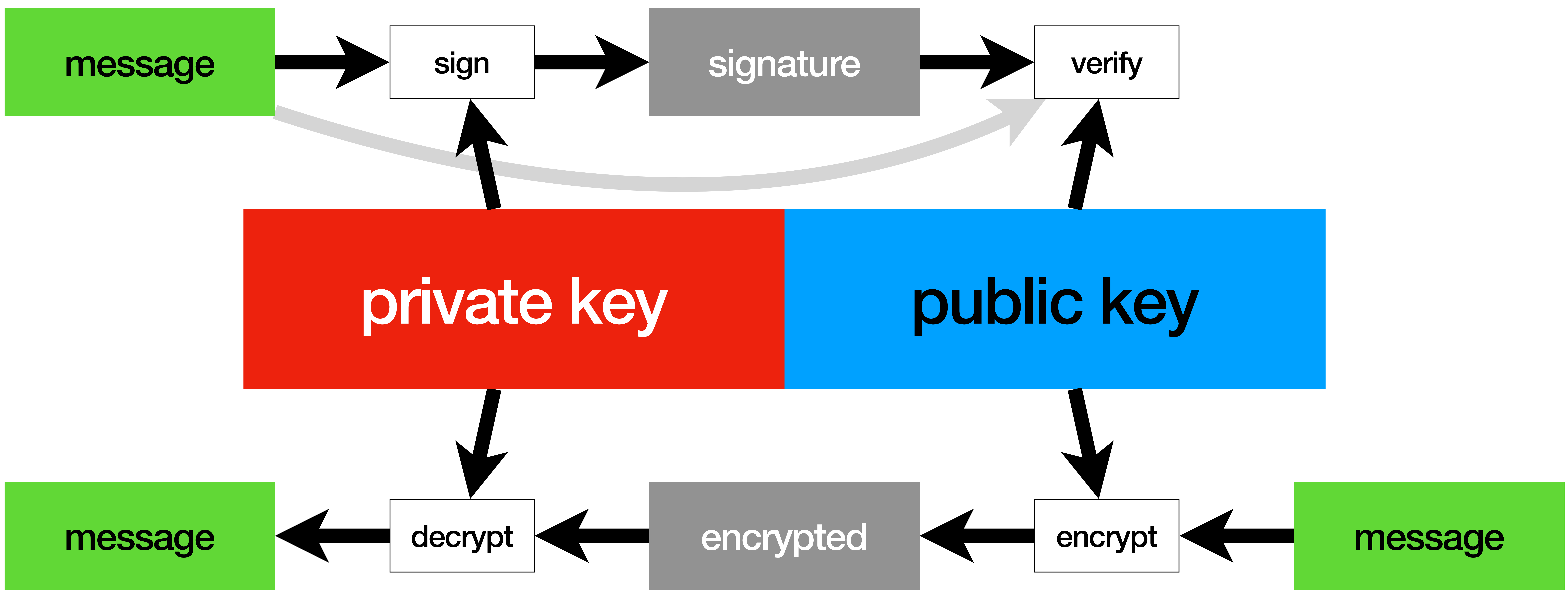
RSA operations



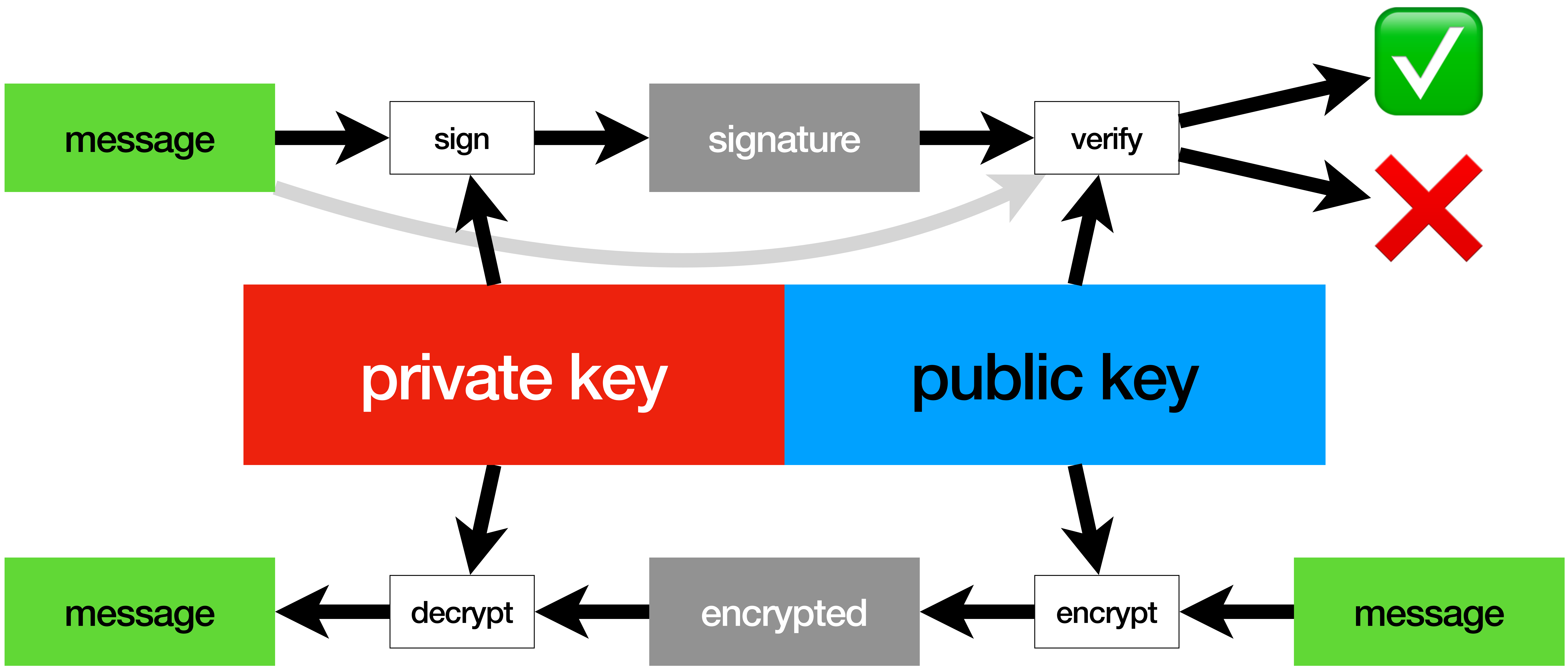
RSA operations



RSA operations



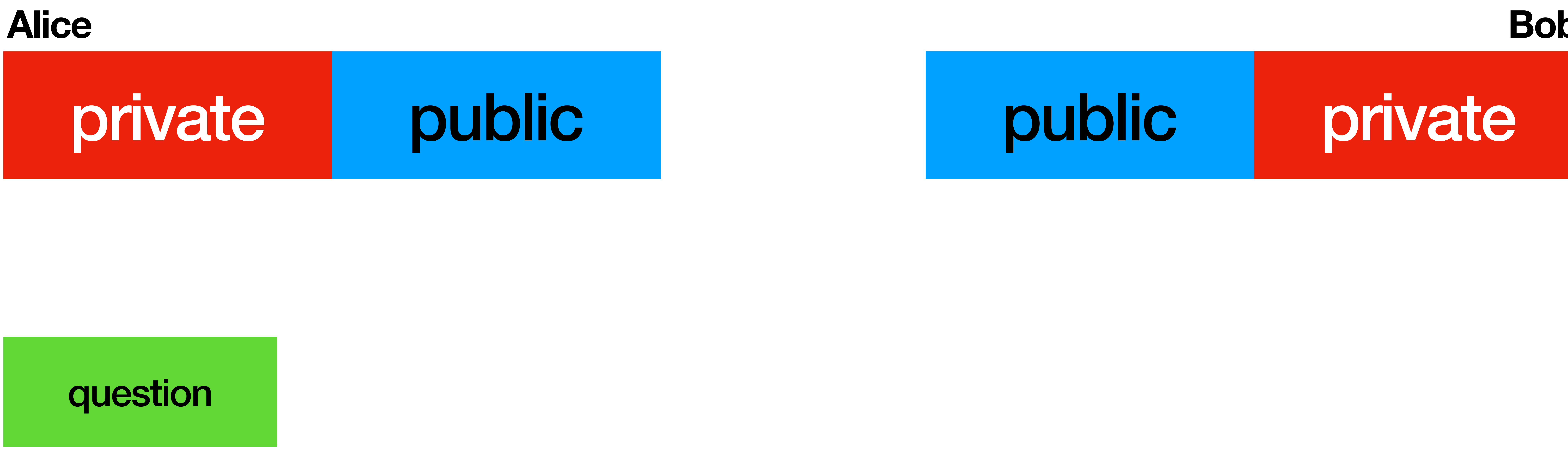
RSA operations



RSA private communication

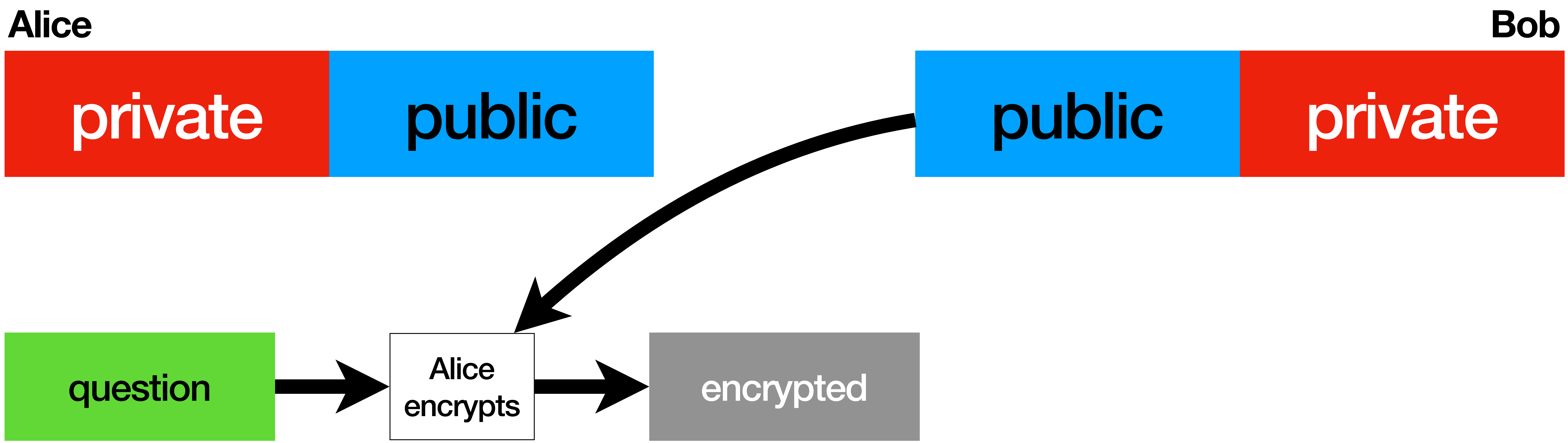
RSA private communication

RSA private communication



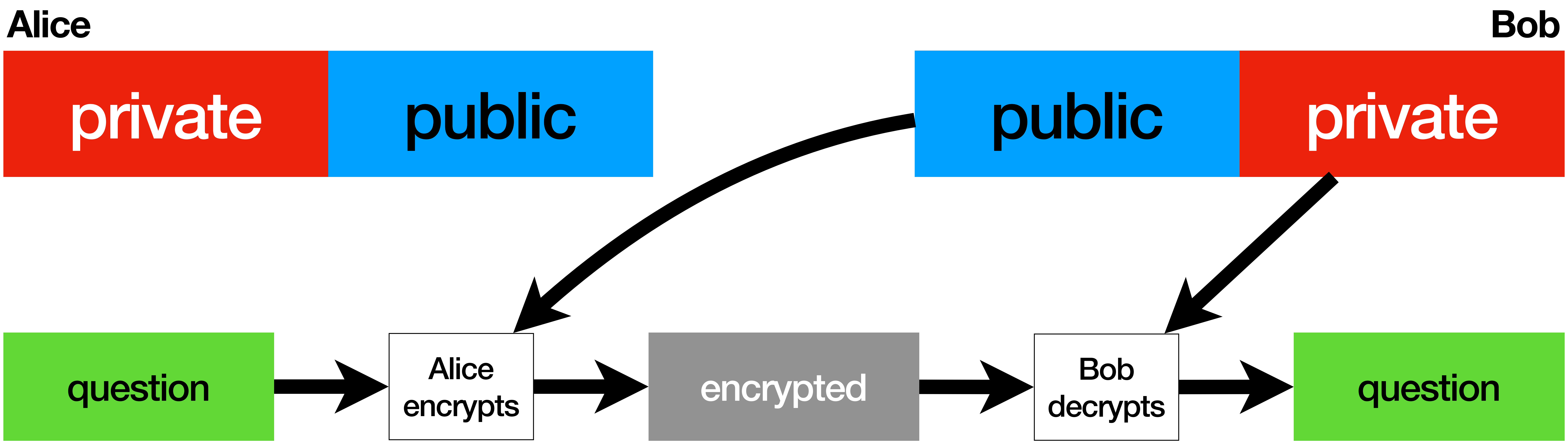
Alice sending a private question to **Bob**

RSA private communication



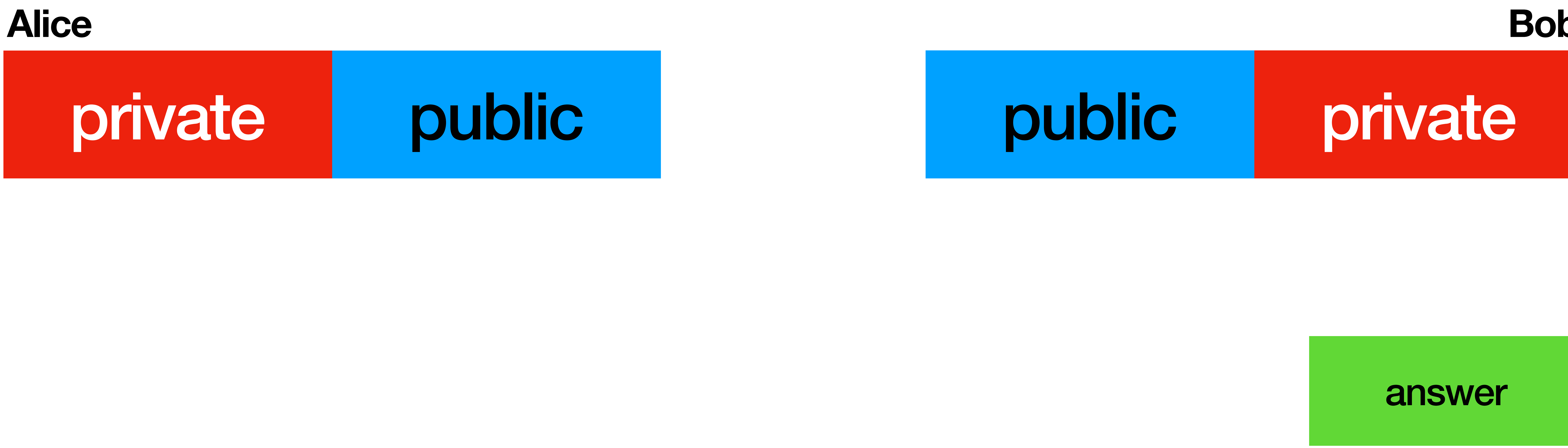
Alice sending a private question to **Bob**

RSA private communication



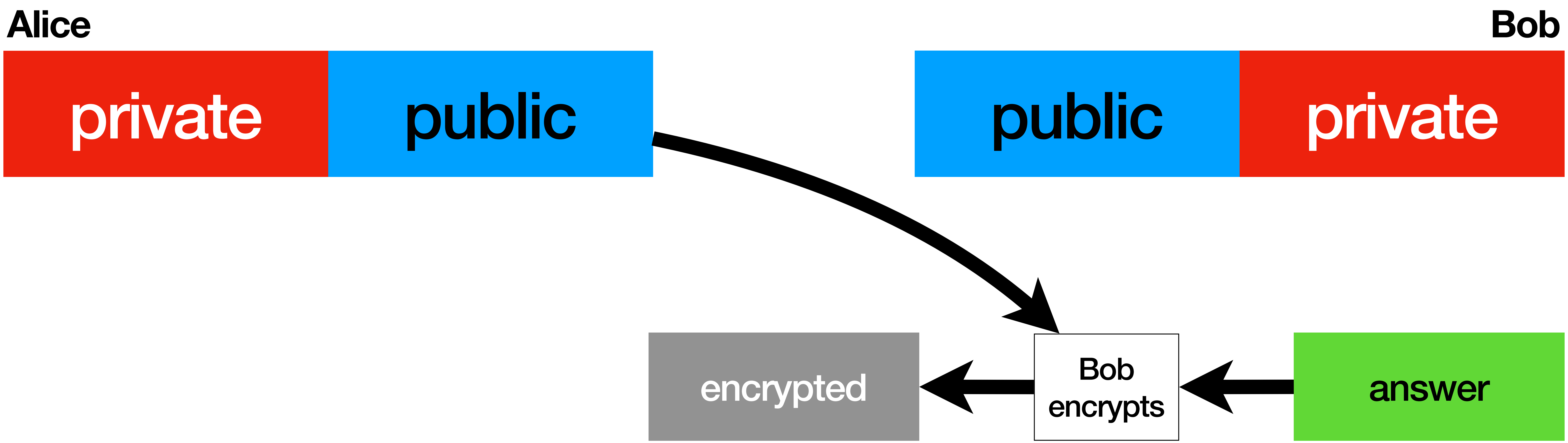
Alice sending a private question to **Bob**

RSA private communication



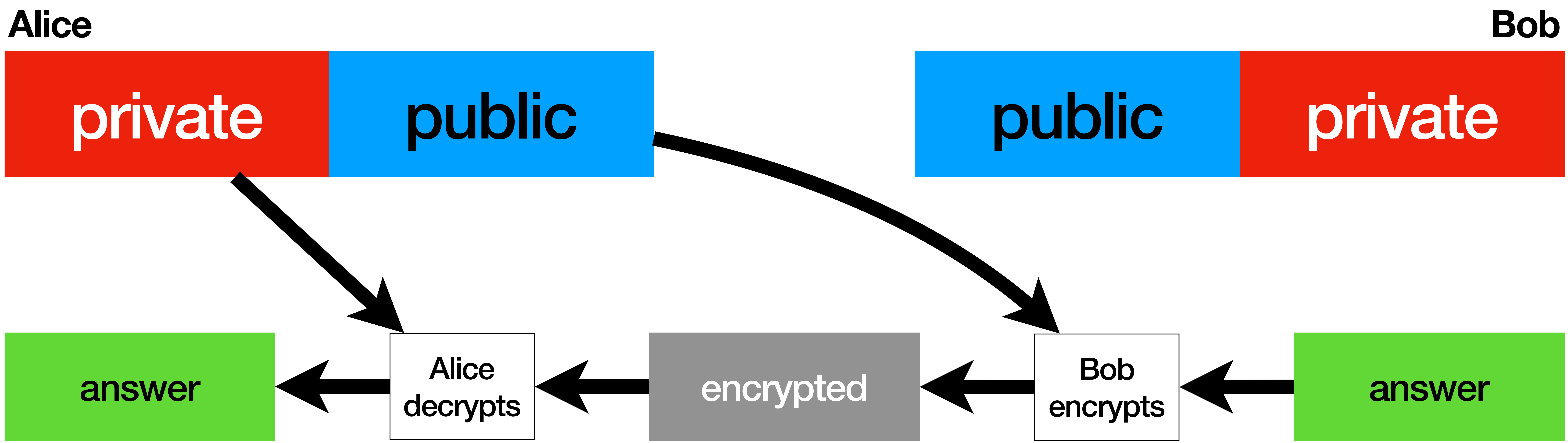
Bob sending a private answer to **Alice**

RSA private communication



Bob sending a private answer to **Alice**

RSA private communication



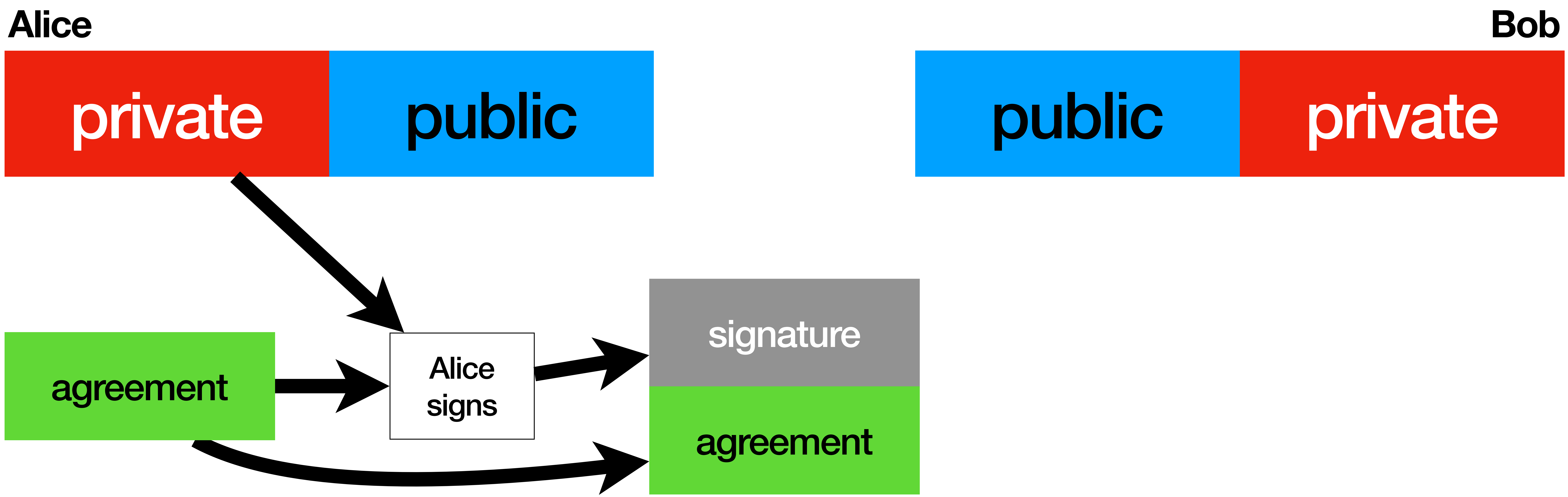
Bob sending a private answer to **Alice**

RSA signing / authentication

RSA signing / authentication

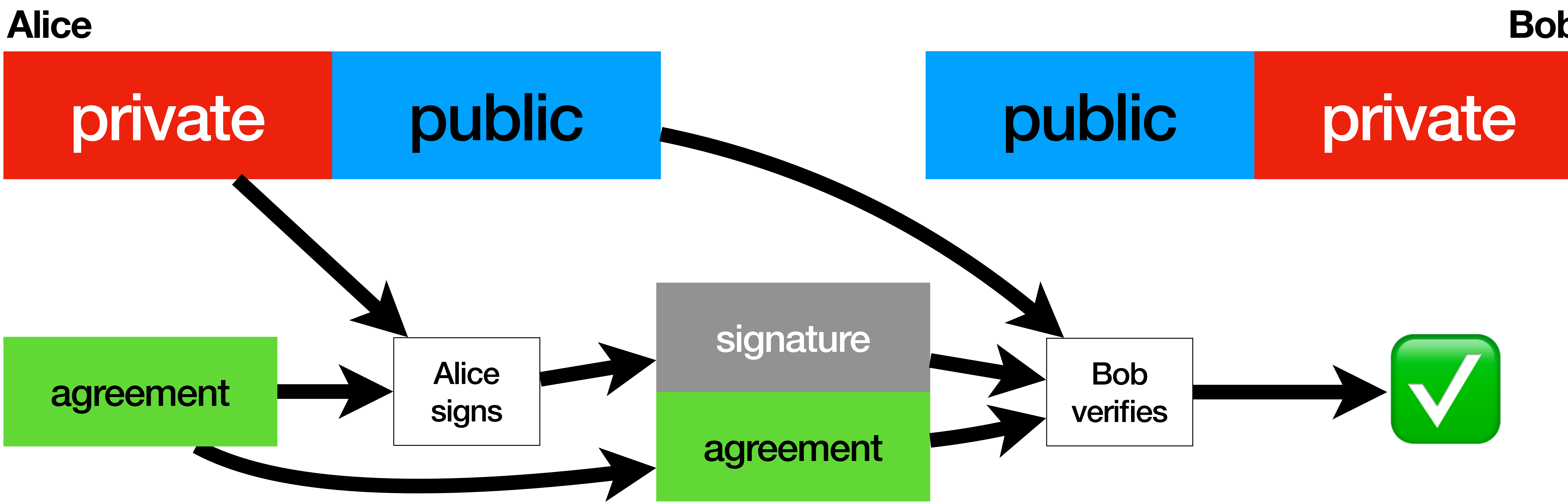
Alice sending an authenticated agreement to **Bob**

RSA signing / authentication



Alice sending an authenticated agreement to **Bob**

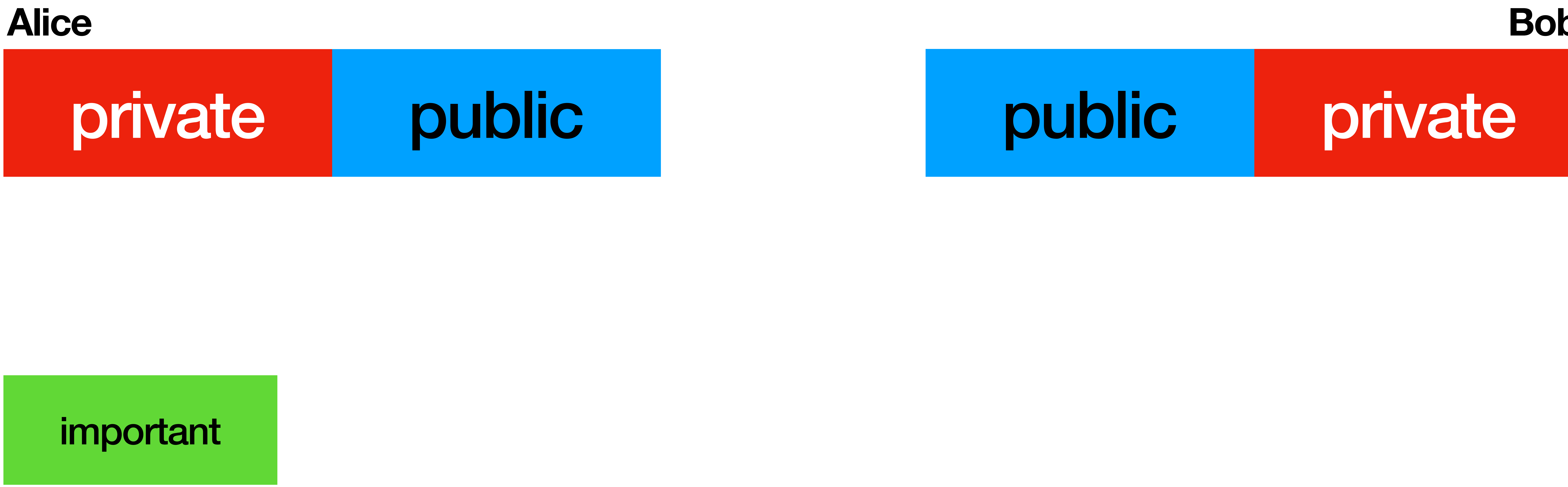
RSA signing / authentication



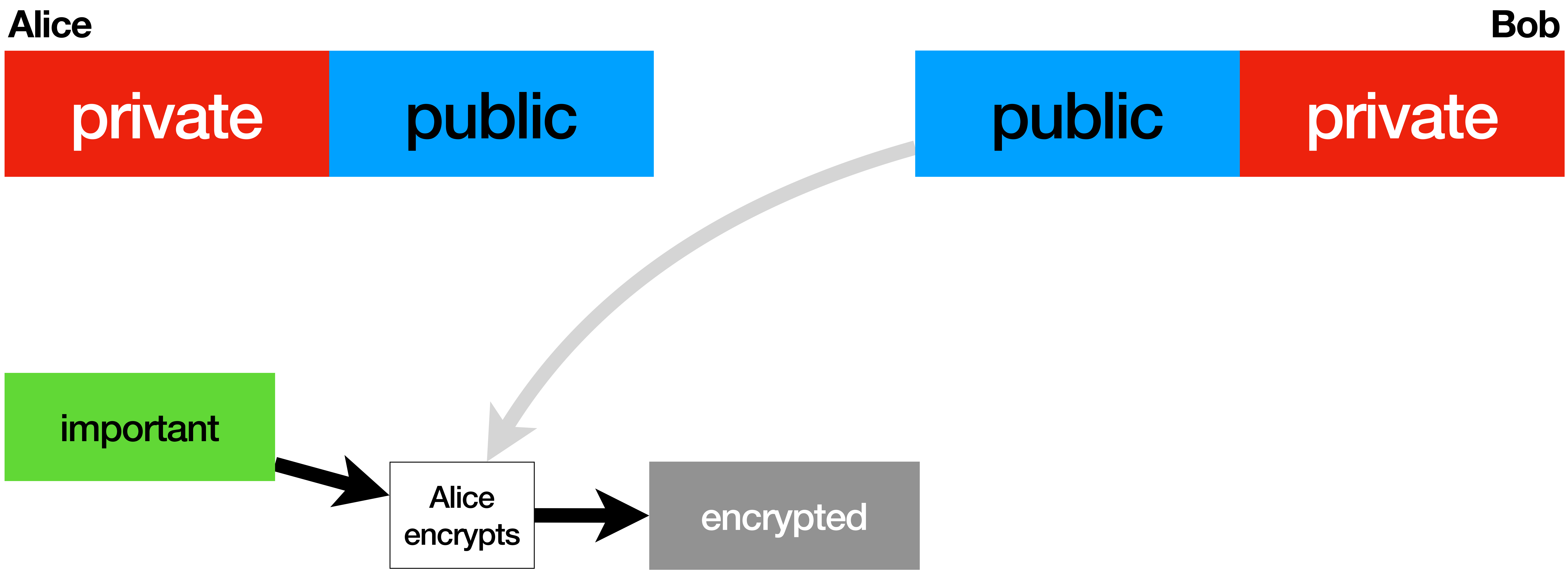
Alice sending an authenticated agreement to **Bob**

RSA private and authenticated

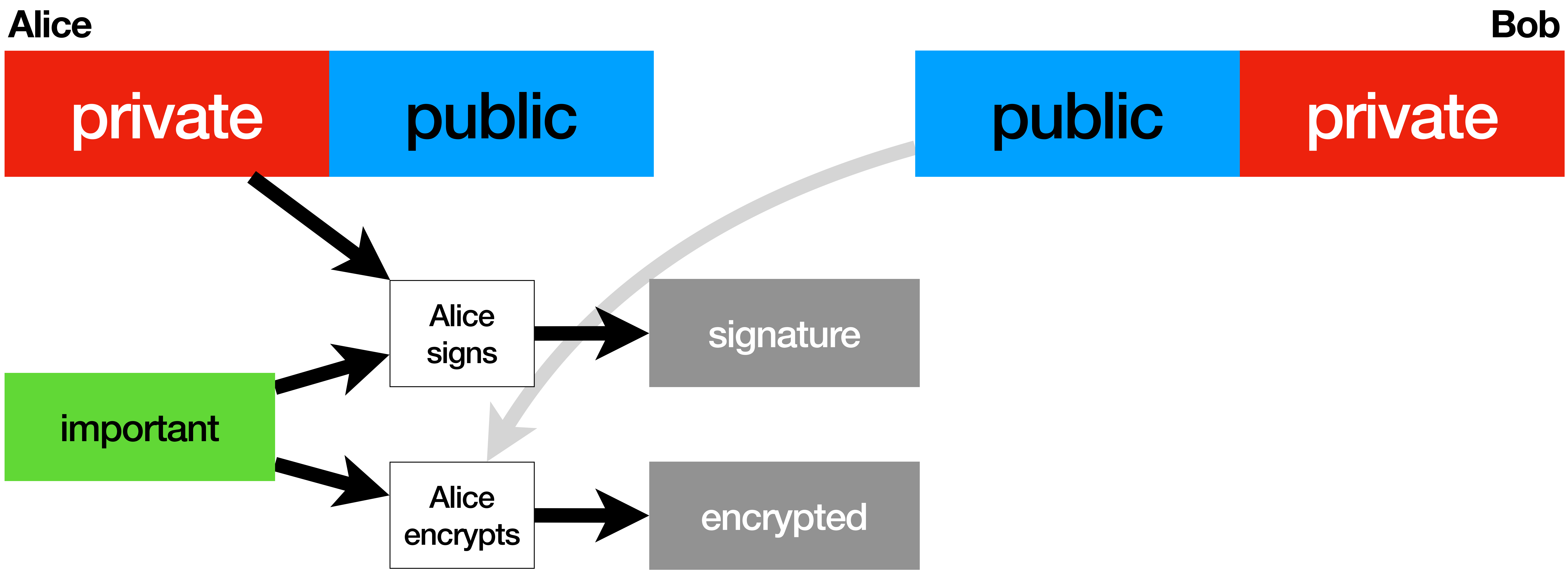
RSA private and authenticated



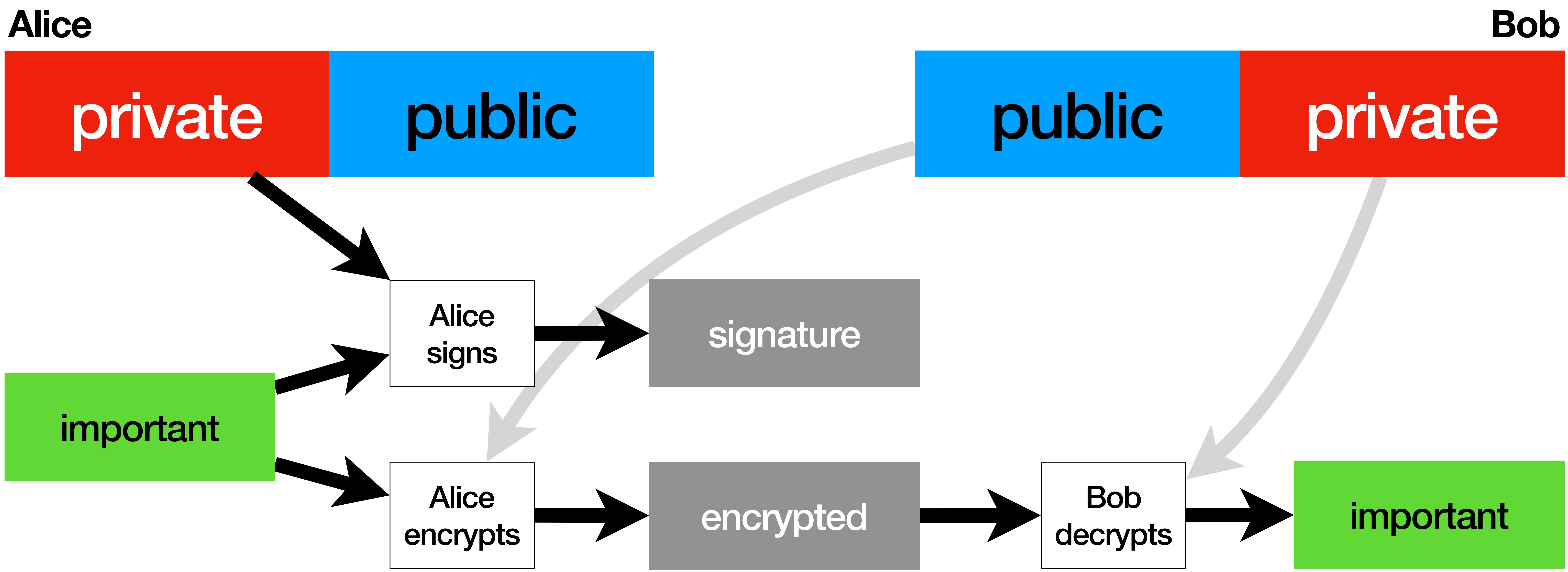
RSA private and authenticated



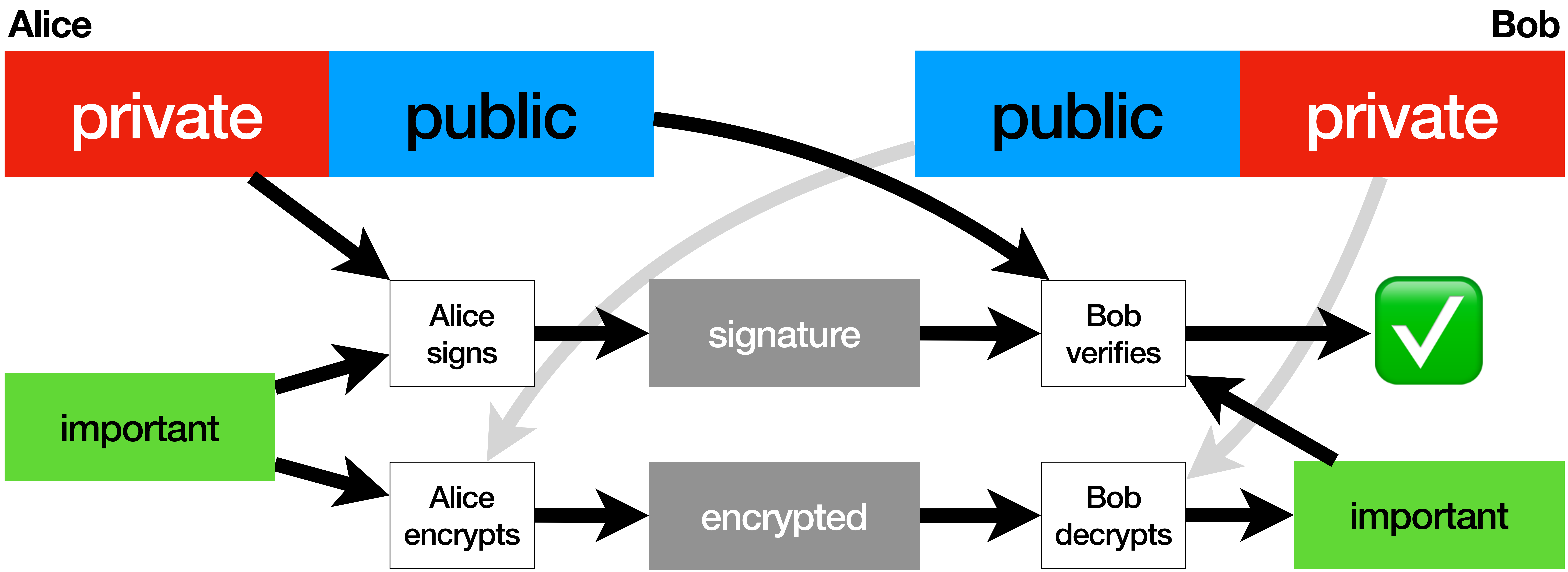
RSA private and authenticated



RSA private and authenticated



RSA private and authenticated



RSA

https://github.com/tmontes/pyconpt2026-tm-iaaca

RSA

no way this is enough

X.509 Certificates

X.509 Certificates

issuer name
subject name
valid from
valid to
public key
signature

X.509 Certificates

issuer name
subject name
valid from
valid to
public key
signature

Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

X.509 Certificates

issuer name
subject name
valid from
valid to
public key *the subject's*
signature *the issuer's*

Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

X.509 Certificates

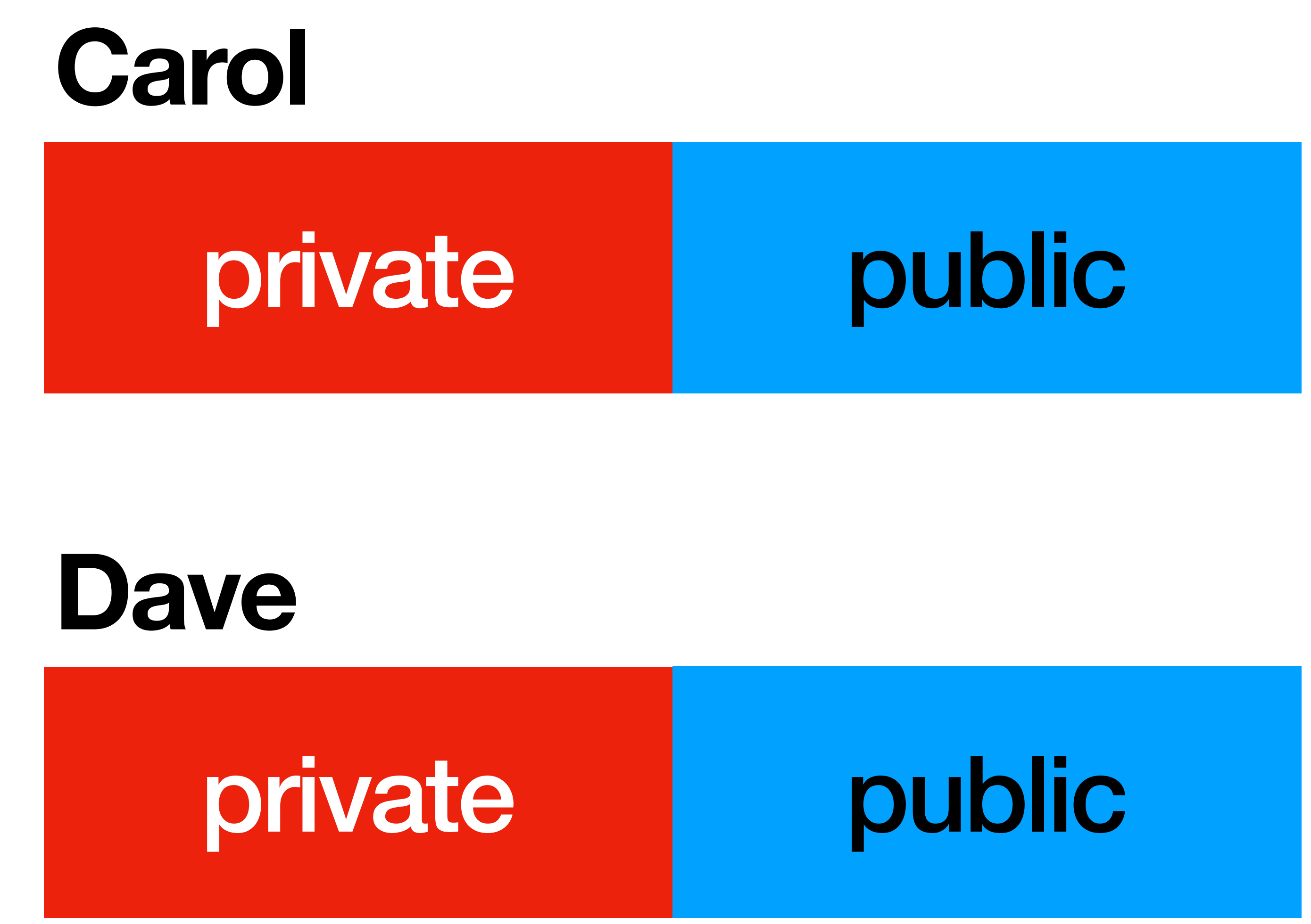
issuer name
subject name
valid from
valid to
public key *the subject's*
signature *the issuer's*

Issuer certifies,
by **signing** the document:

- This **public key**
- Belongs to this **Subject**
- During this **period**

Certificates provide **Identity Assurance**

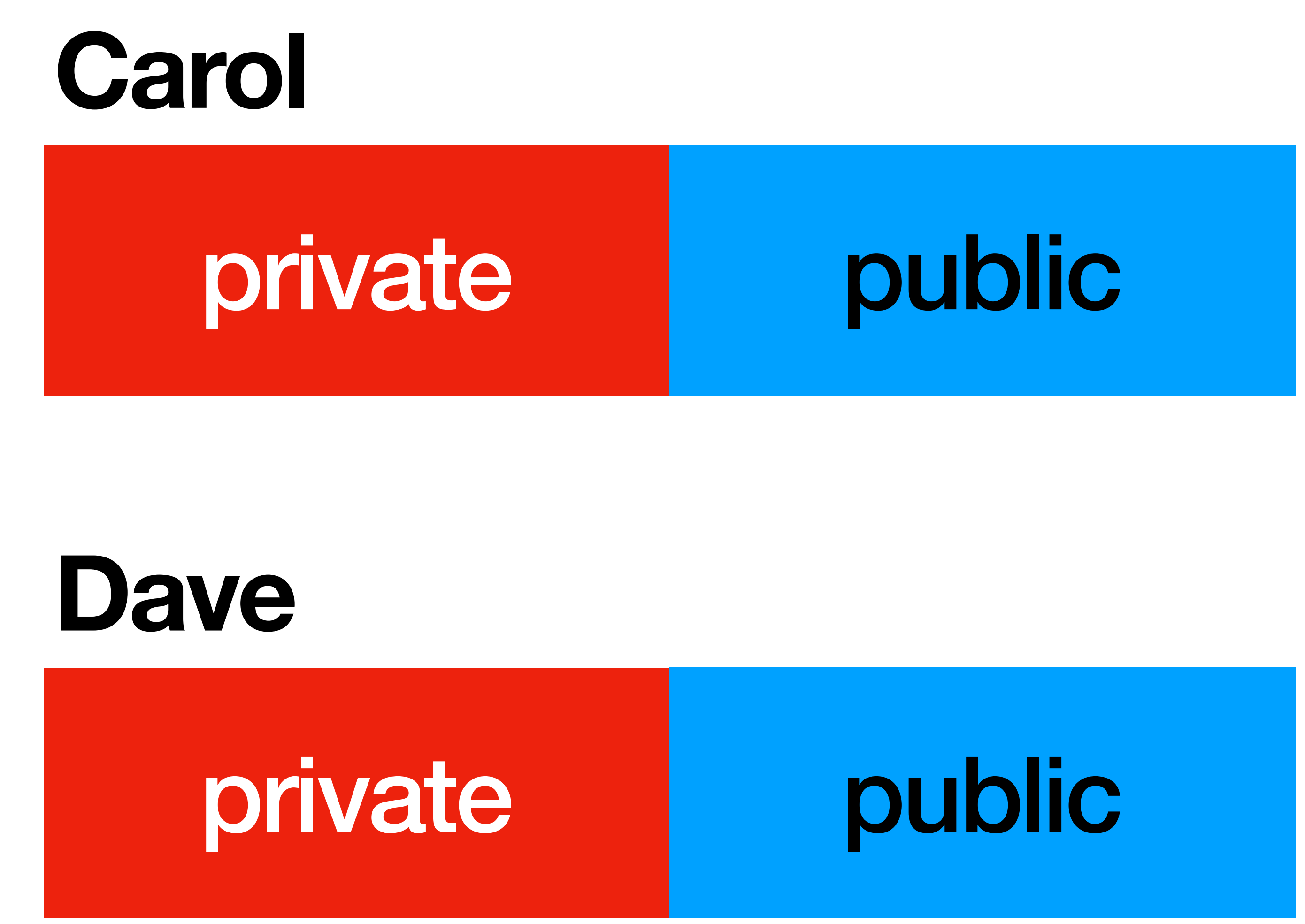
X.509 Certificates



Carol certifying this public key is **Dave's**

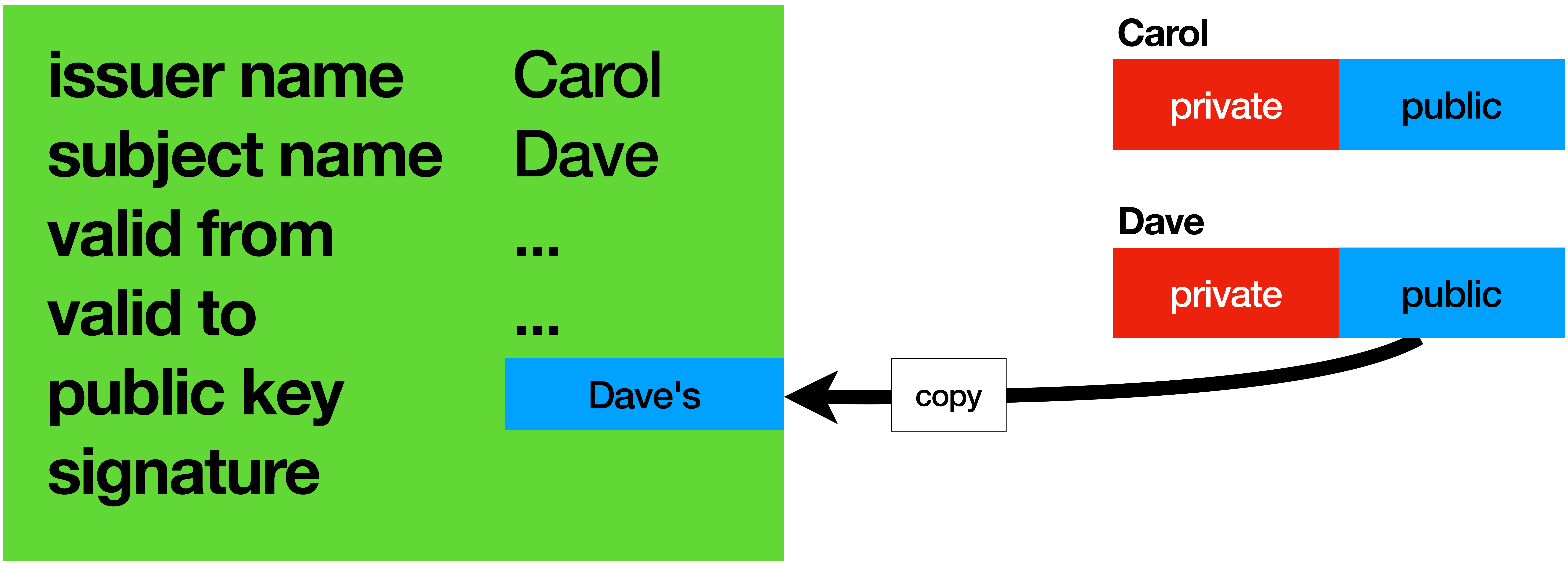
X.509 Certificates

issuer name	Carol
subject name	Dave
valid from	...
valid to	...
public key	
signature	



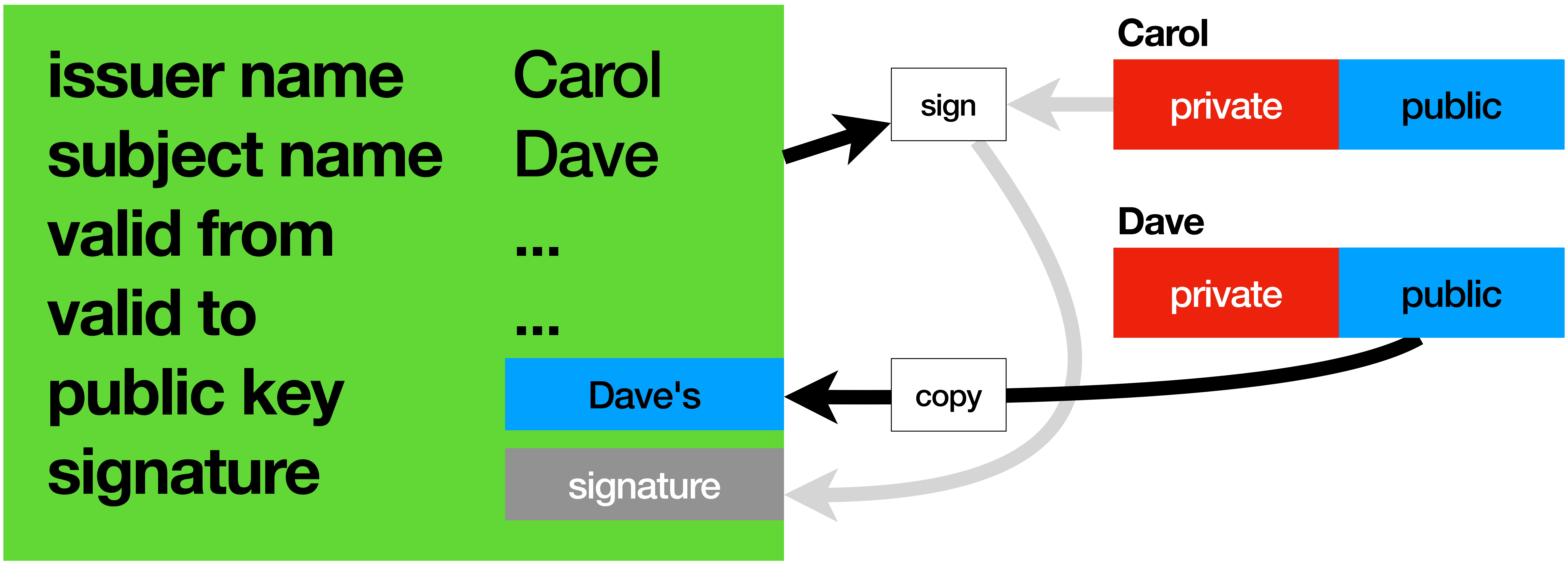
Carol certifying this public key is **Dave's**

X.509 Certificates



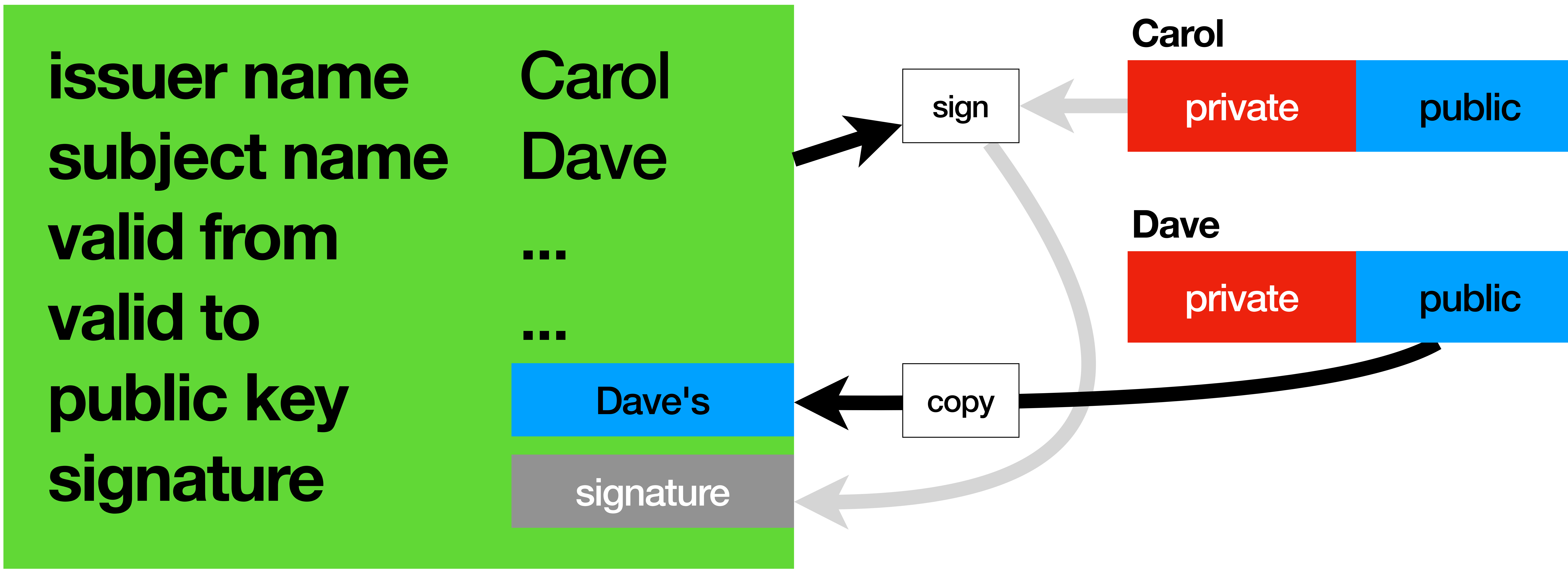
Carol certifying this public key is **Dave's**

X.509 Certificates



Carol certifying this public key is **Dave's**

X.509 Certificates



Certificates hold no secrets and are **public.**

X.509 Self-Signed Certificates

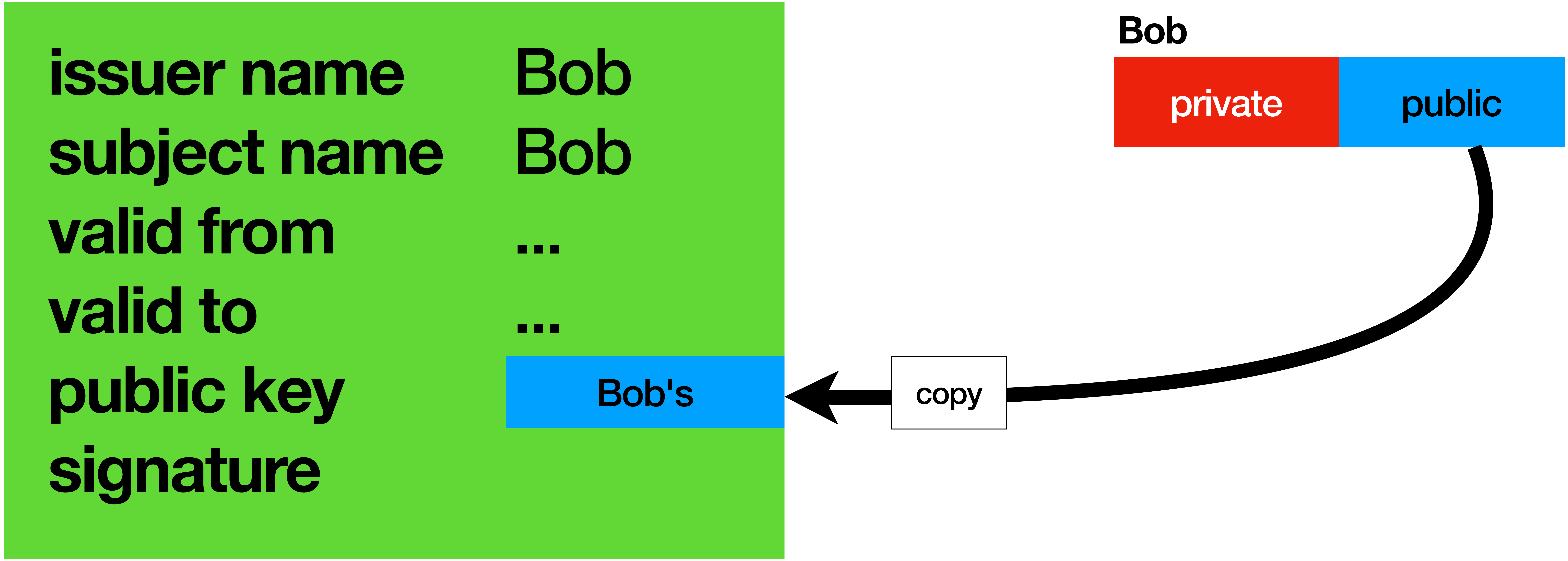
X.509 Self-Signed Certificates

issuer name	Bob
subject name	Bob
valid from	...
valid to	...
public key	
signature	

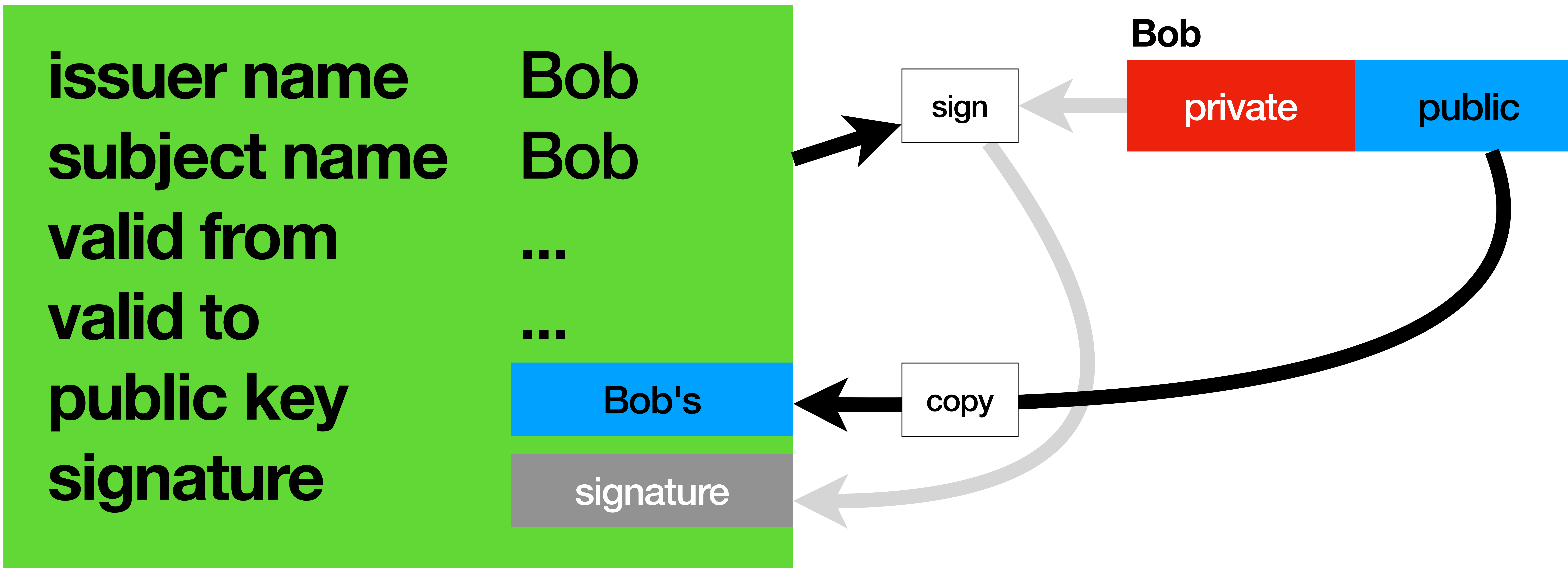
Bob

private	public

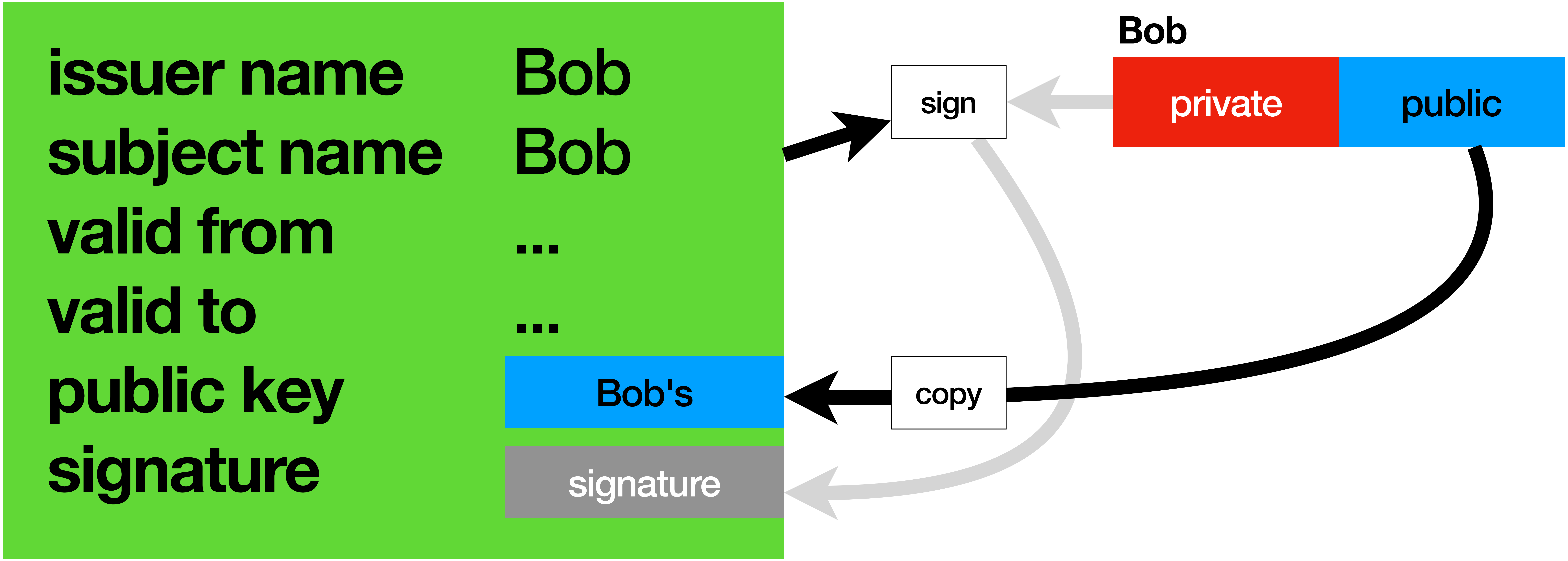
X.509 Self-Signed Certificates



X.509 Self-Signed Certificates



X.509 Self-Signed Certificates



Self-Signed Certificates are **auto proclamations of Identity**

Certificates

Certificates

no way self-signed certificates are enough

Certificate Authorities

Certificate Authorities

- Issue **Certificates**, by **signing** them

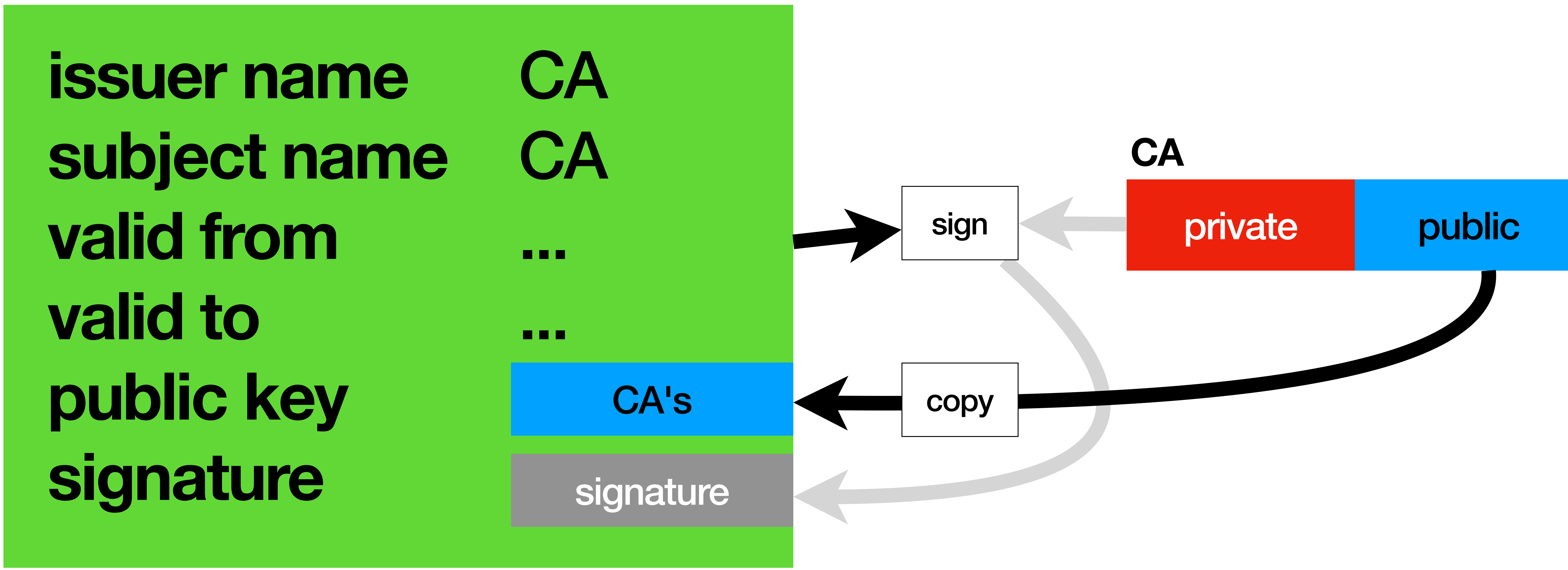
Certificate Authorities

- Issue **Certificates**, by **signing** them
- Using their own **private** key

Certificate Authorities

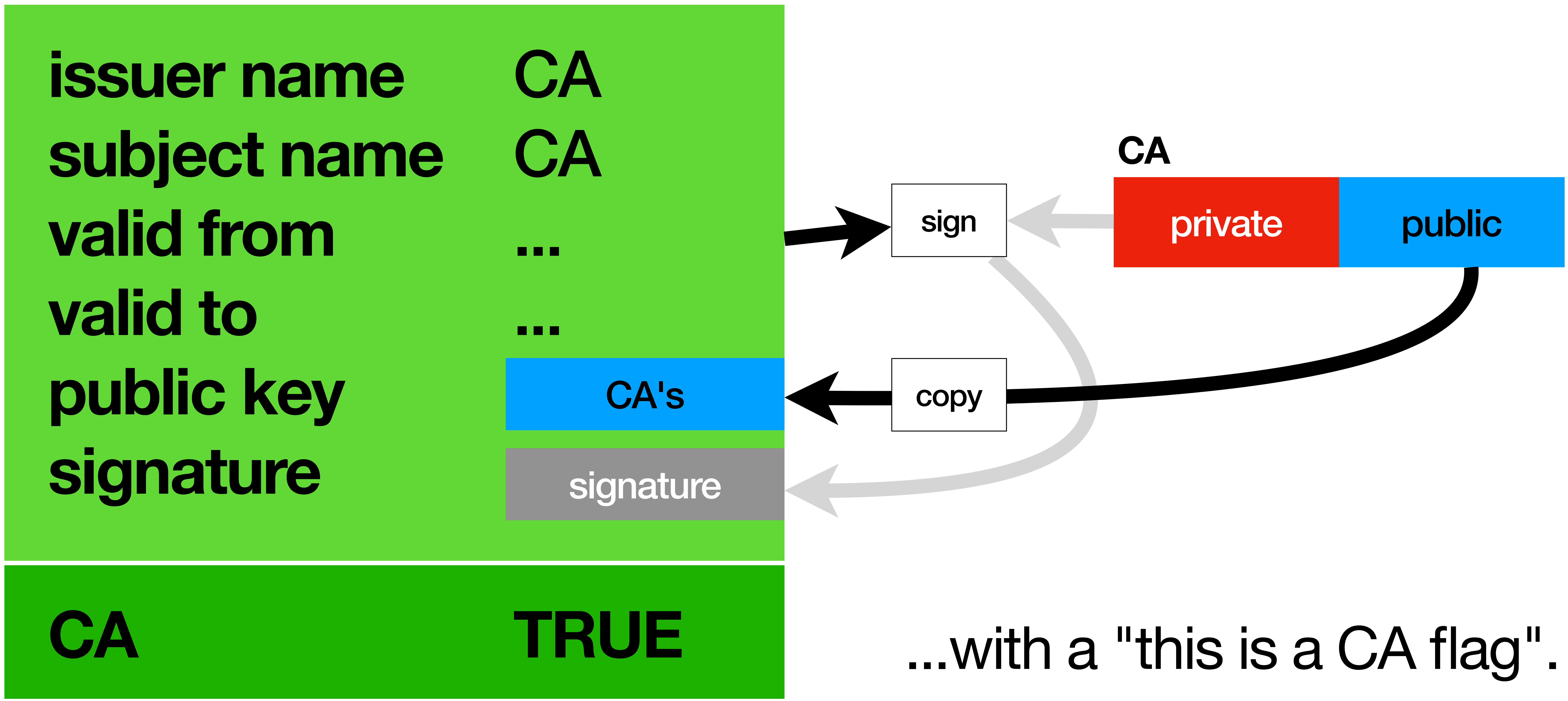
- Issue **Certificates**, by **signing** them
- Using their own **private** key
- And claim their own **Identity** via a **Self-Signed Certificate**

Certificate Authorities



Certificate Authorities are built on **Self-Signed Certificates**

Certificate Authorities



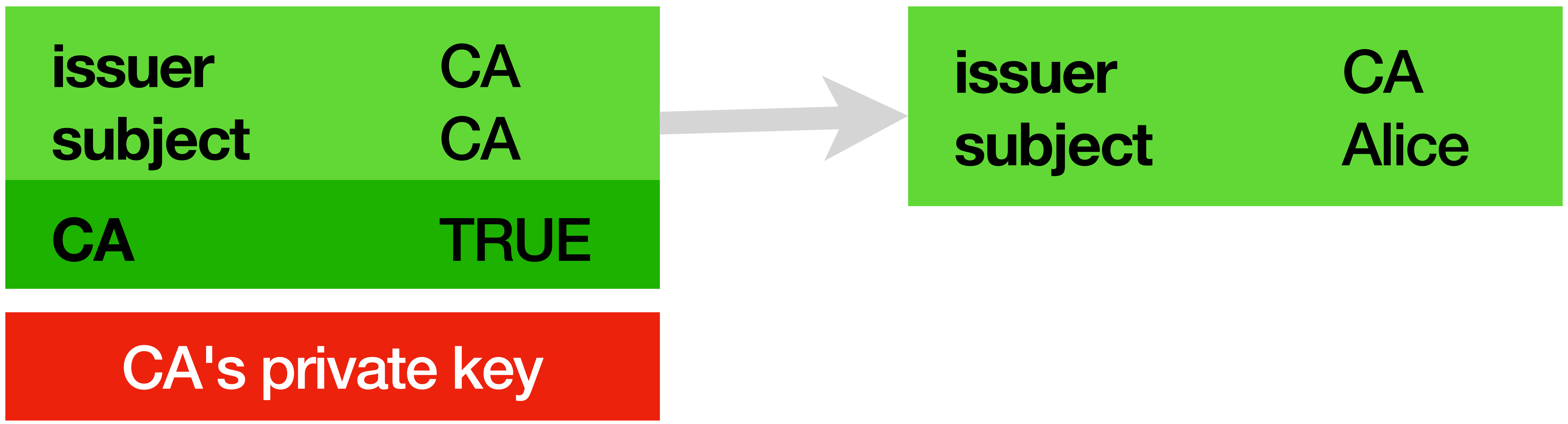
...with a "this is a CA flag".

Certificate Authorities

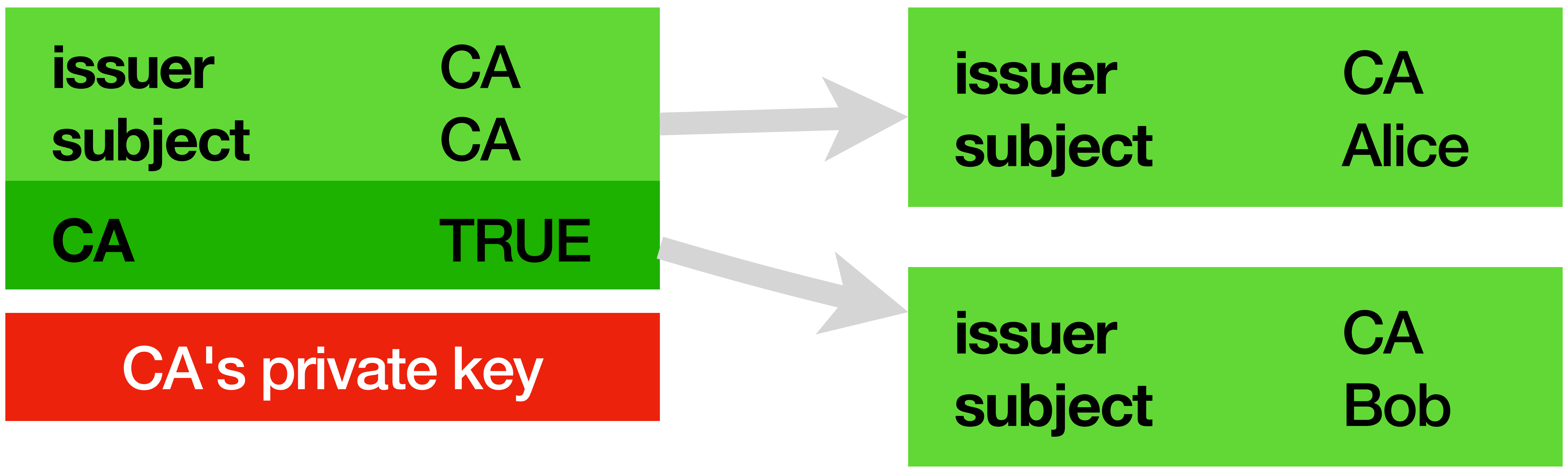
issuer	CA
subject	CA
CA	TRUE

CA's private key

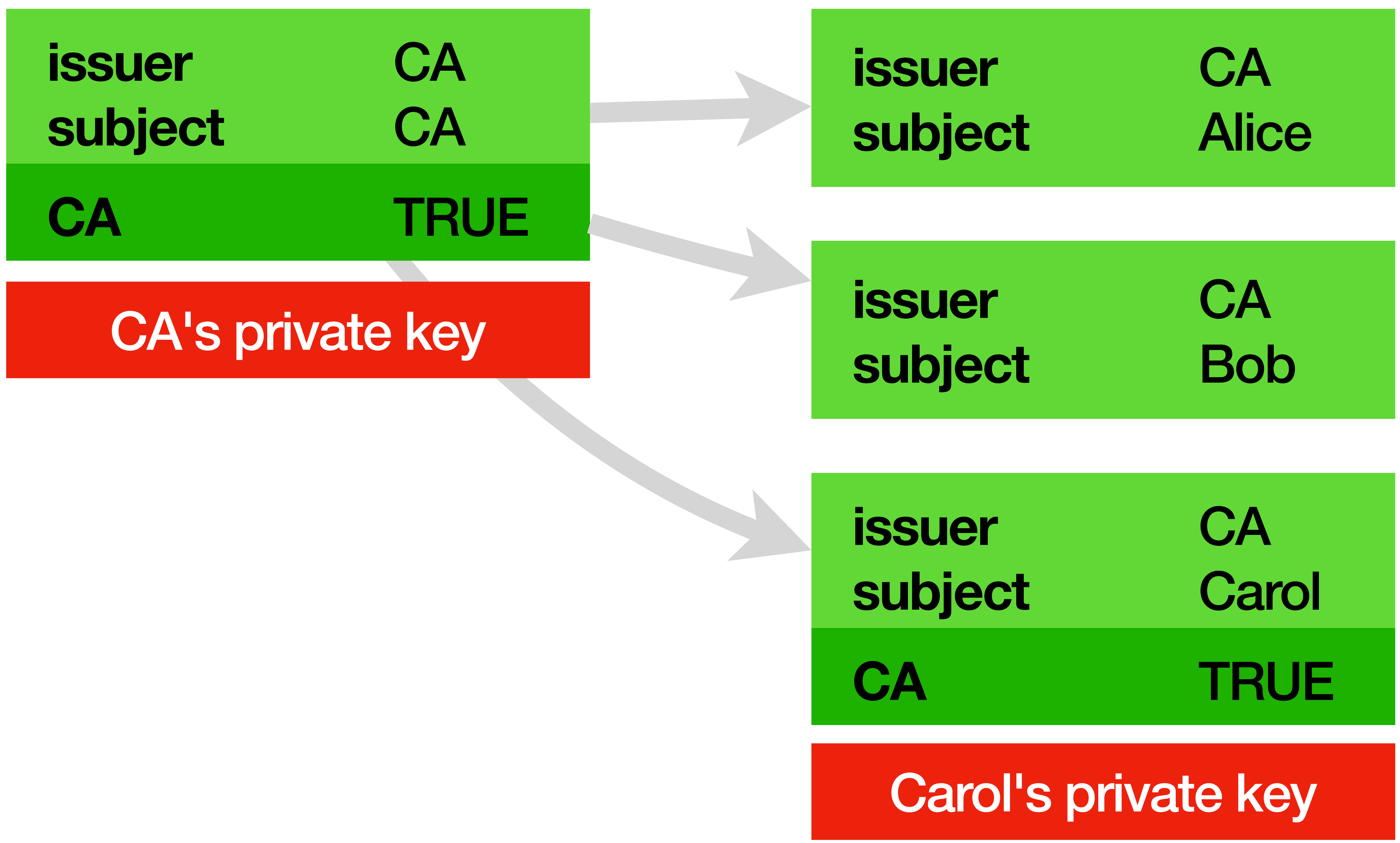
Certificate Authorities



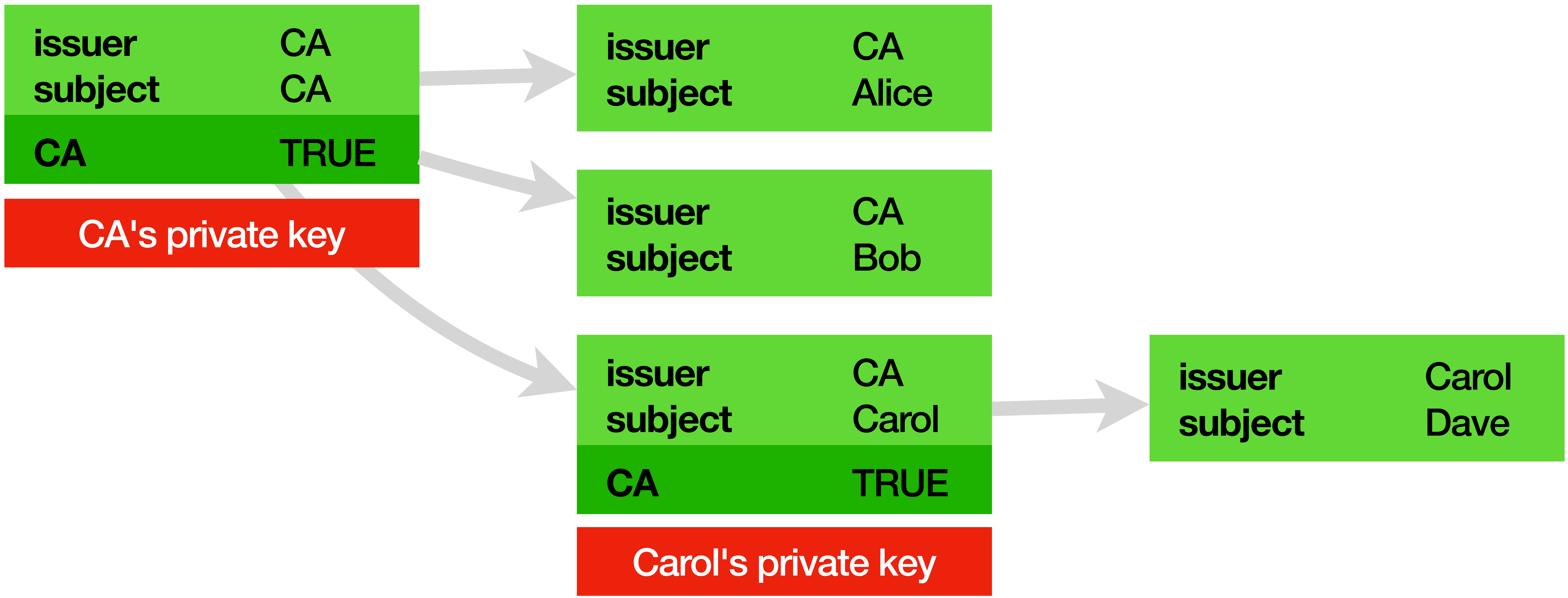
Certificate Authorities



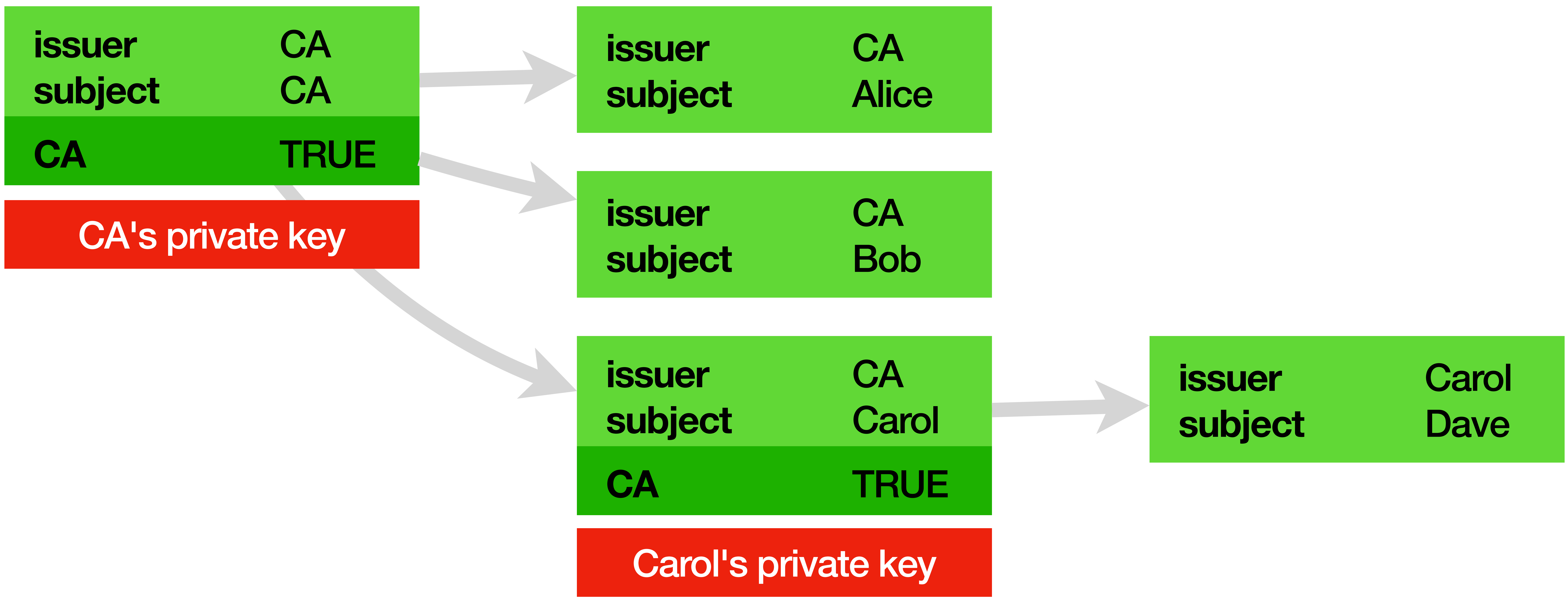
Certificate Authorities



Certificate Authorities

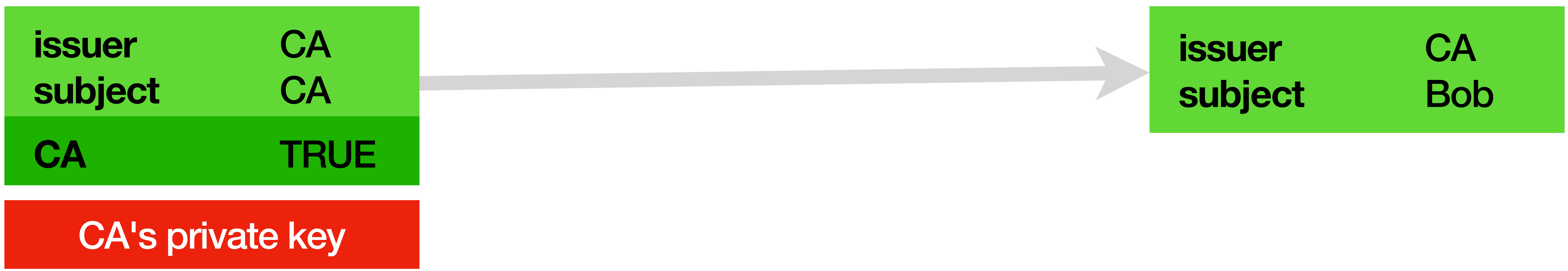


Certificate Authorities

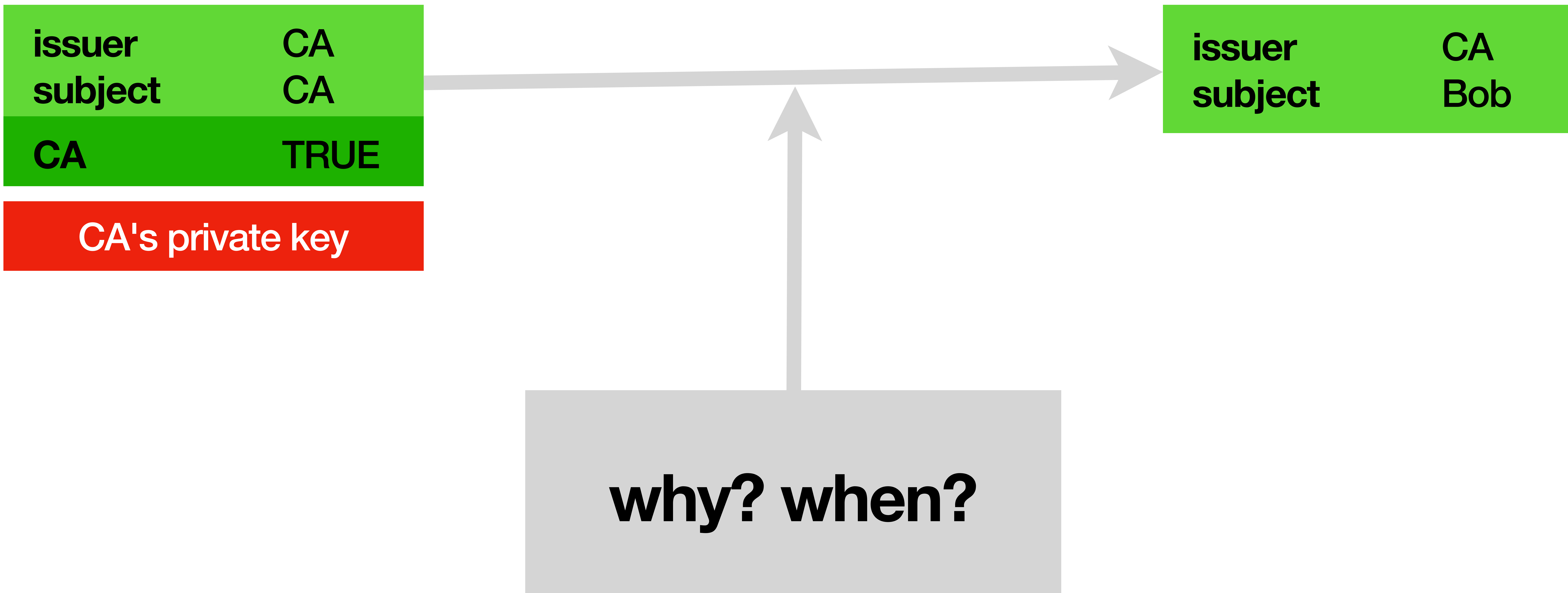


...turtles all the way down.

Certificate Authorities



Certificate Authorities



Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private	public

Bob

private	public

Certificate Authorities

issuer	CA
subject	CA
CA	TRUE

CA

private | public

Bob

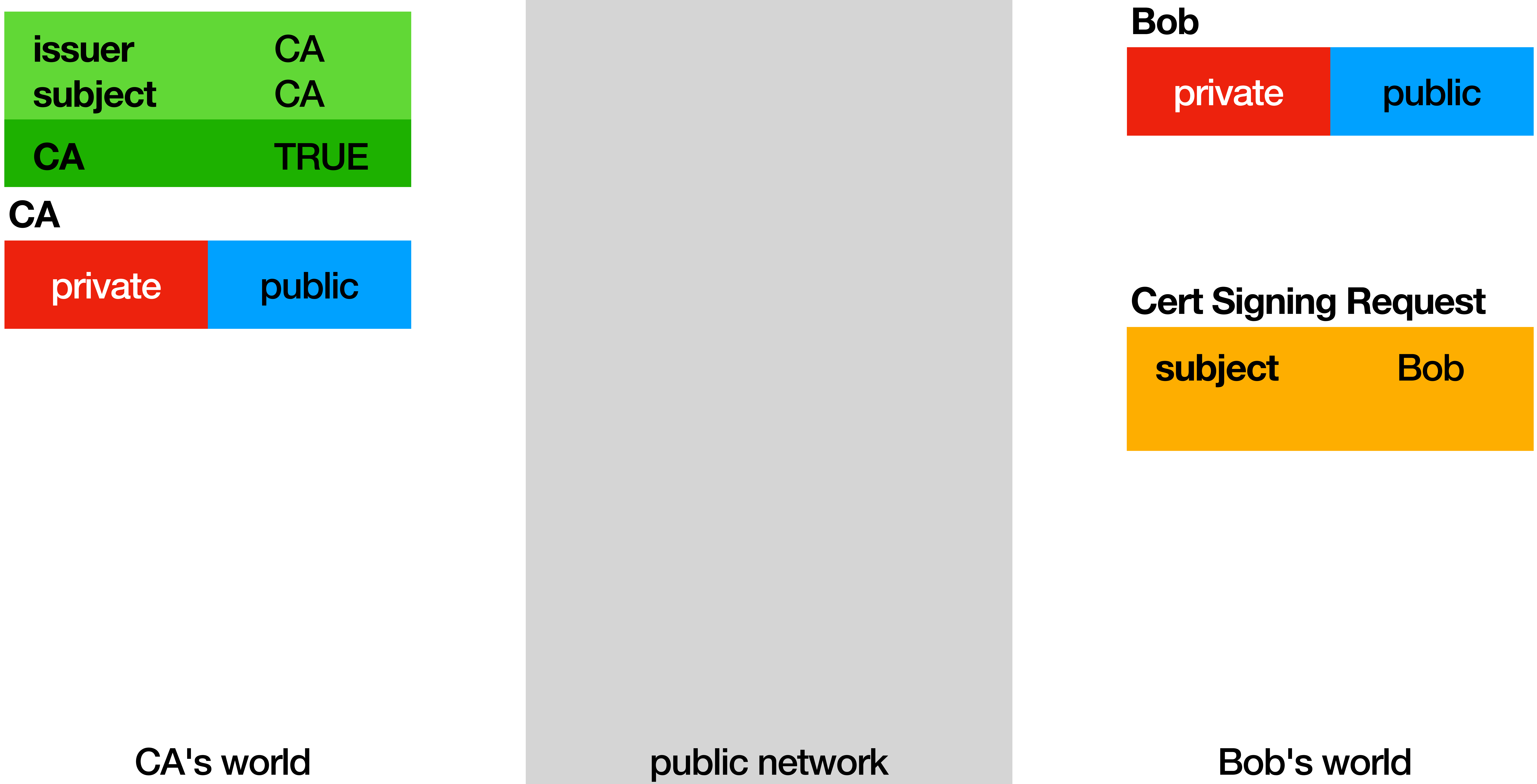
private | public

CA's world

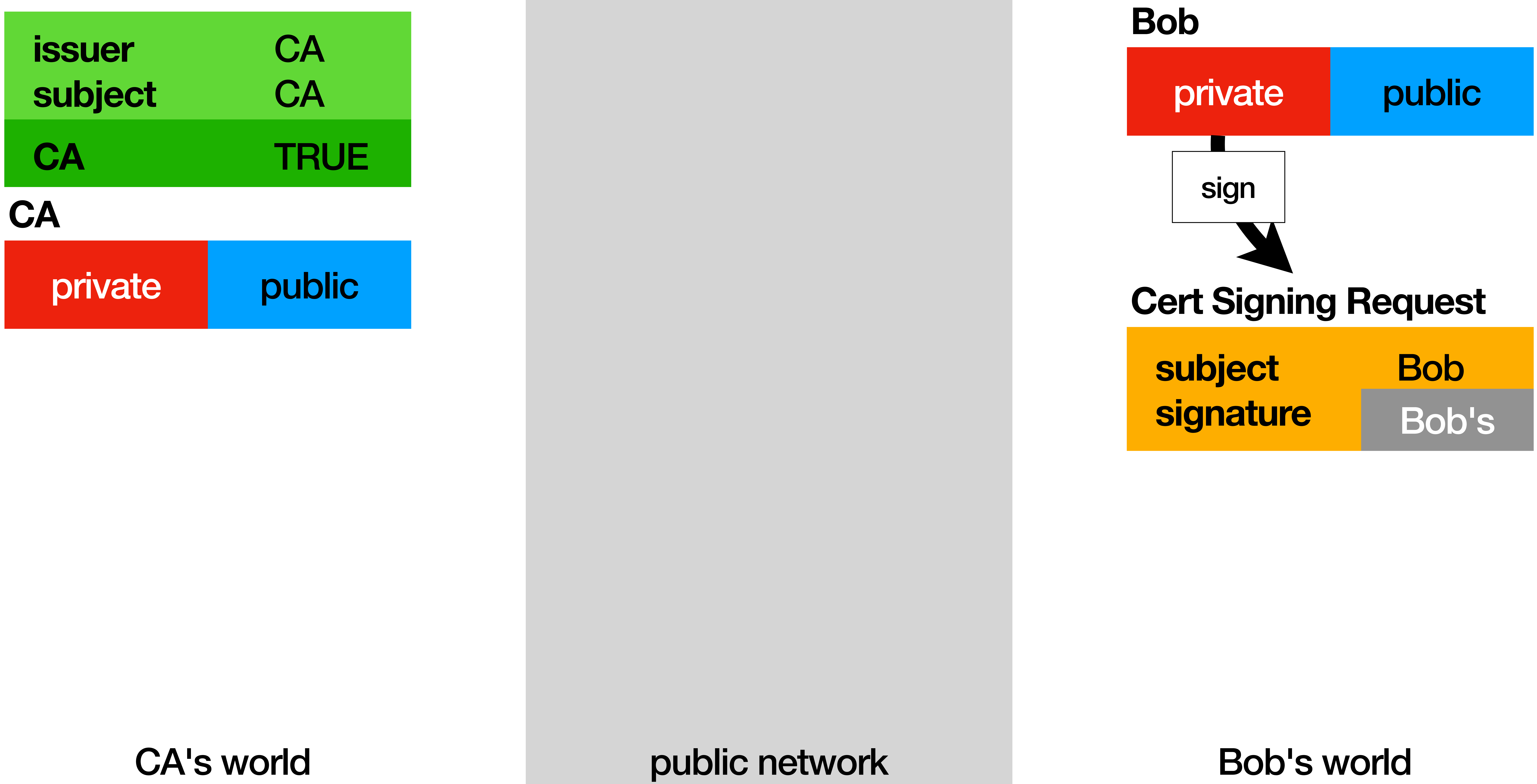
public network

Bob's world

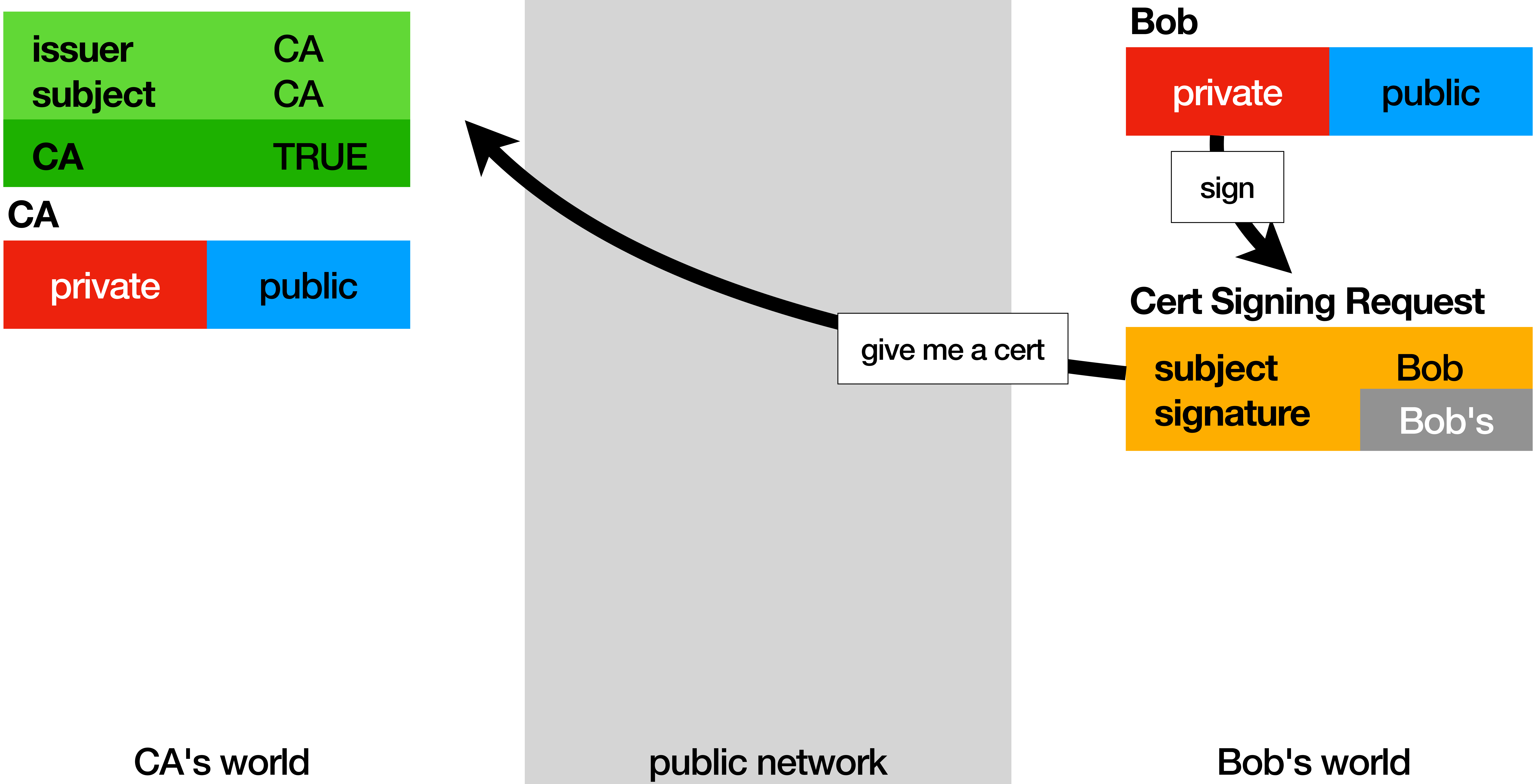
Certificate Authorities



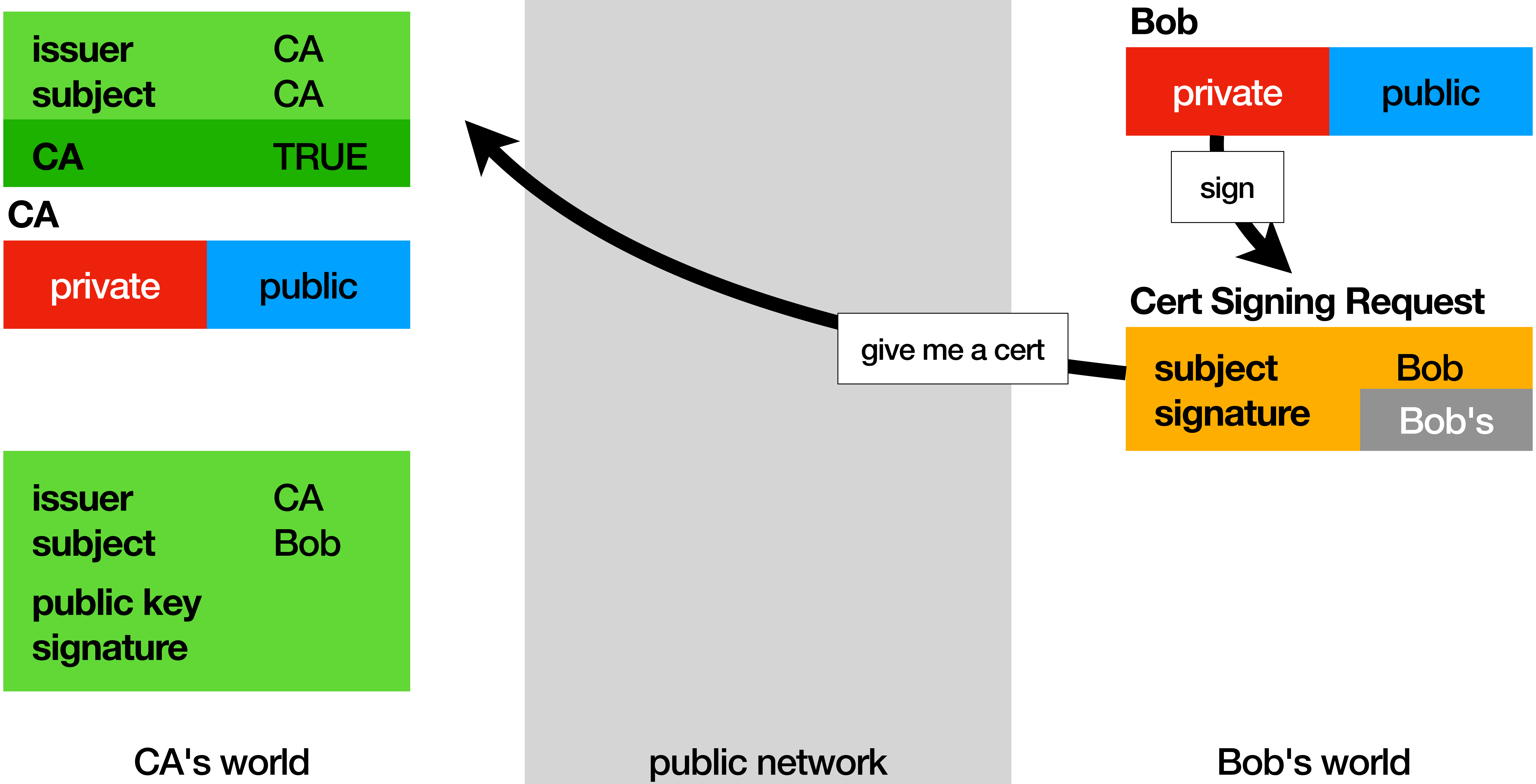
Certificate Authorities



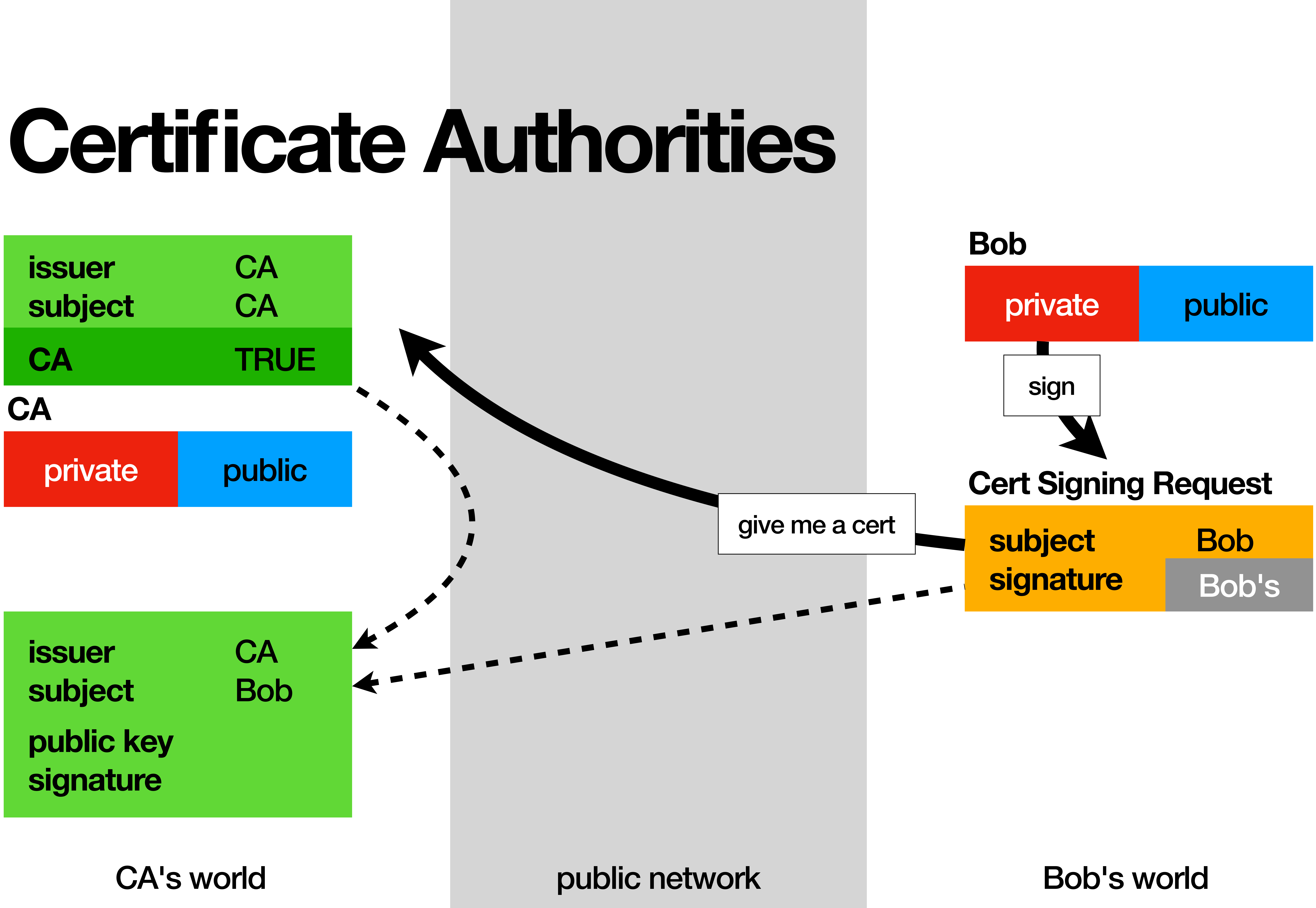
Certificate Authorities



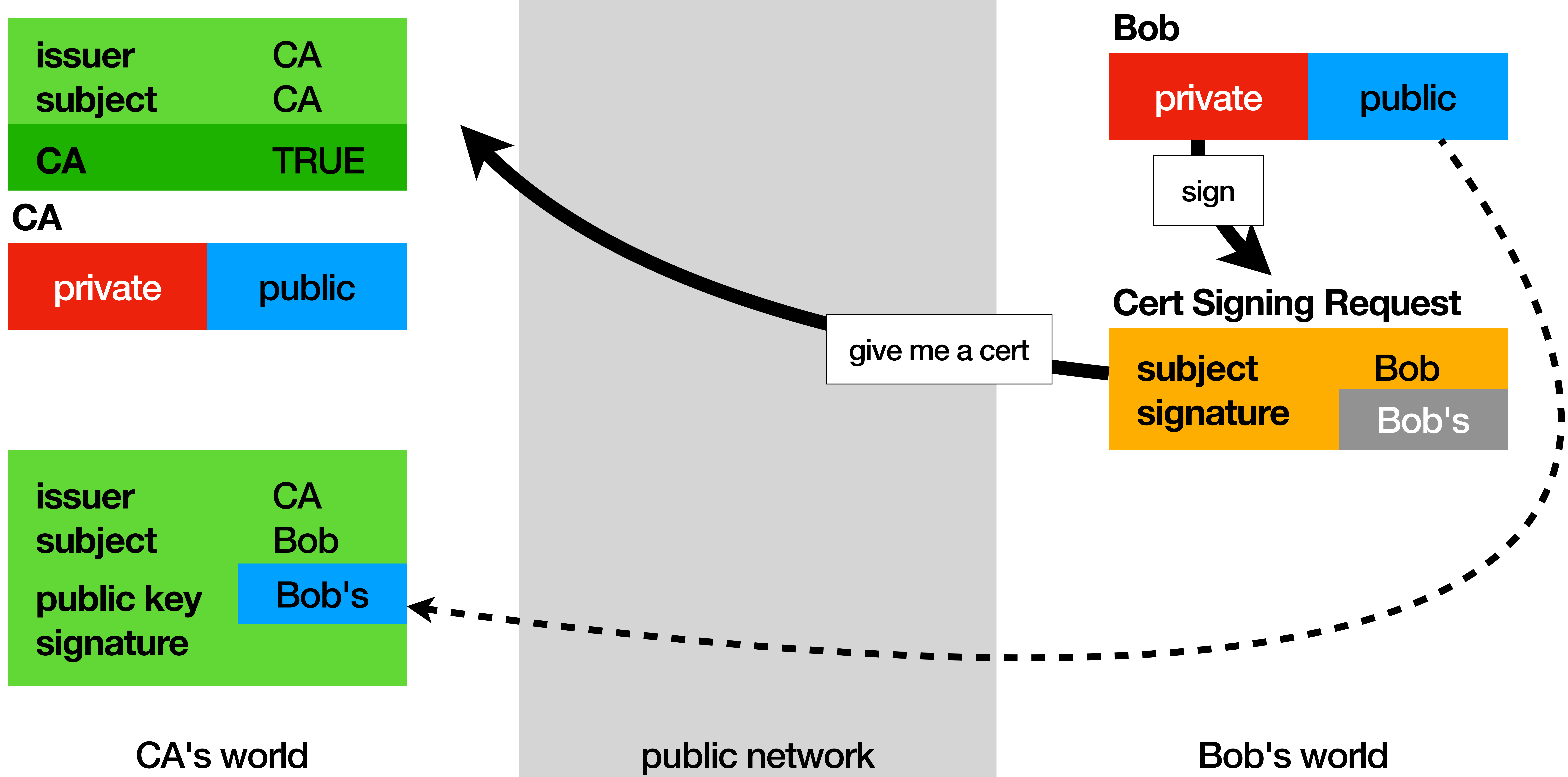
Certificate Authorities



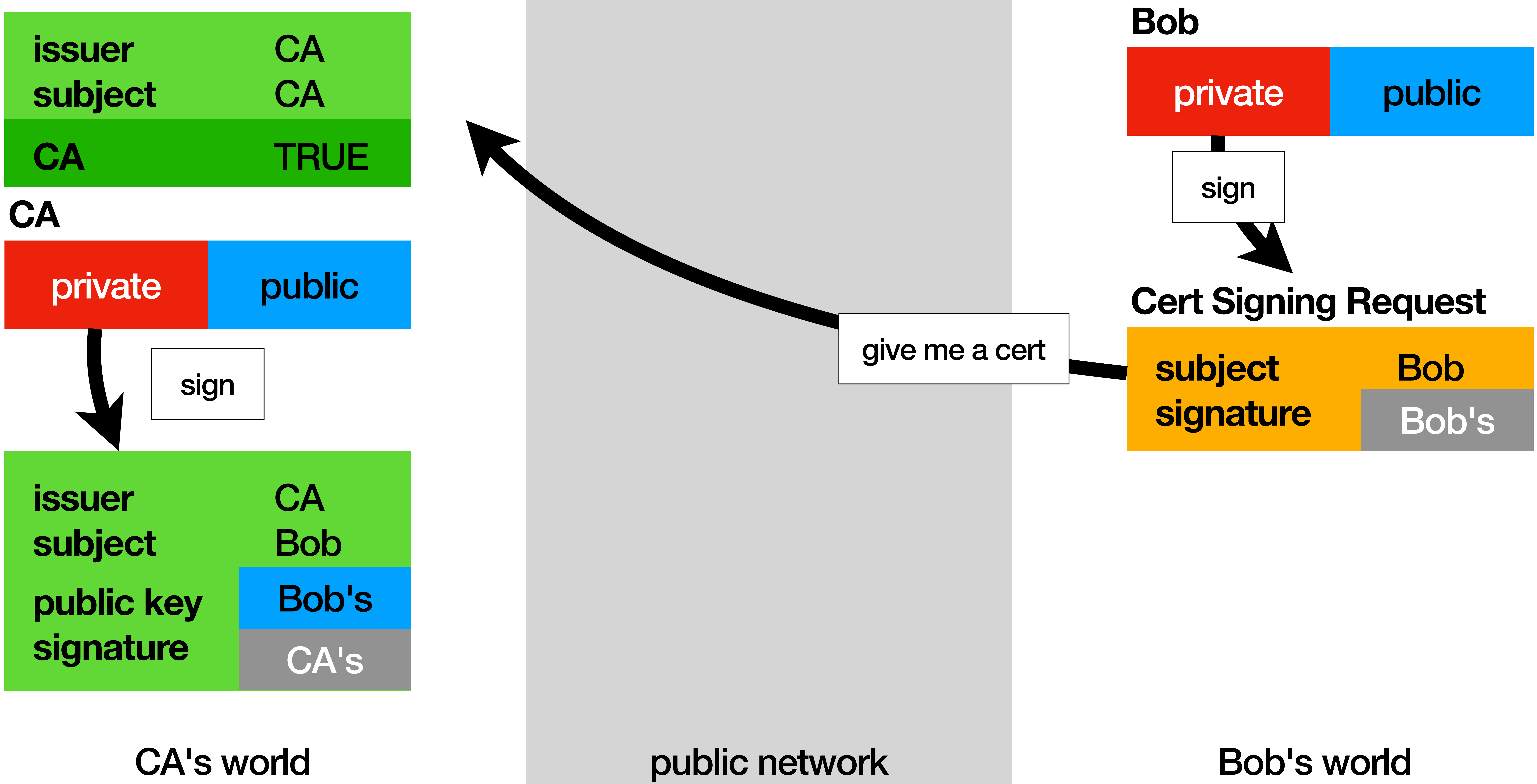
Certificate Authorities



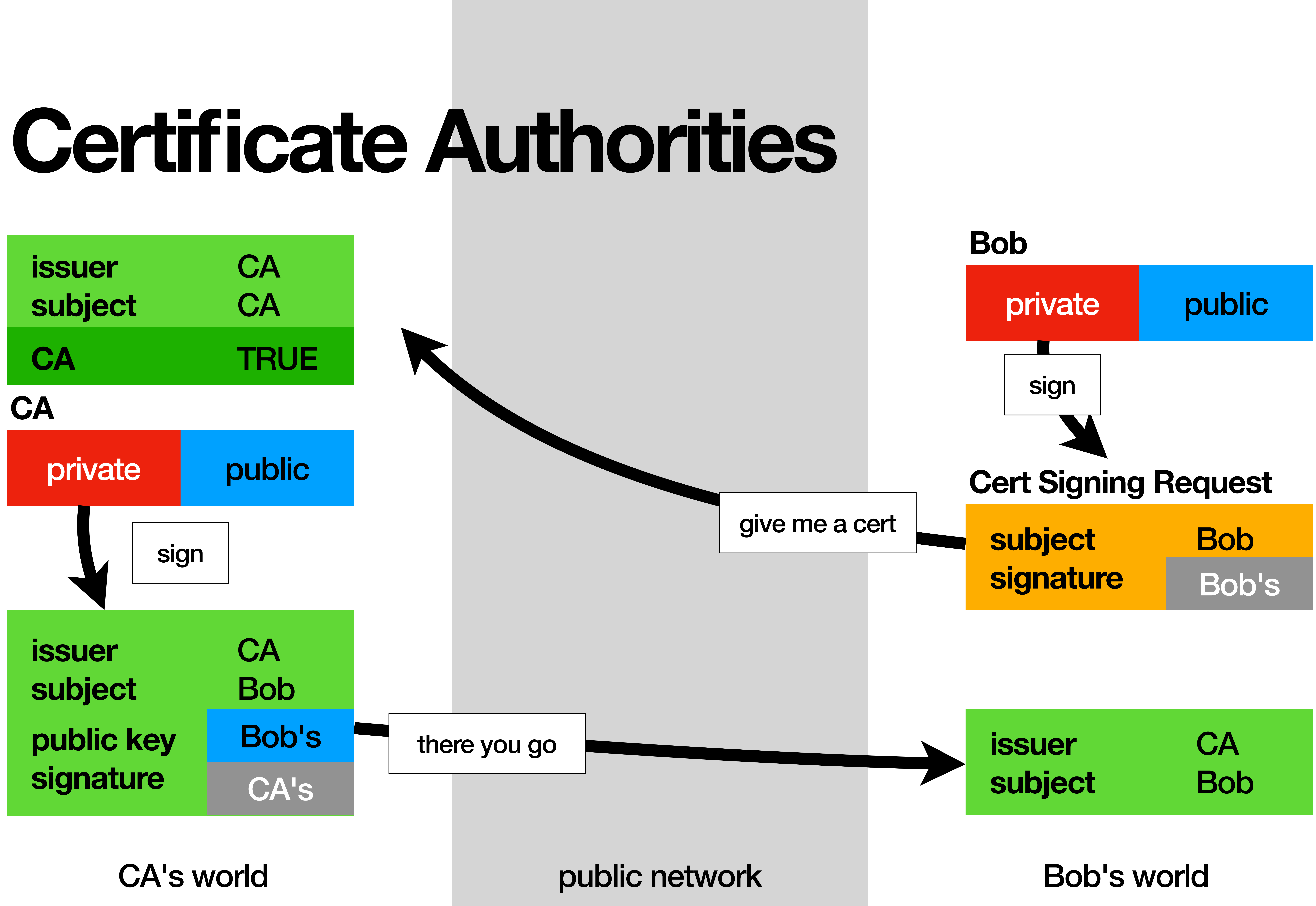
Certificate Authorities



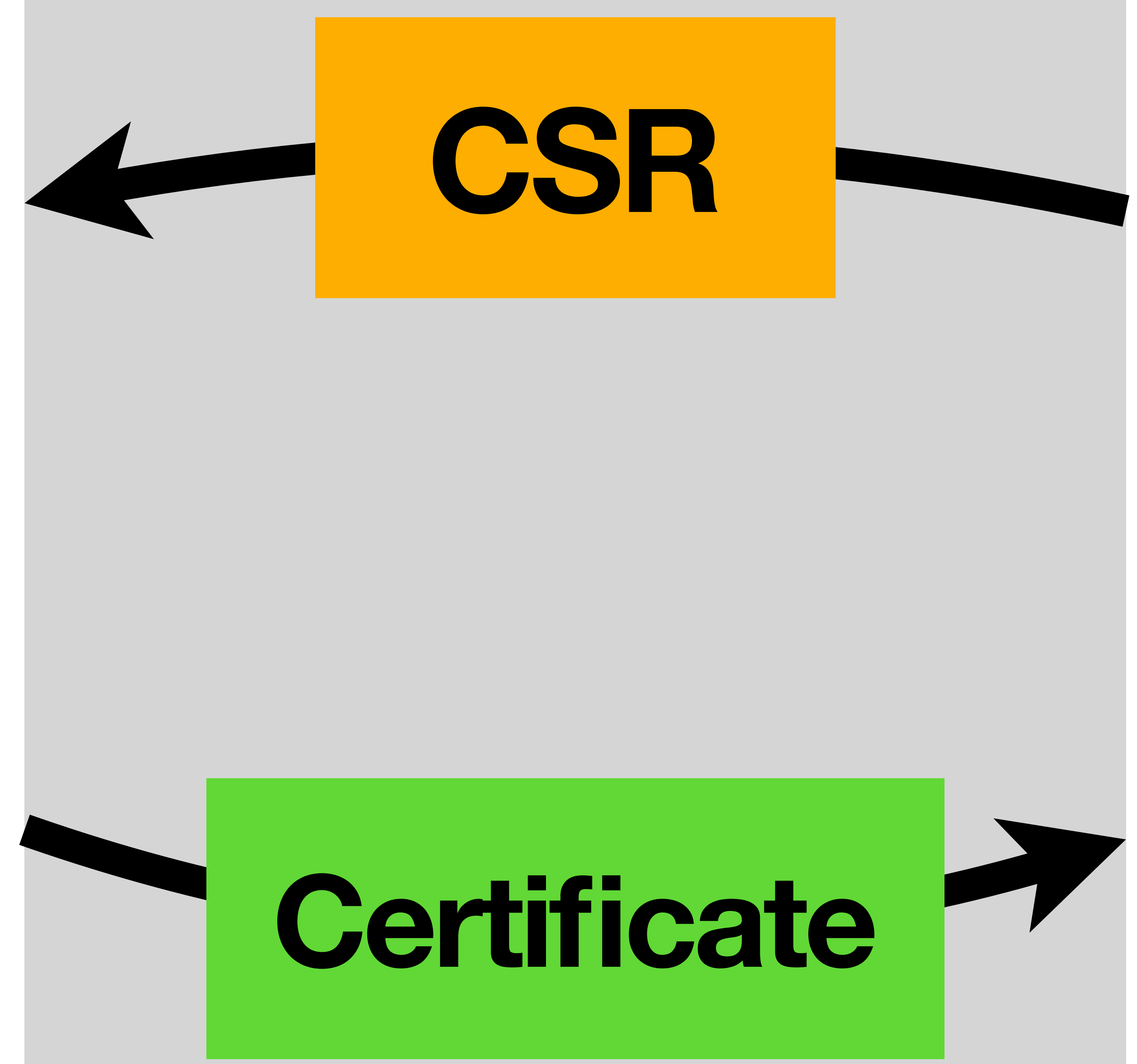
Certificate Authorities



Certificate Authorities



Certificate Authorities



CA's world

public network

Bob's world

...and TLS

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate** servers **using certificates**

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate** servers **using certificates**
- Clients connect, server sends certificate, client validates

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate** servers **using certificates**
- Clients connect, server sends certificate, client validates
- **Authenticates** server and **encrypts** traffic

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate** servers **using certificates**
- Clients connect, server sends certificate, client validates
- **Authenticates** server and **encrypts** traffic
  traffic encryption is not RSA encryption

...and TLS (aka Transport Layer Security)

- Protocol that **wraps other protocols**
- Allows clients to **validate** servers **using certificates**
- Clients connect, server sends certificate, client validates
- **Authenticates** server and **encrypts** traffic
  traffic encryption is not RSA encryption

*in **m**(utual)**TLS** clients also use certificates, server validated*

TLS Server Certificates

TLS Server Certificates

Bob serves a web app at **https://example.com.**

TLS Server Certificates

Bob serves a web app at **https://example.com**.

Needs a **server certificate**.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature

Bob serves a web app at **https://example.com.**

Needs a **server certificate.**

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	**...**
valid to	**...**
public key	Bob's
signature	signature

Bob serves a web app at **https://example.com**.

Needs a **server certificate**.

This is **not enough.**

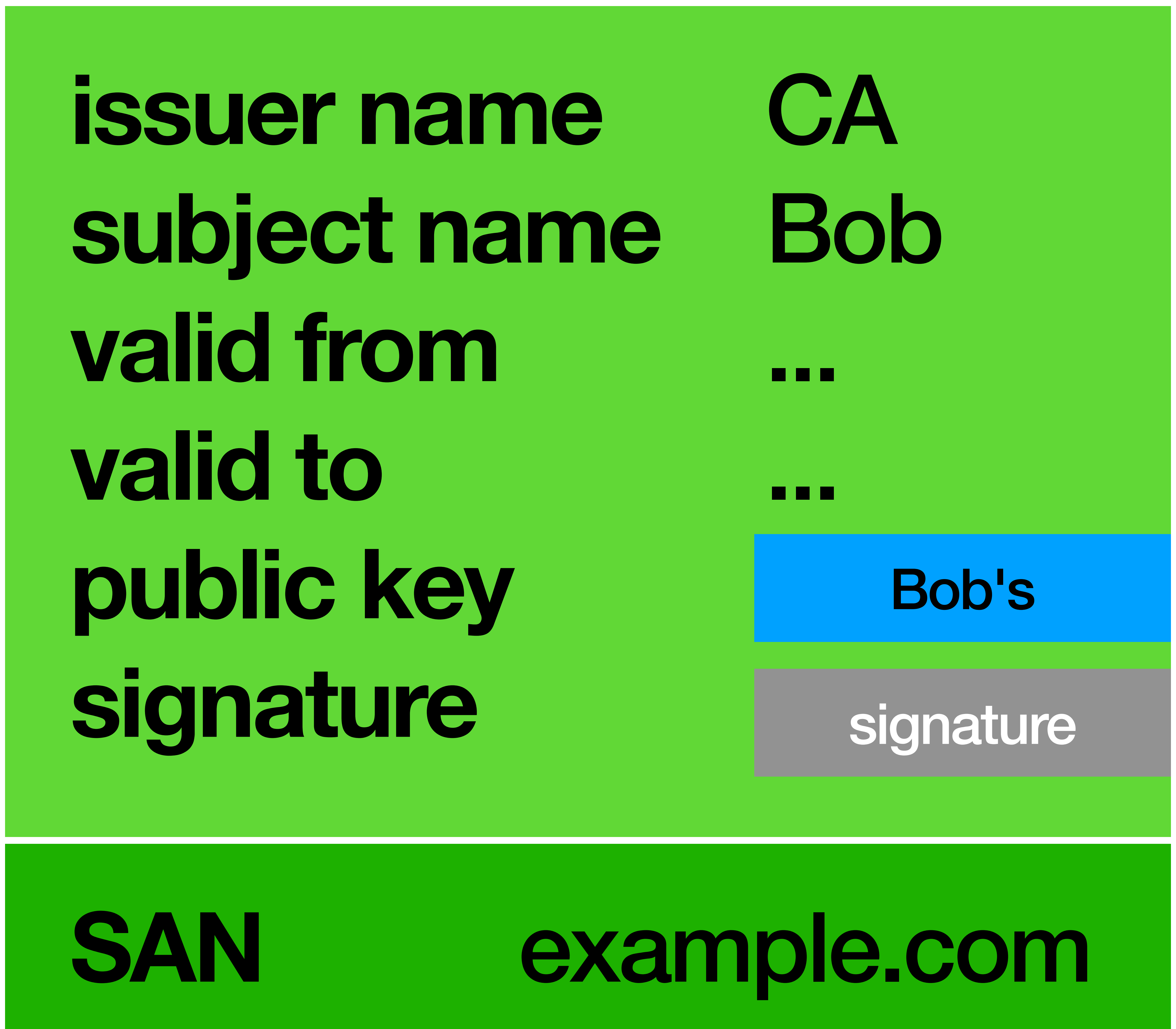
TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Bob serves a web app at **https://example.com.**

Needs a **server certificate.**

TLS Server Certificates

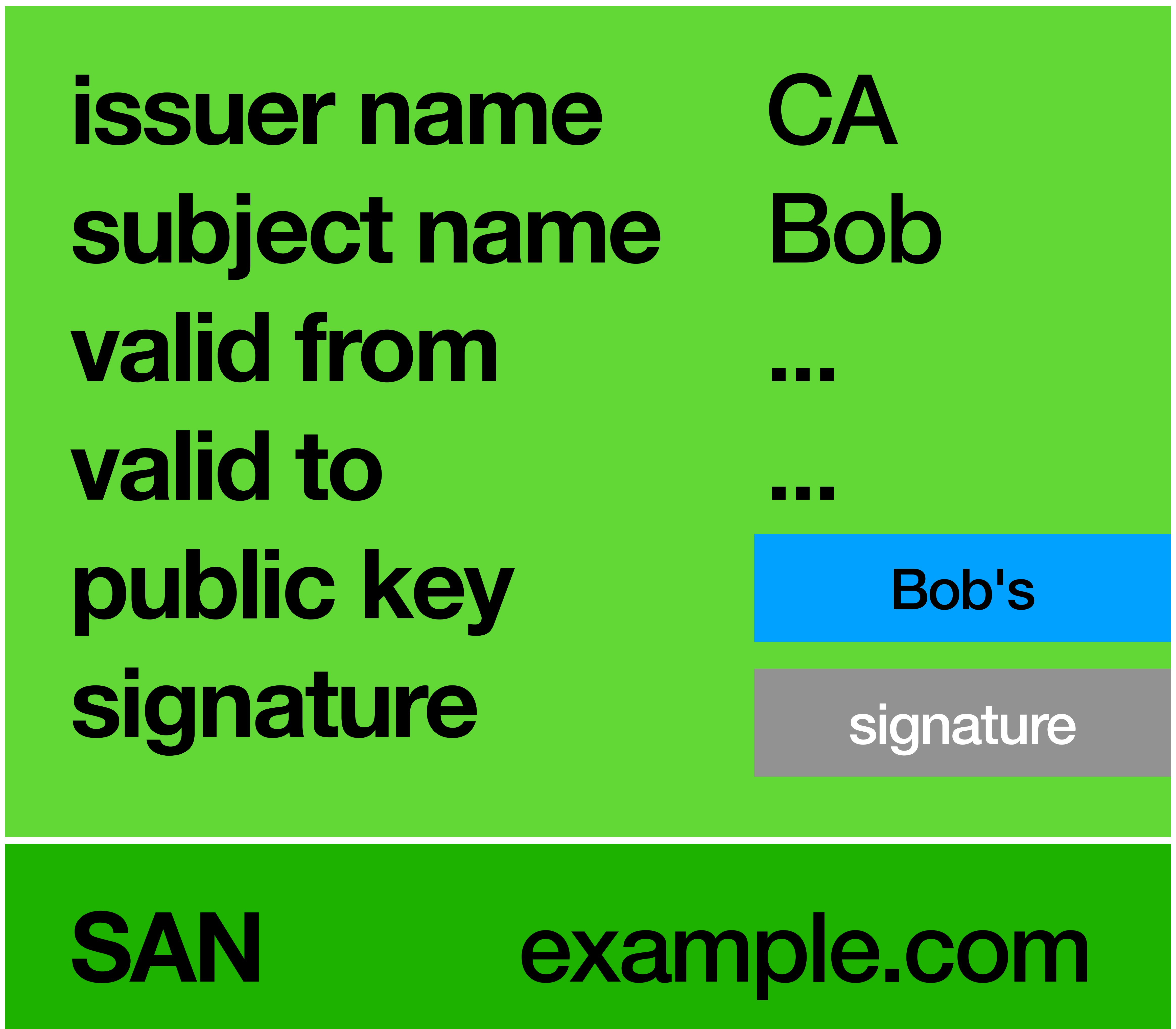


Bob serves a web app at **https://example.com**.

Needs a **server certificate**.

Server certificates include **Subject Alternative Name**.

TLS Server Certificates



Bob serves a web app at **https://example.com**.

Needs a **server certificate**.

Server certificates include **Subject Alternative Name**.

Also used in client validation.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

- Signature is valid.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

- Signature is valid.
- Valid from/to is ok.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.
- Issued by a CA I trust.
  or by a sub-CA of a CA I trust

TLS Server Certificates

issuer name	CA
subject name	Bob
valid from	...
valid to	...
public key	Bob's
signature	signature
SAN	example.com

Client Validation

- Signature is valid.
- Valid from/to is ok.
- SAN matches.
- Issued by a CA I trust.
  or by a sub-CA of a CA I trust

...there is much more!

CAs & TLS

CAs & TLS

who you trust dictates everything

MITM (aka Man-in-the-middle)

MITM (aka Man-in-the-middle)

web application at
http://example.com

Alice's client

public network

Bob's server

MITM (aka Man-in-the-middle)

HTTP client (no TLS)

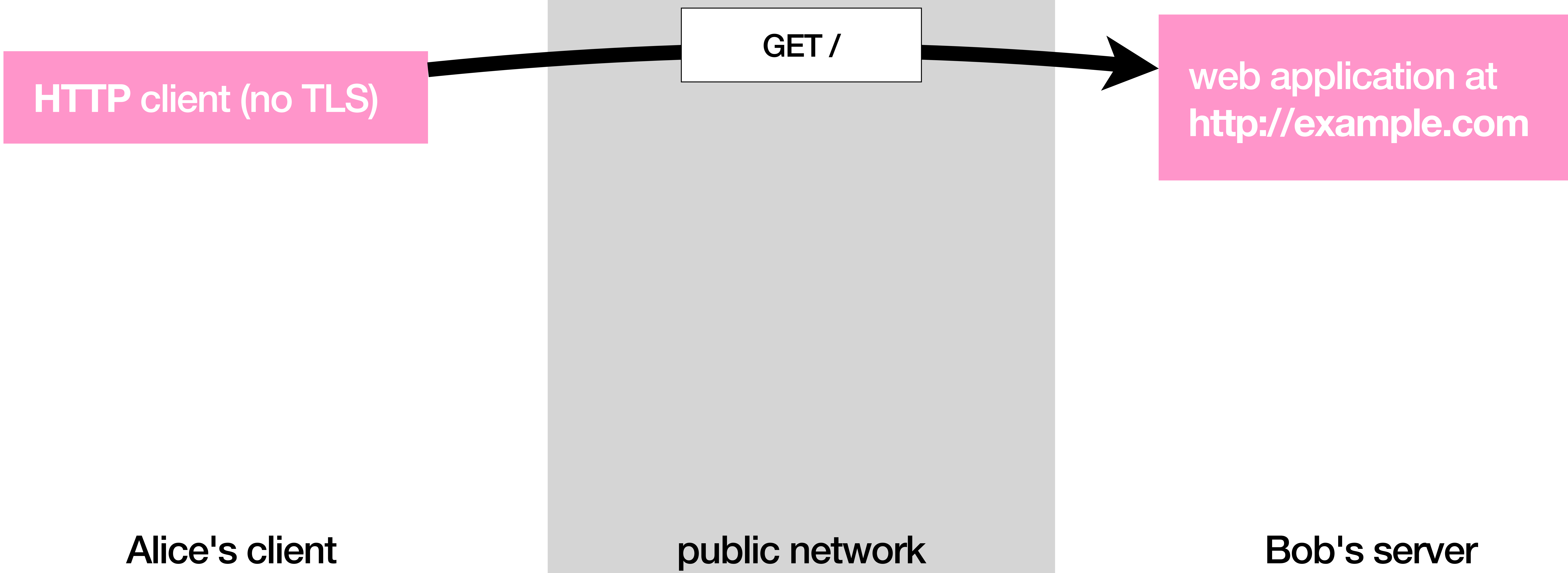
web application at
http://example.com

Alice's client

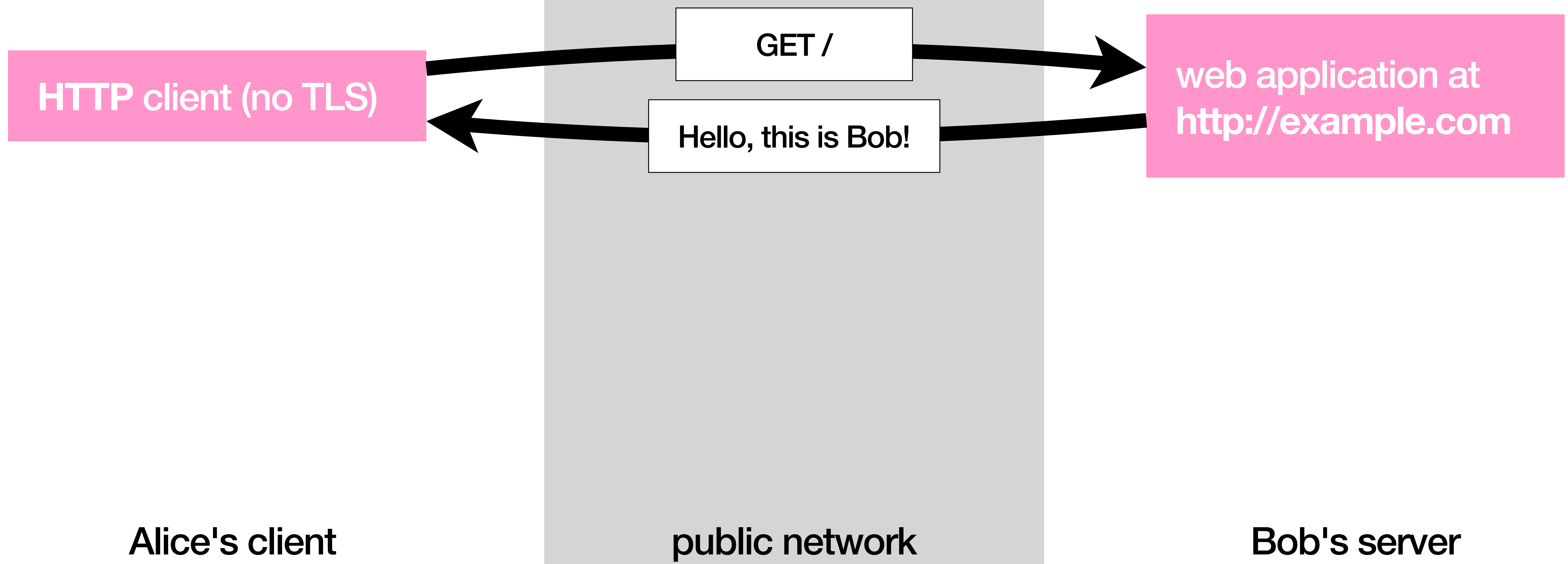
public network

Bob's server

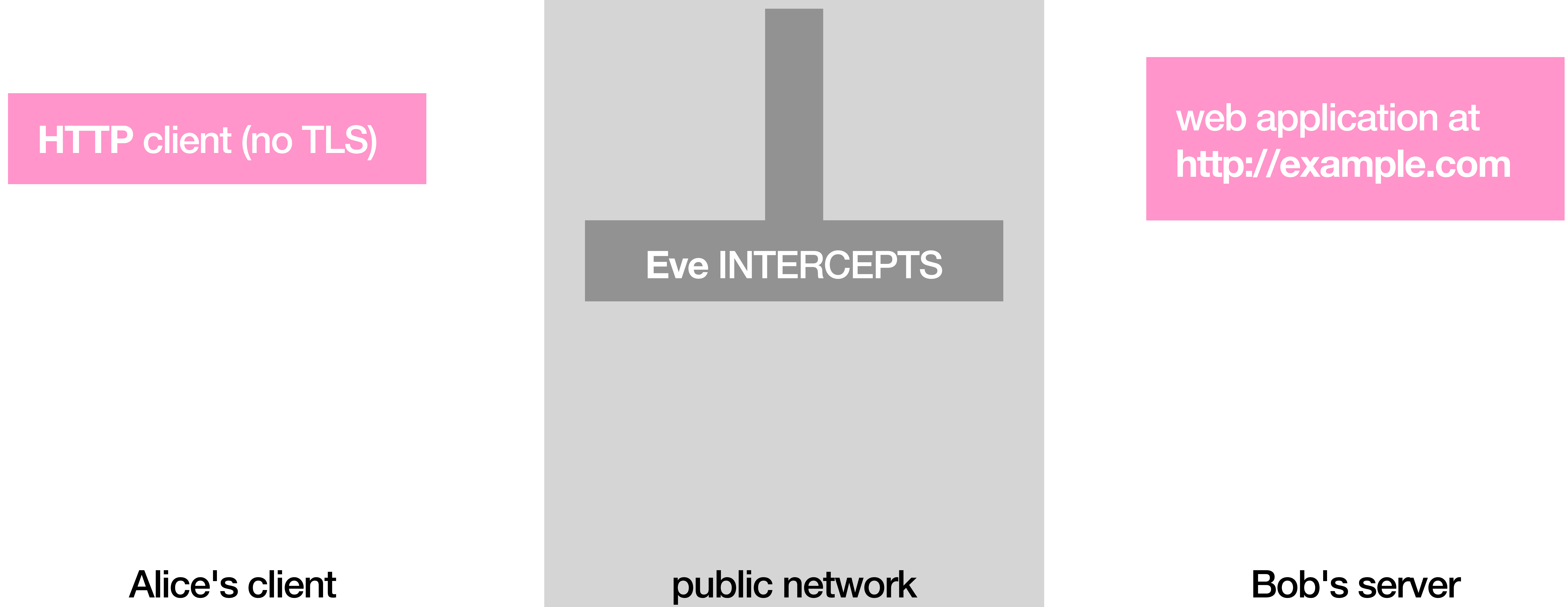
MITM (aka Man-in-the-middle)



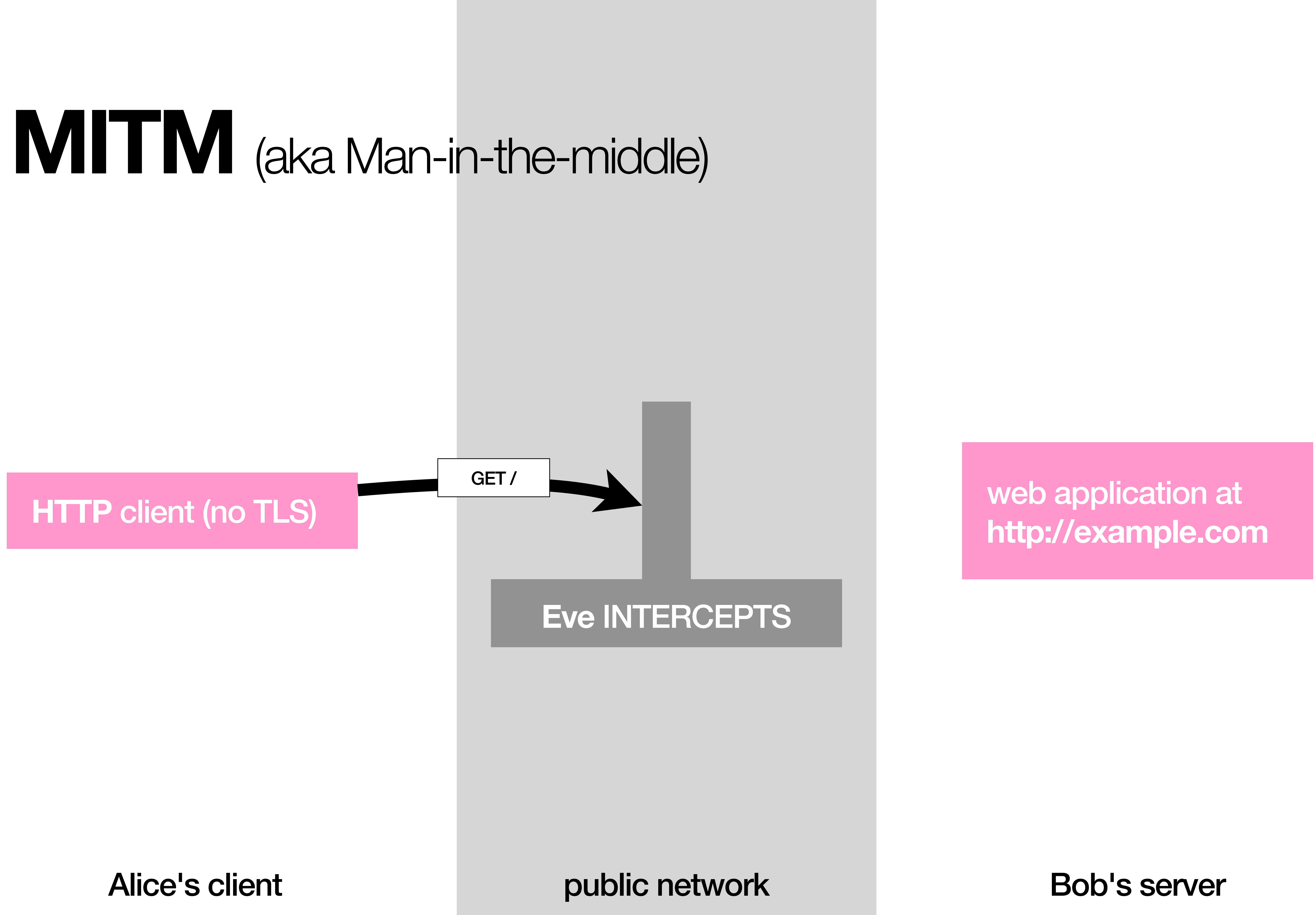
MITM (aka Man-in-the-middle)



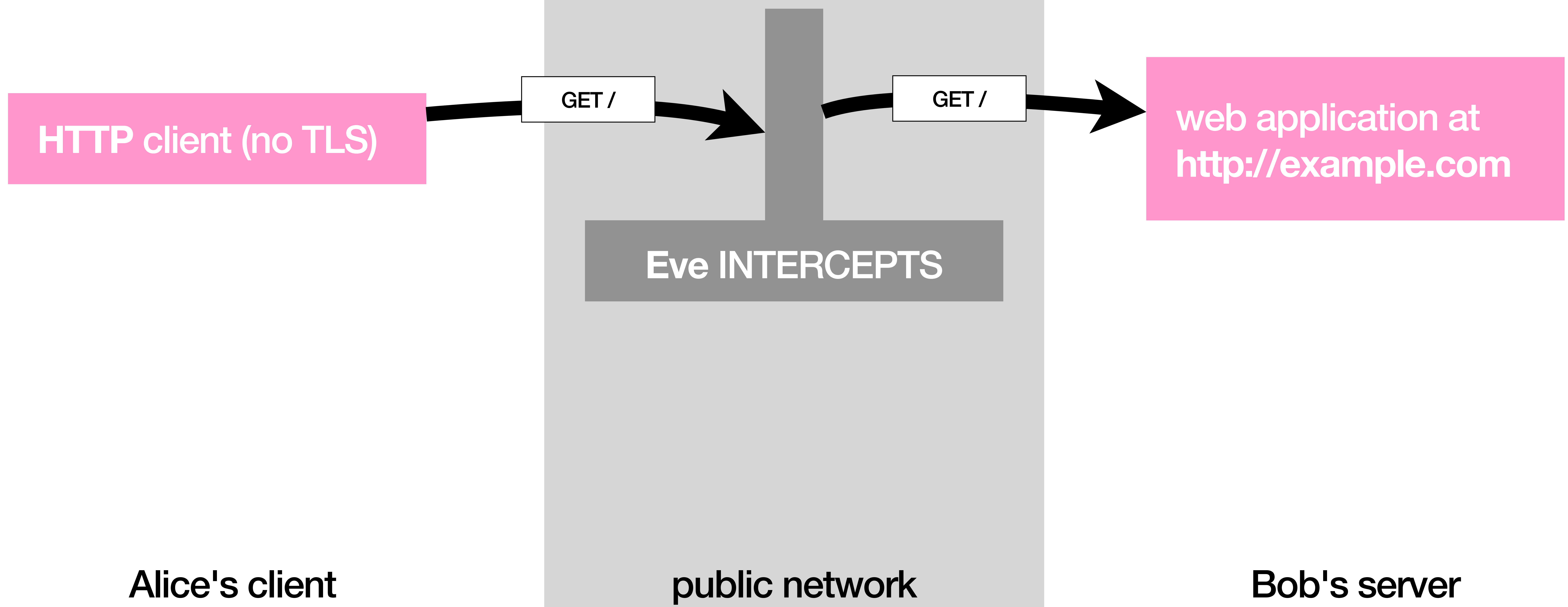
MITM (aka Man-in-the-middle)



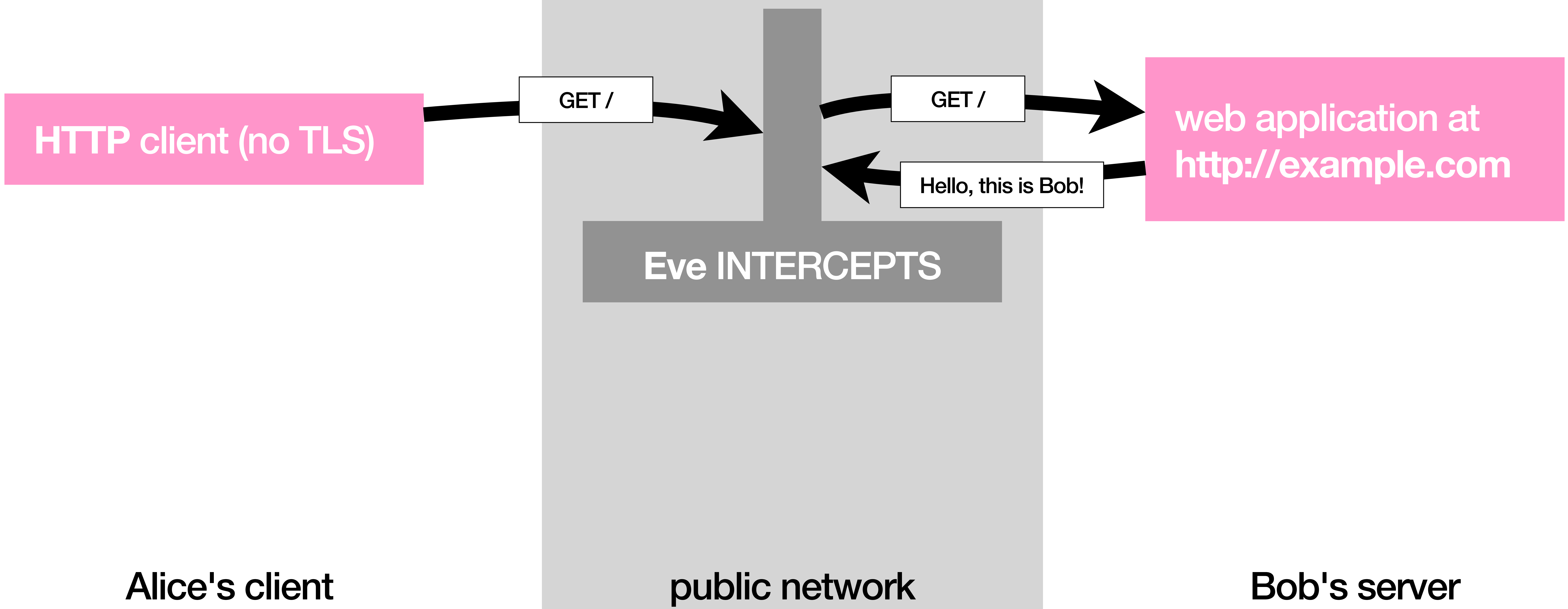
MITM (aka Man-in-the-middle)



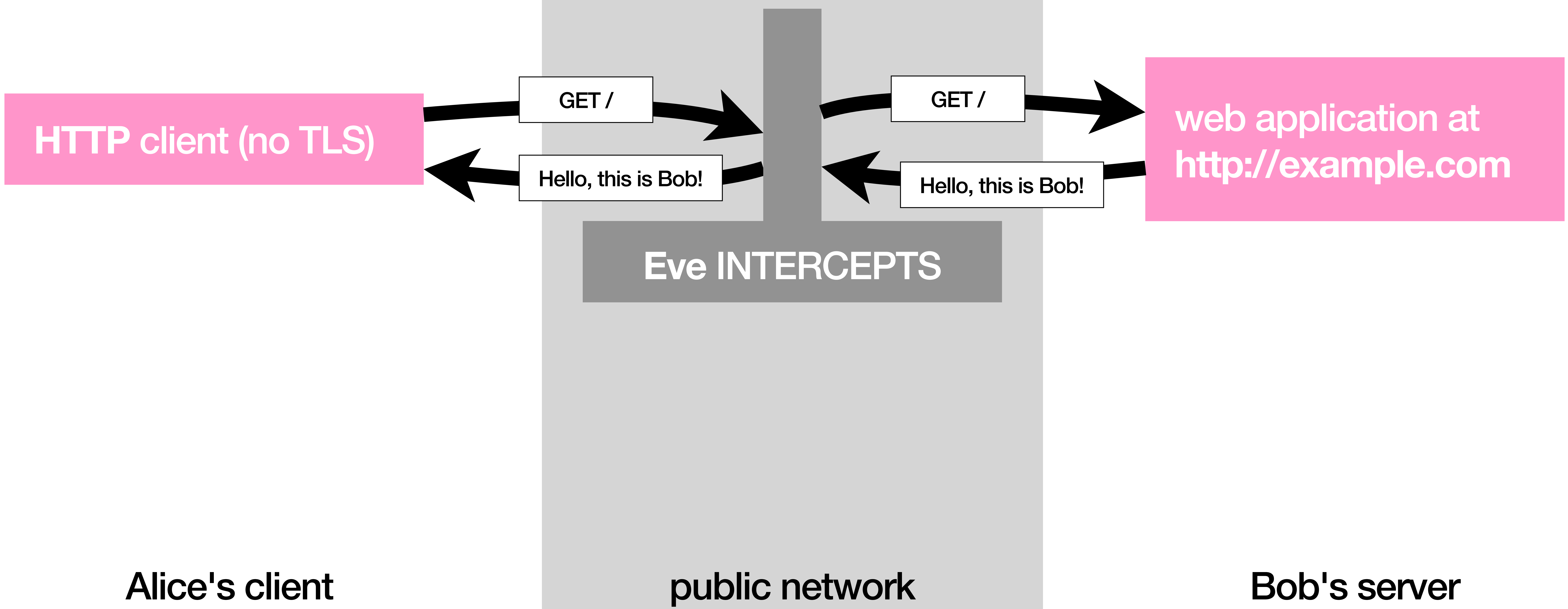
MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)

issuer	CA
subject	CA
CA	TRUE

issuer	CA
subject	Bob
SAN	**example.com**

HTTPS client

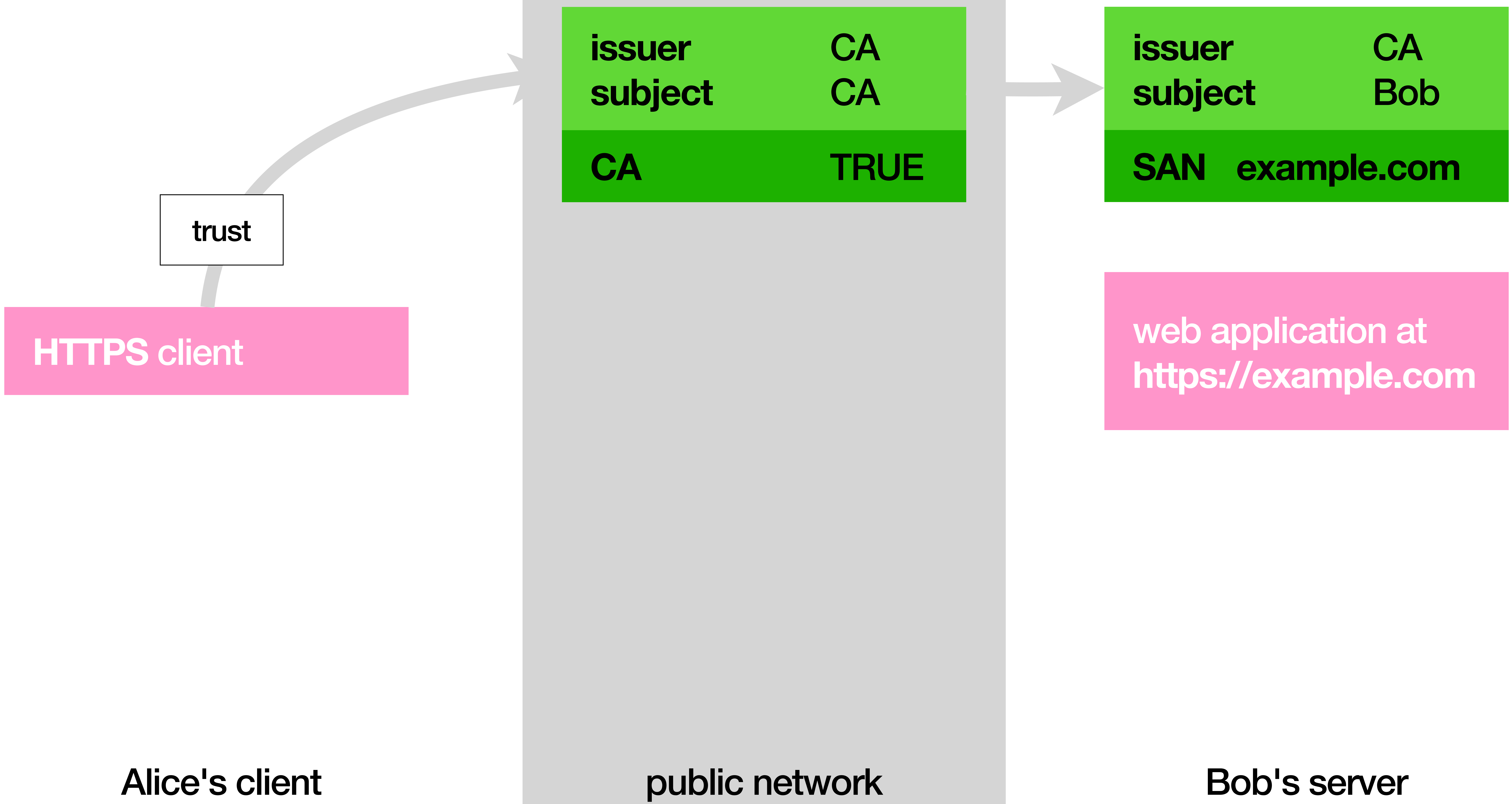
web application at
https://example.com

Alice's client

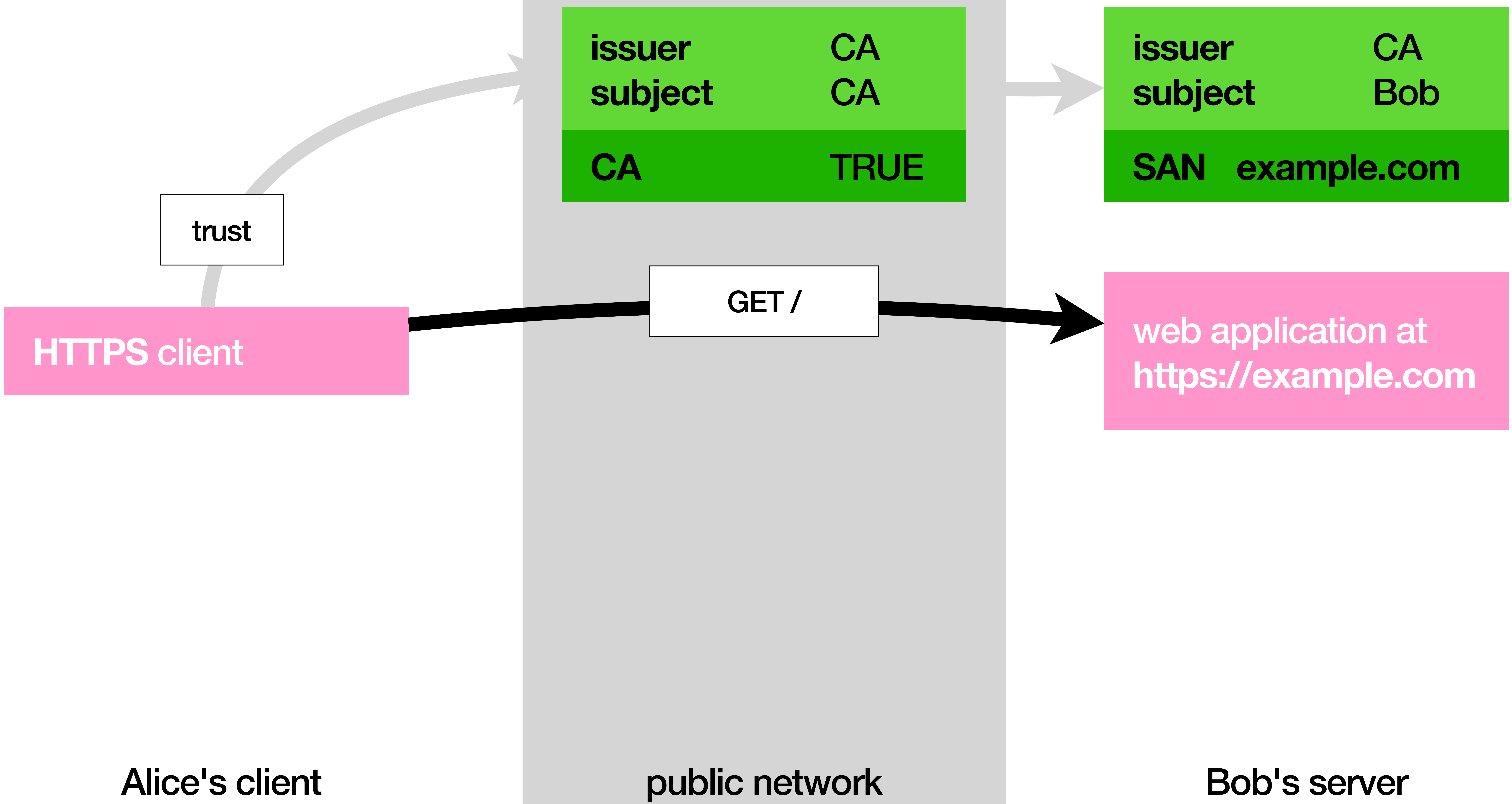
public network

Bob's server

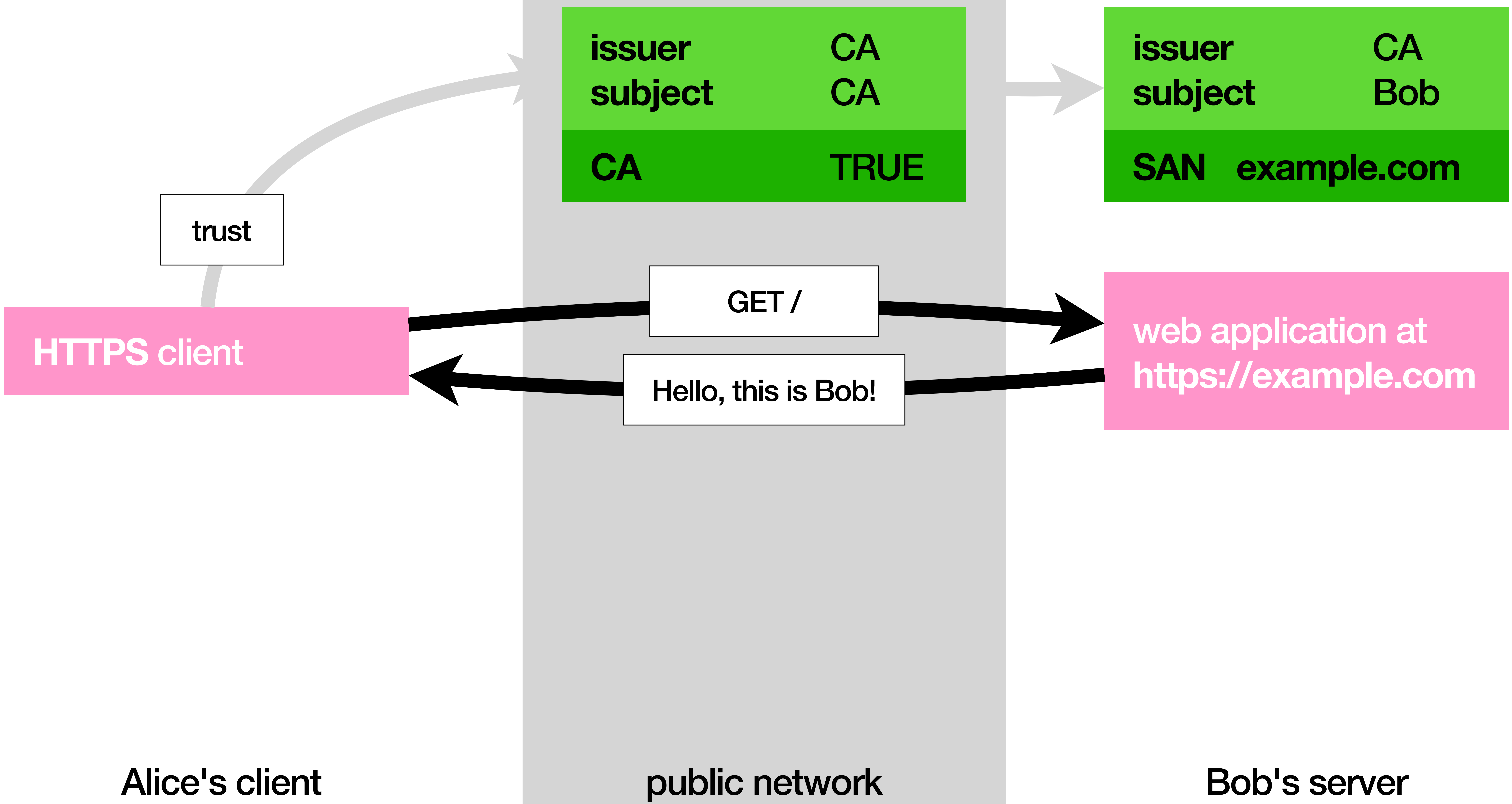
MITM (aka Man-in-the-middle)



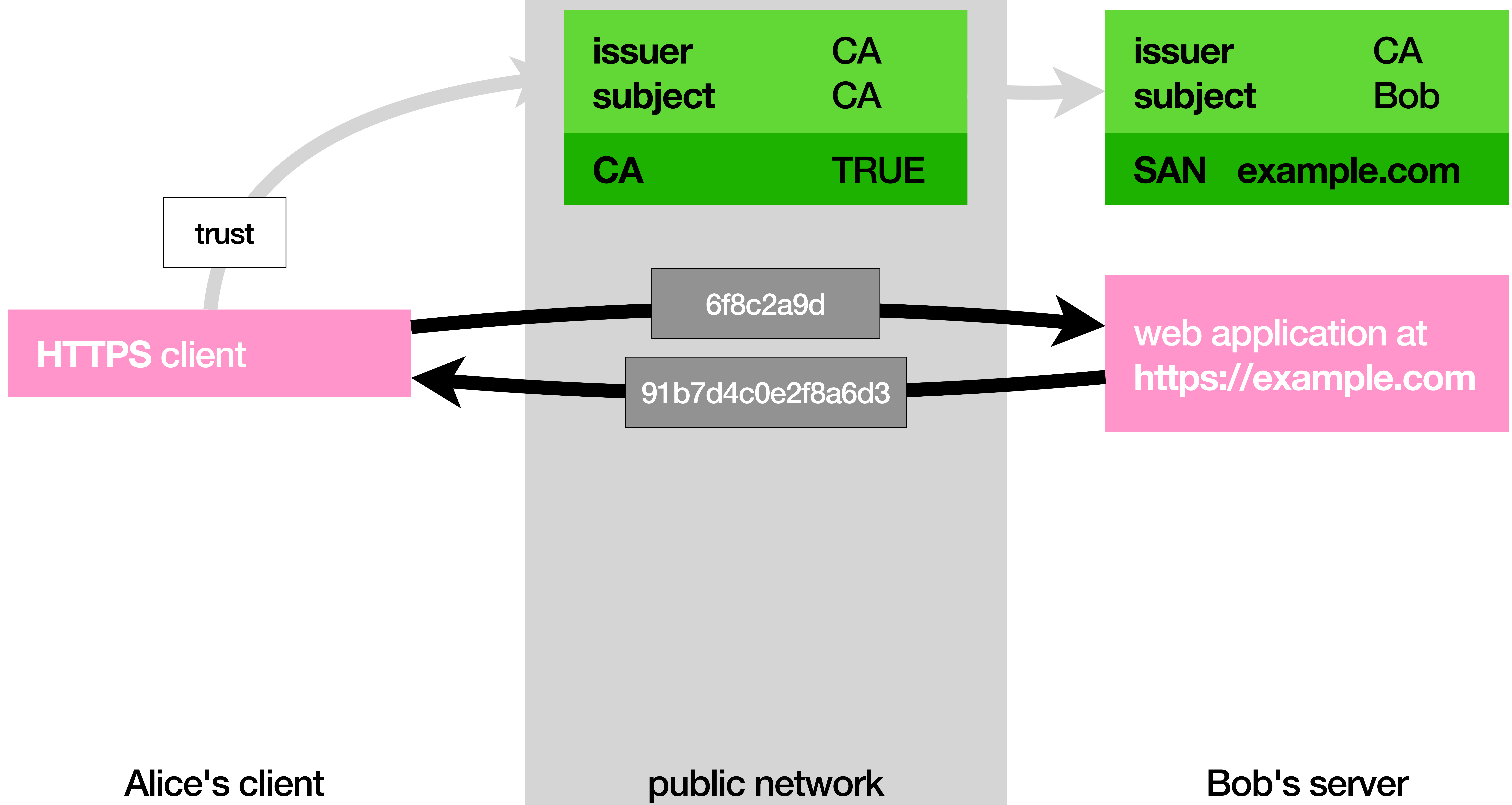
MITM (aka Man-in-the-middle)



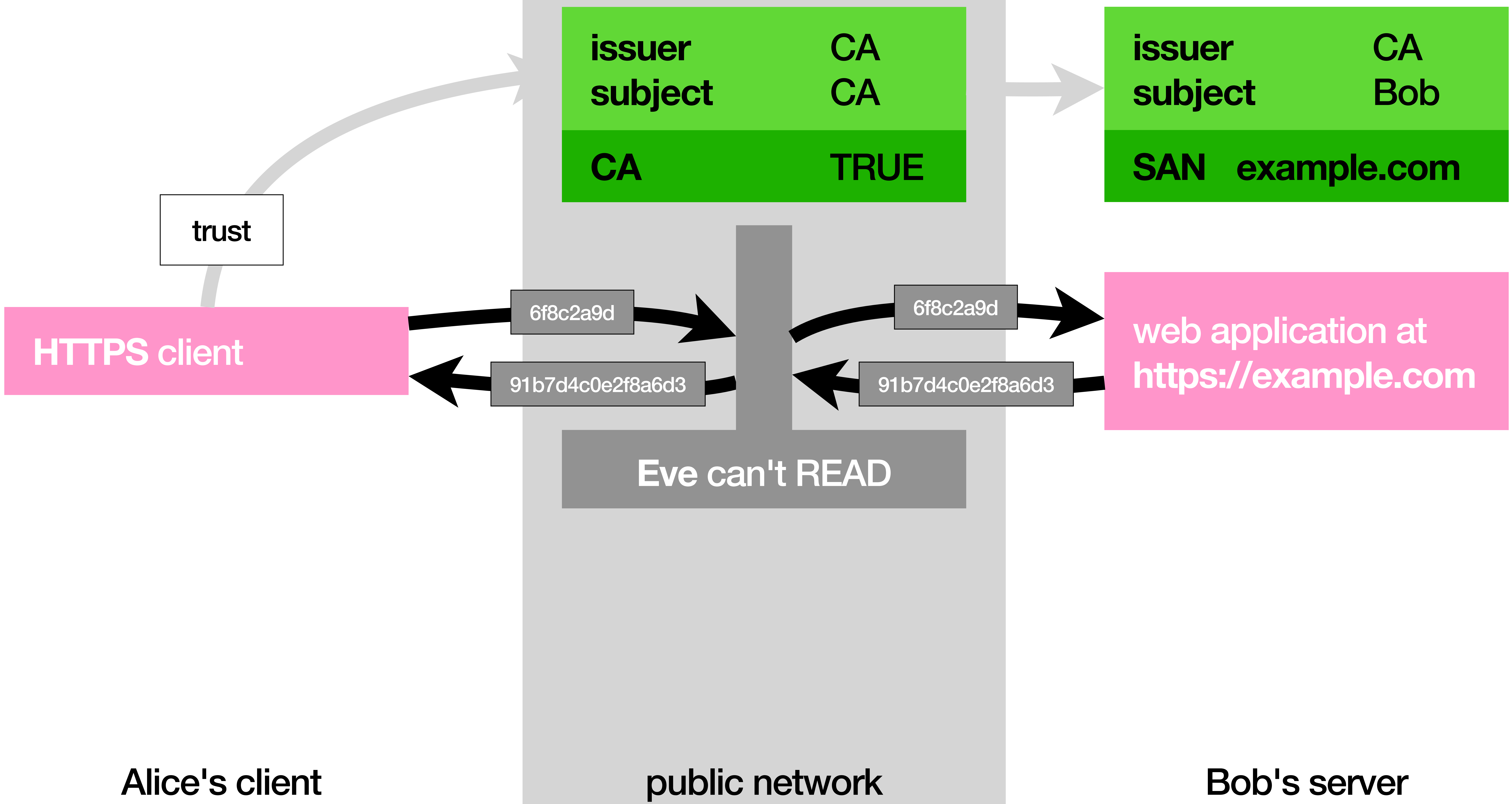
MITM (aka Man-in-the-middle)



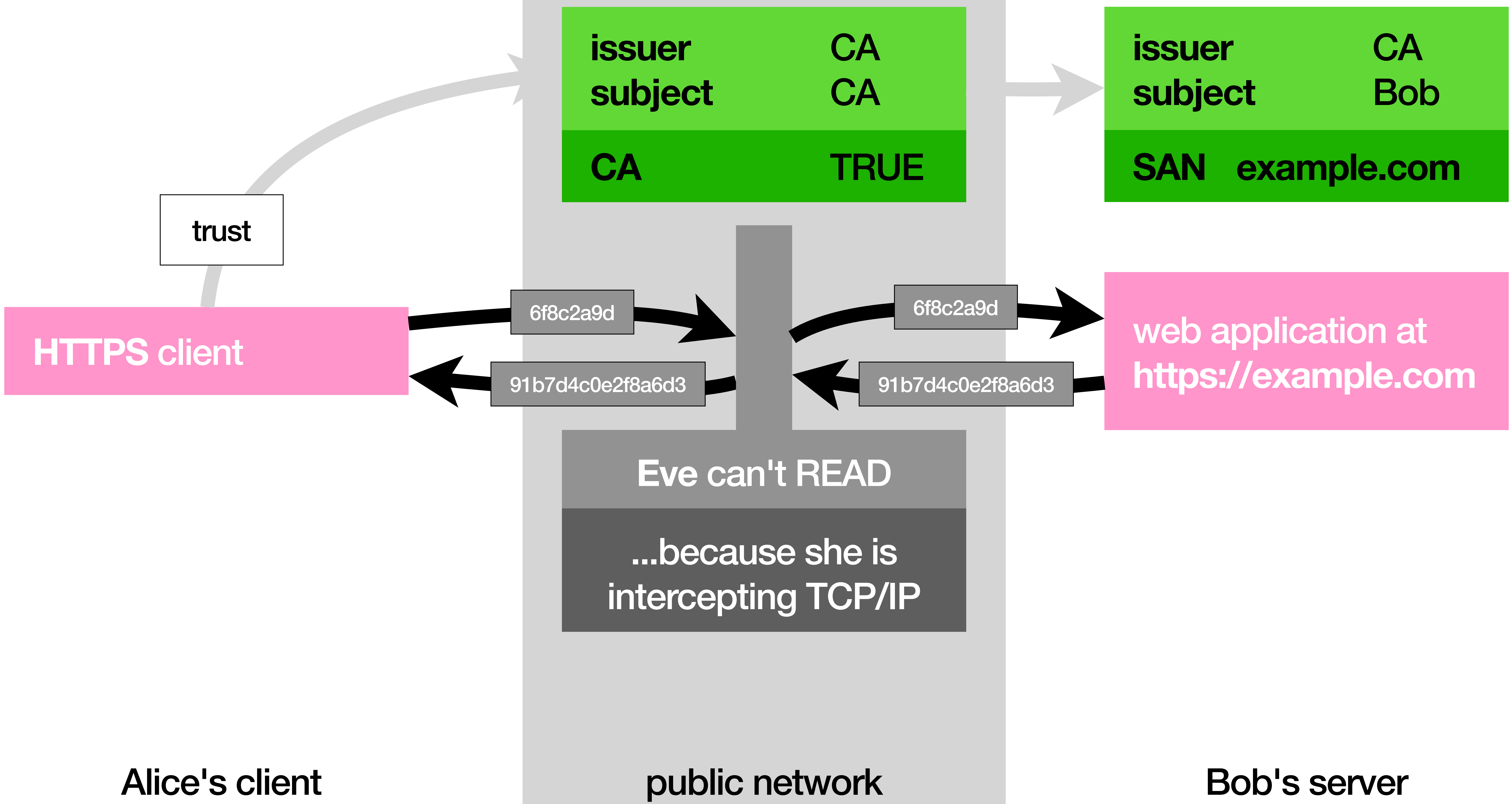
MITM (aka Man-in-the-middle)



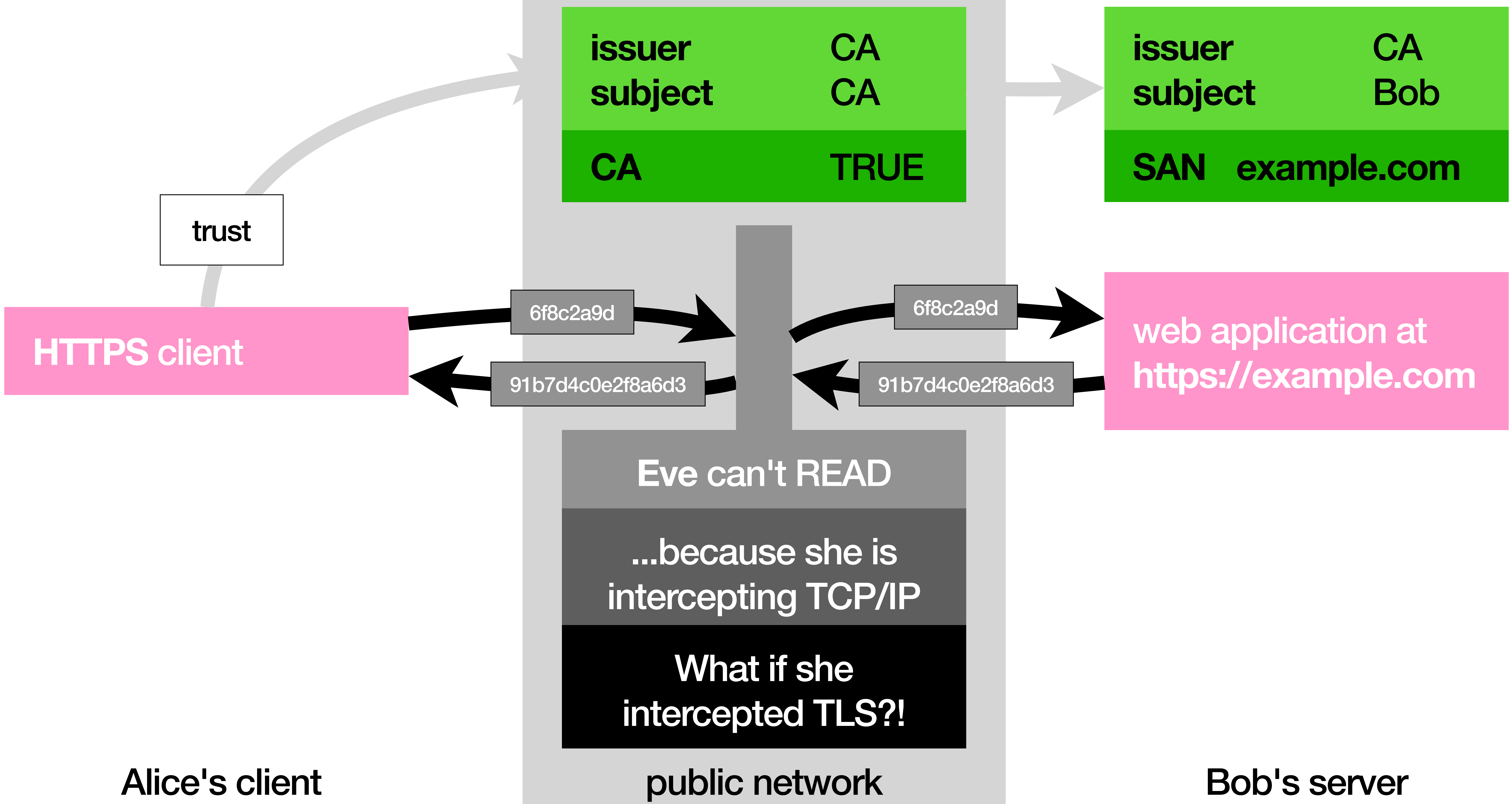
MITM (aka Man-in-the-middle)



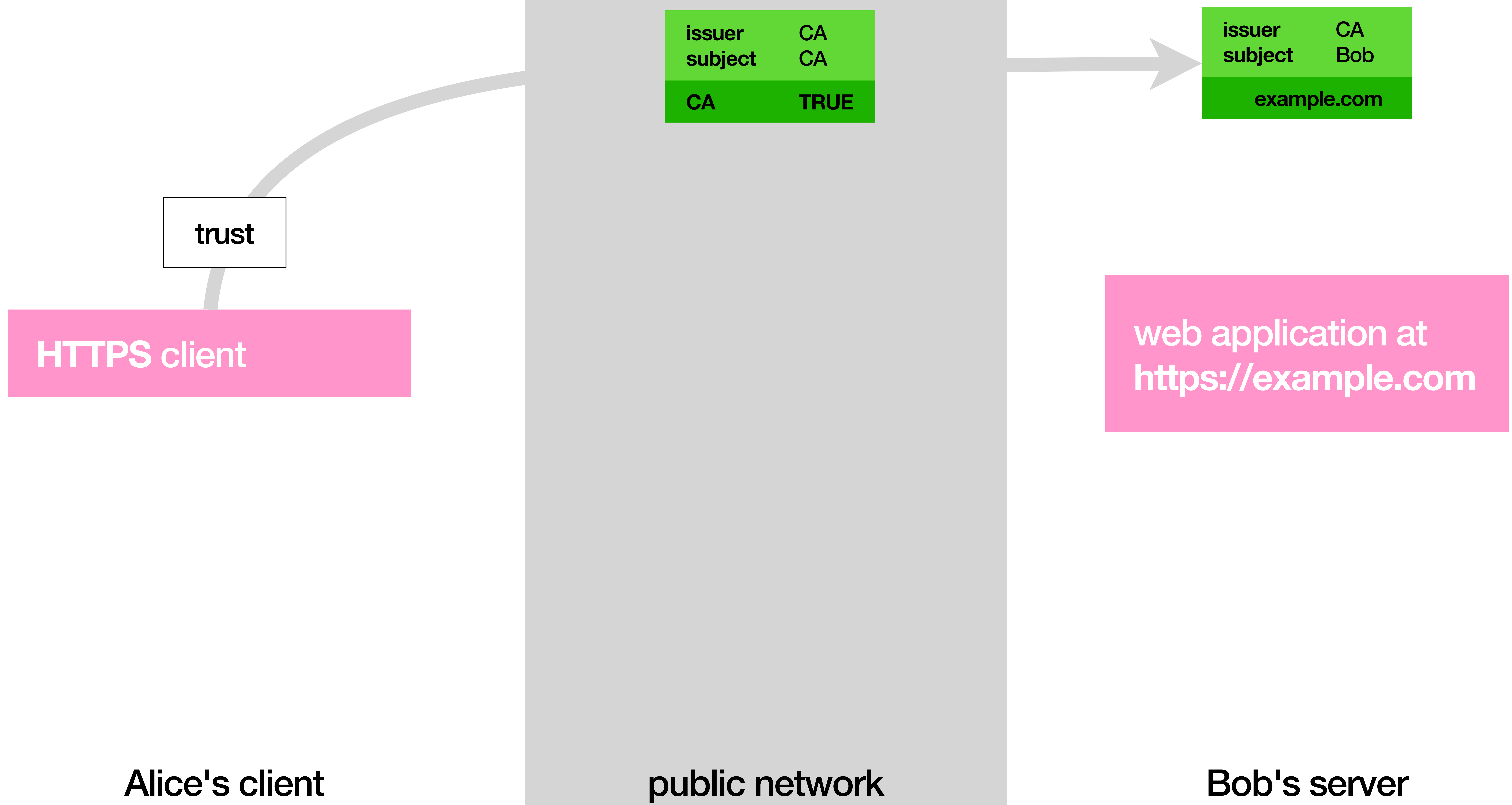
MITM (aka Man-in-the-middle)



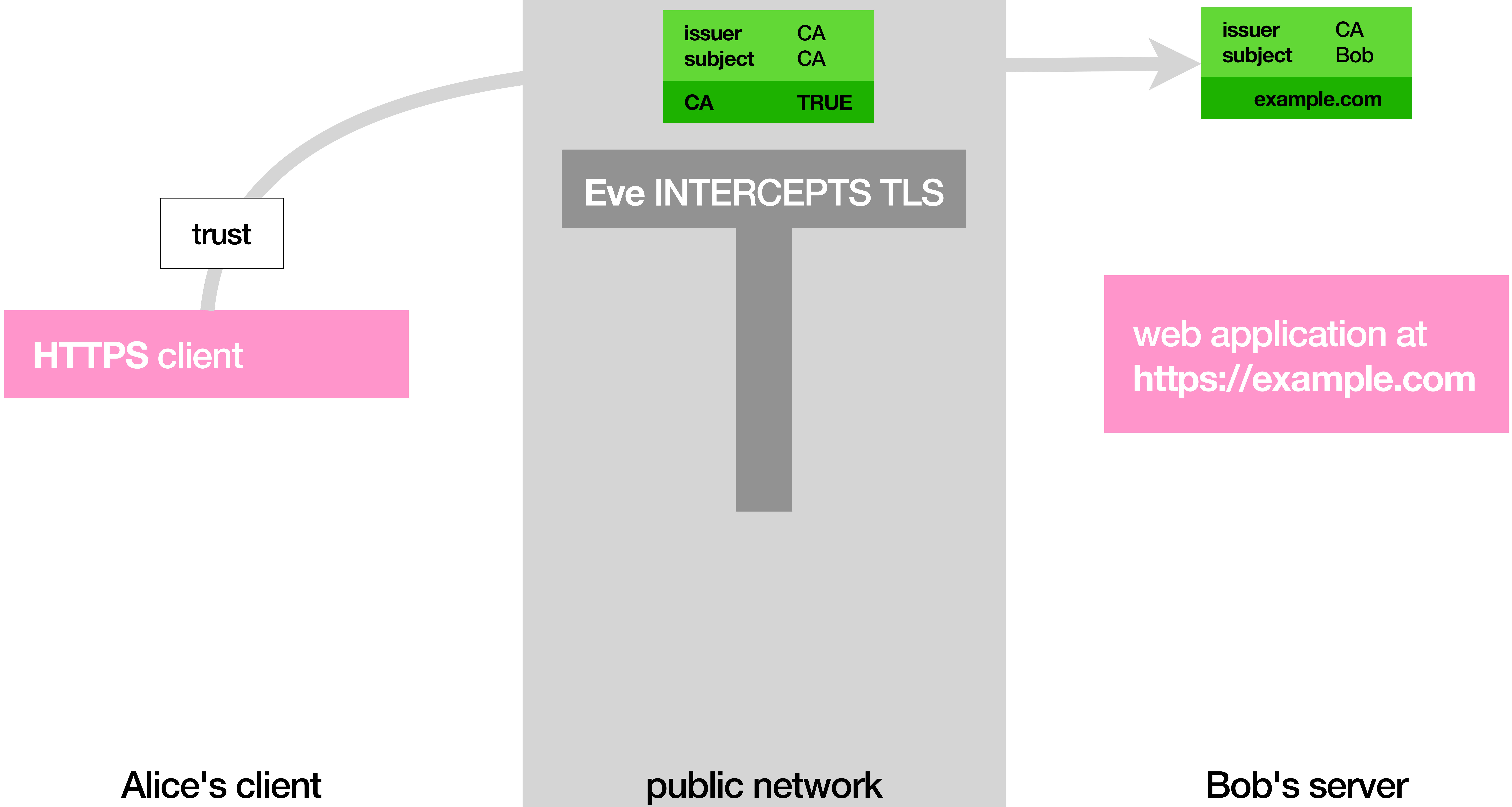
MITM (aka Man-in-the-middle)



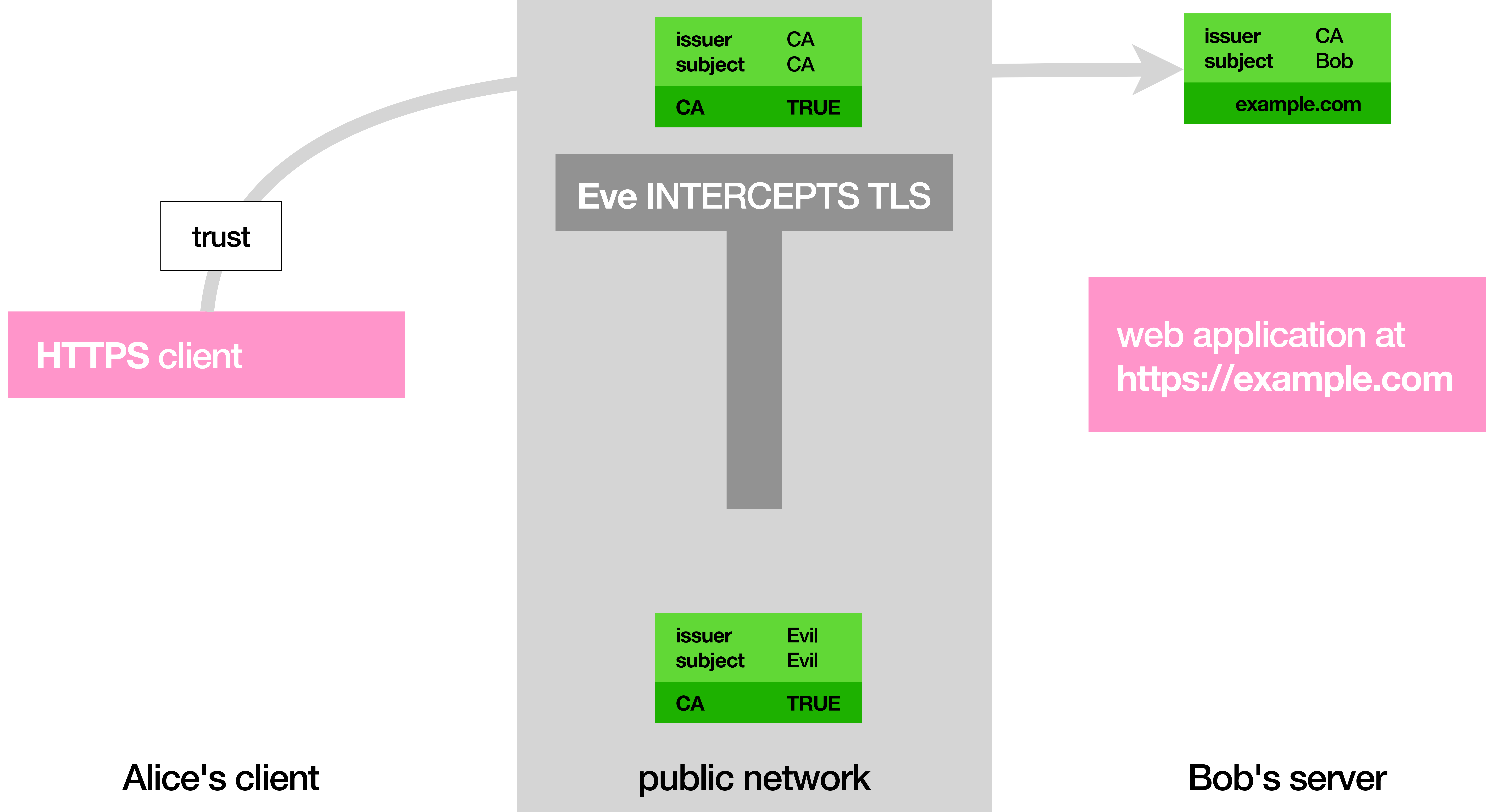
MITM (aka Man-in-the-middle)



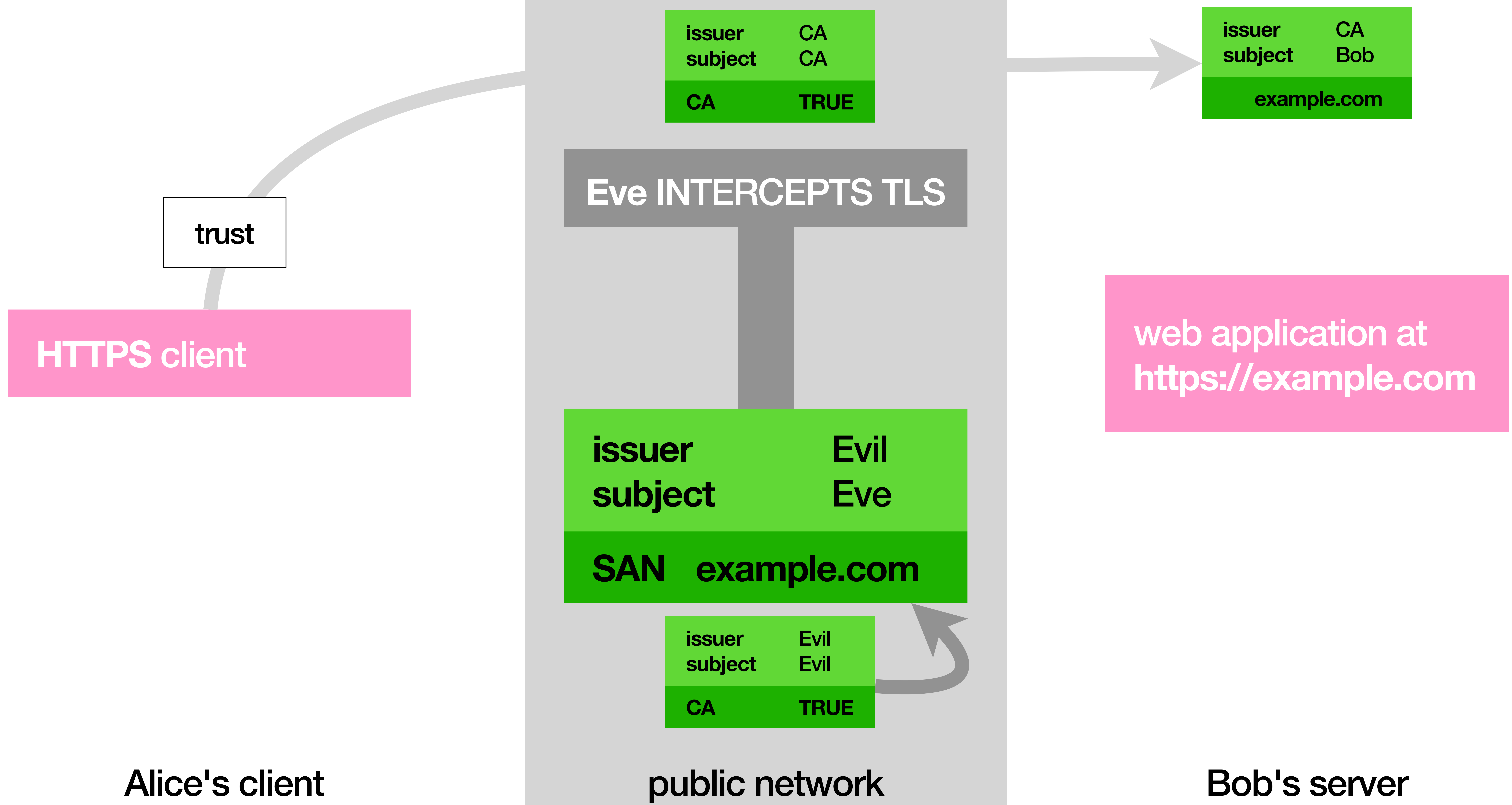
MITM (aka Man-in-the-middle)



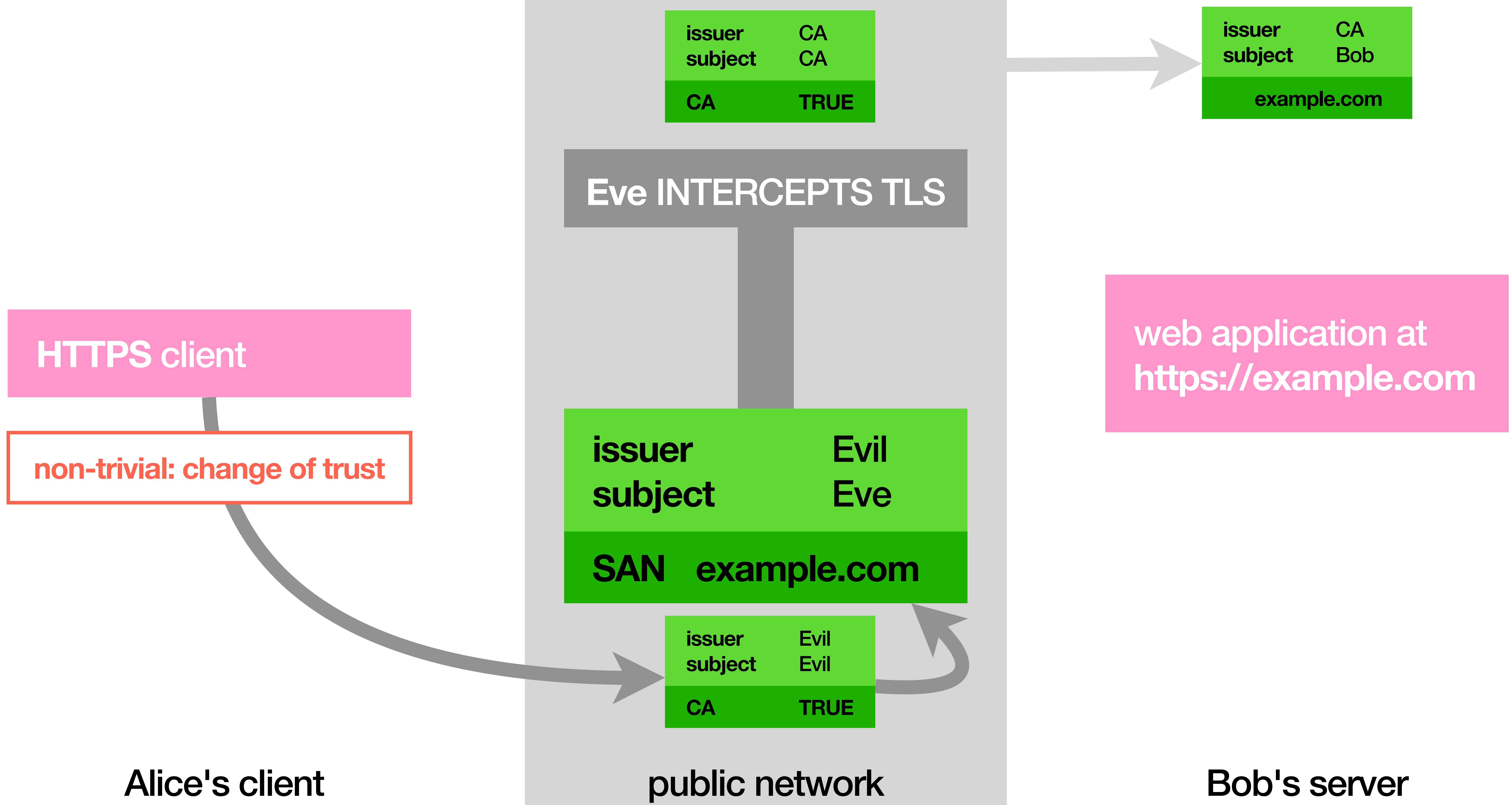
MITM (aka Man-in-the-middle)



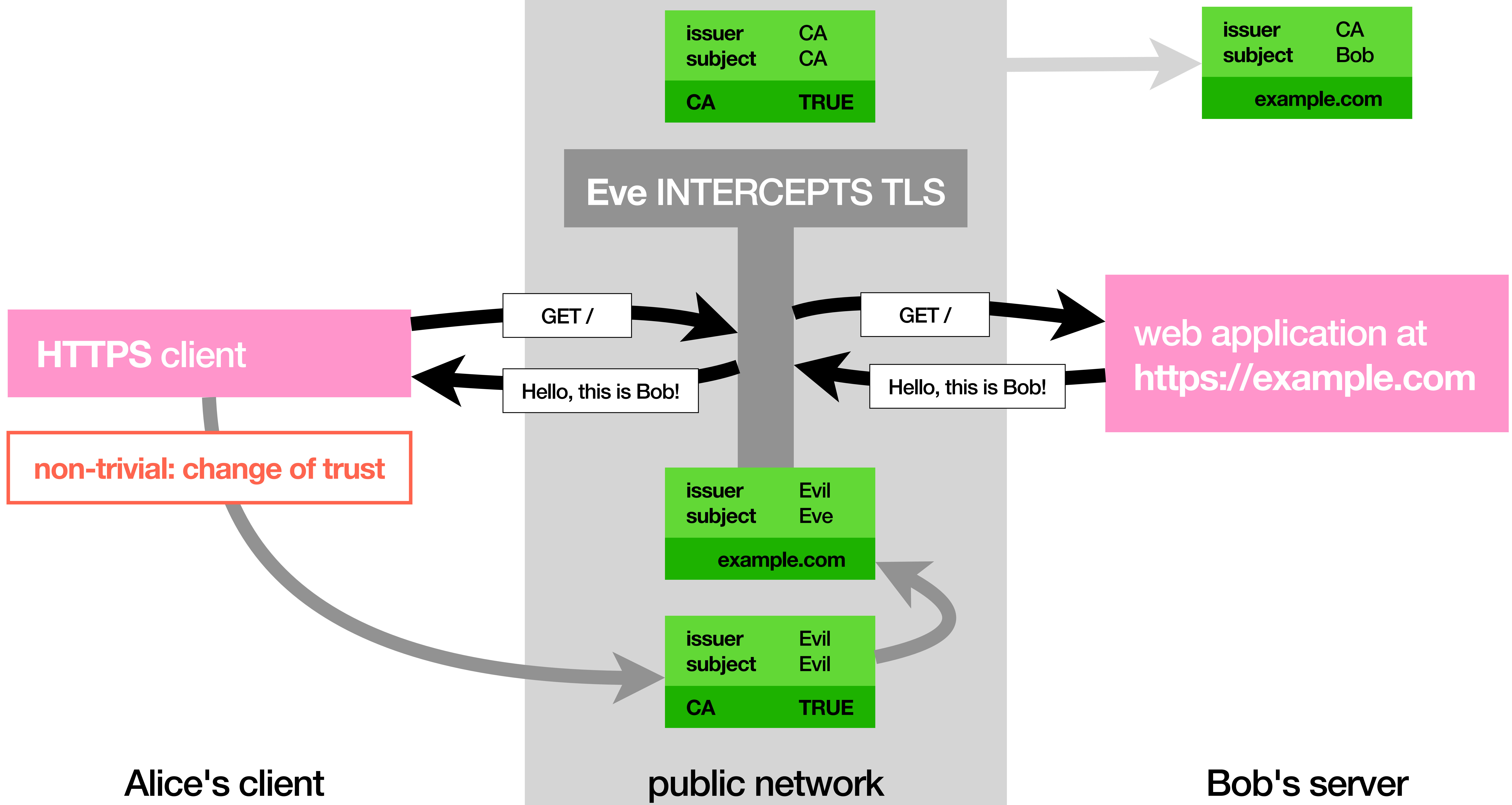
MITM (aka Man-in-the-middle)



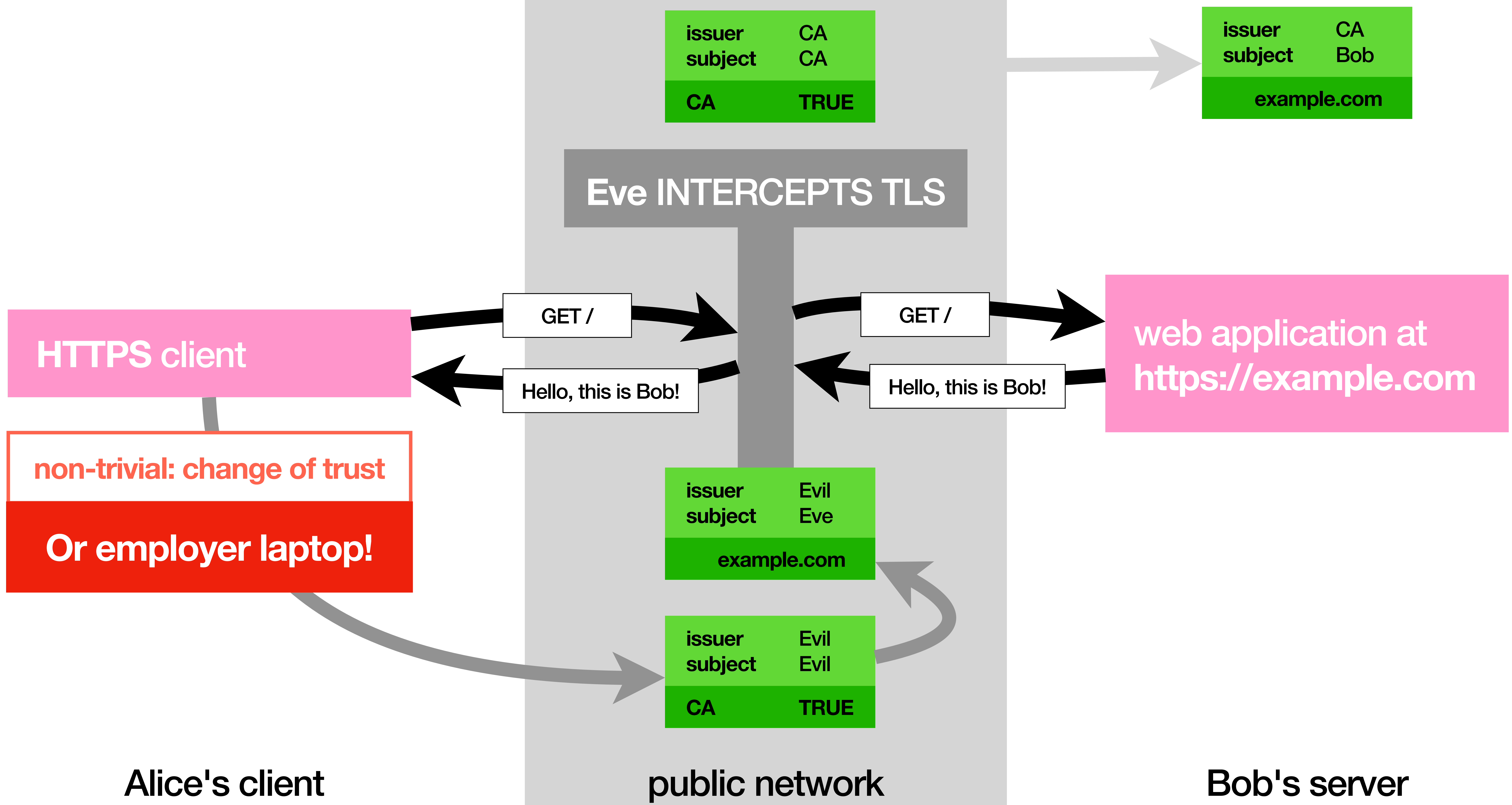
MITM (aka Man-in-the-middle)



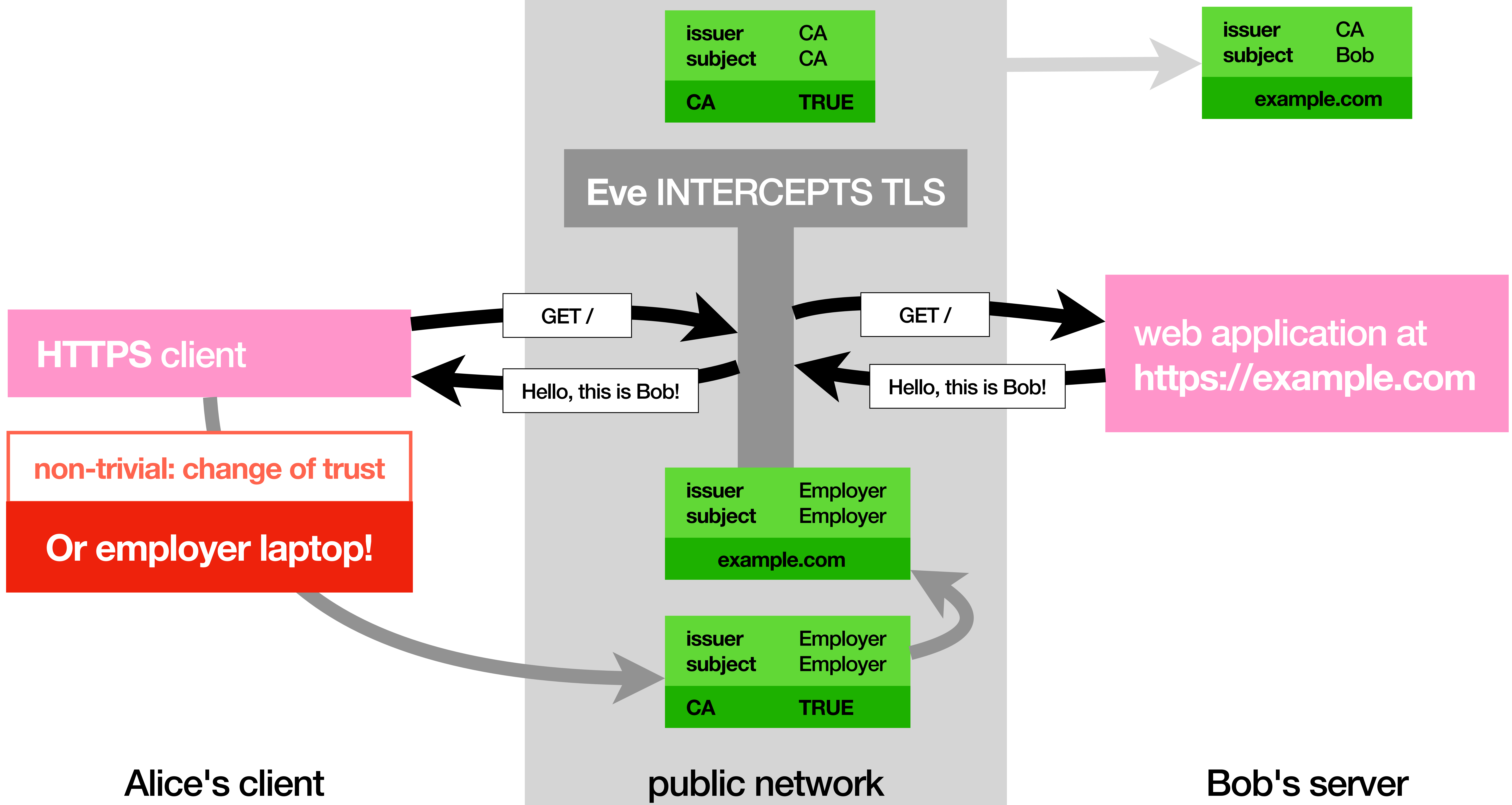
MITM (aka Man-in-the-middle)



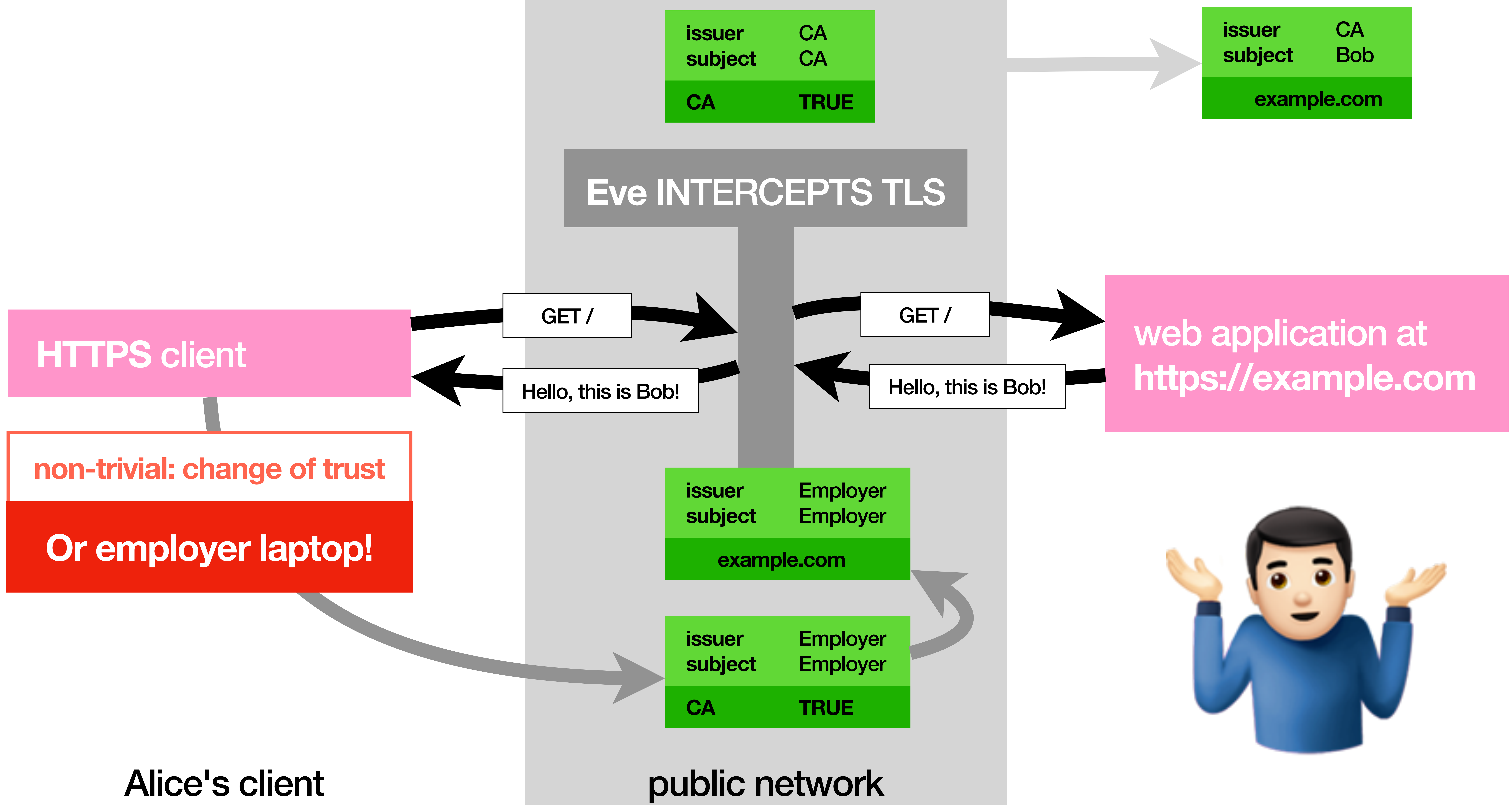
MITM (aka Man-in-the-middle)



MITM (aka Man-in-the-middle)



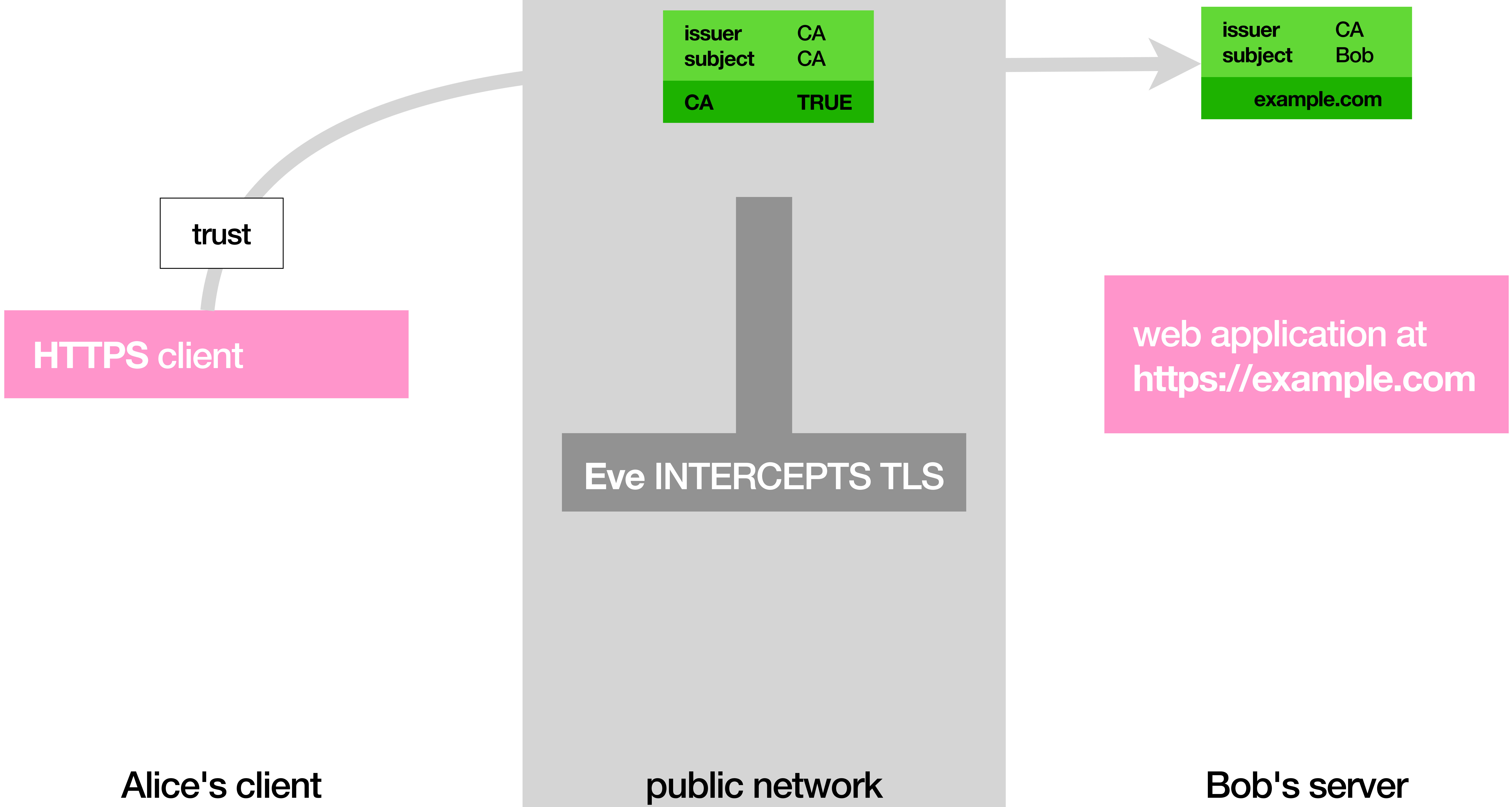
MITM (aka Man-in-the-middle)



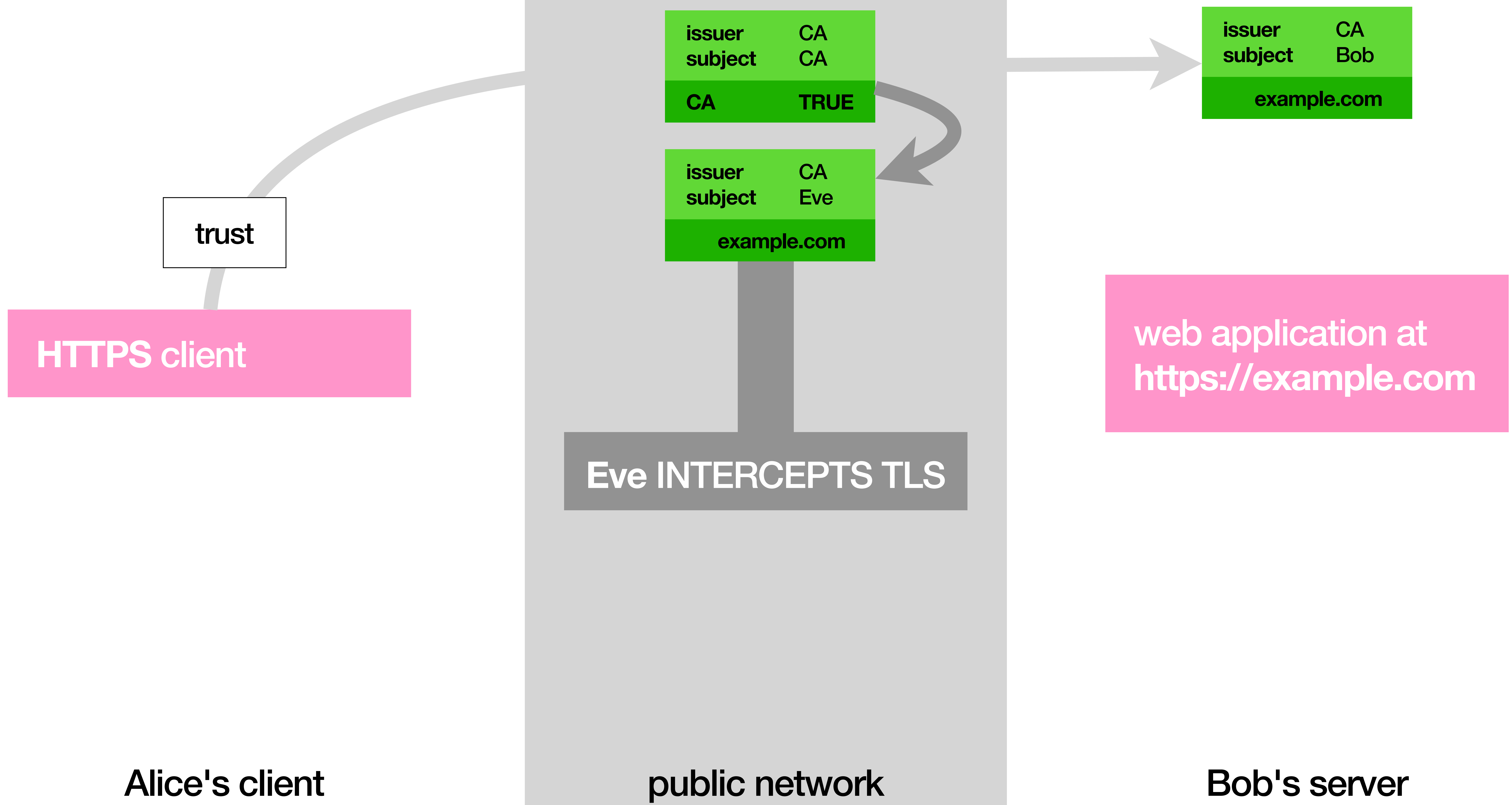
MITM tk2 (aka the now-be-afraid version)

Alice's client | public network | Bob's server

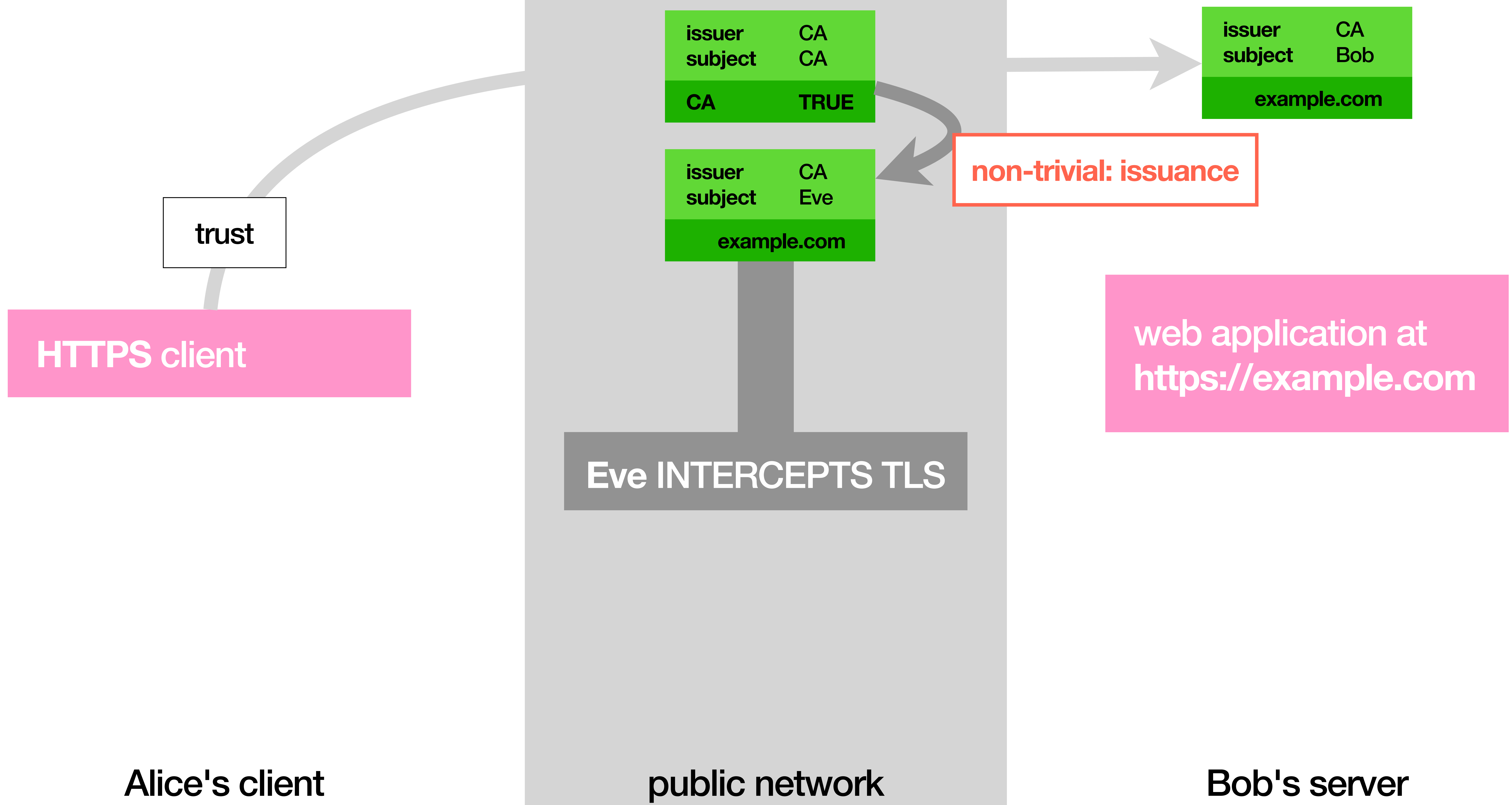
MITM tk2 (aka the now-be-afraid version)



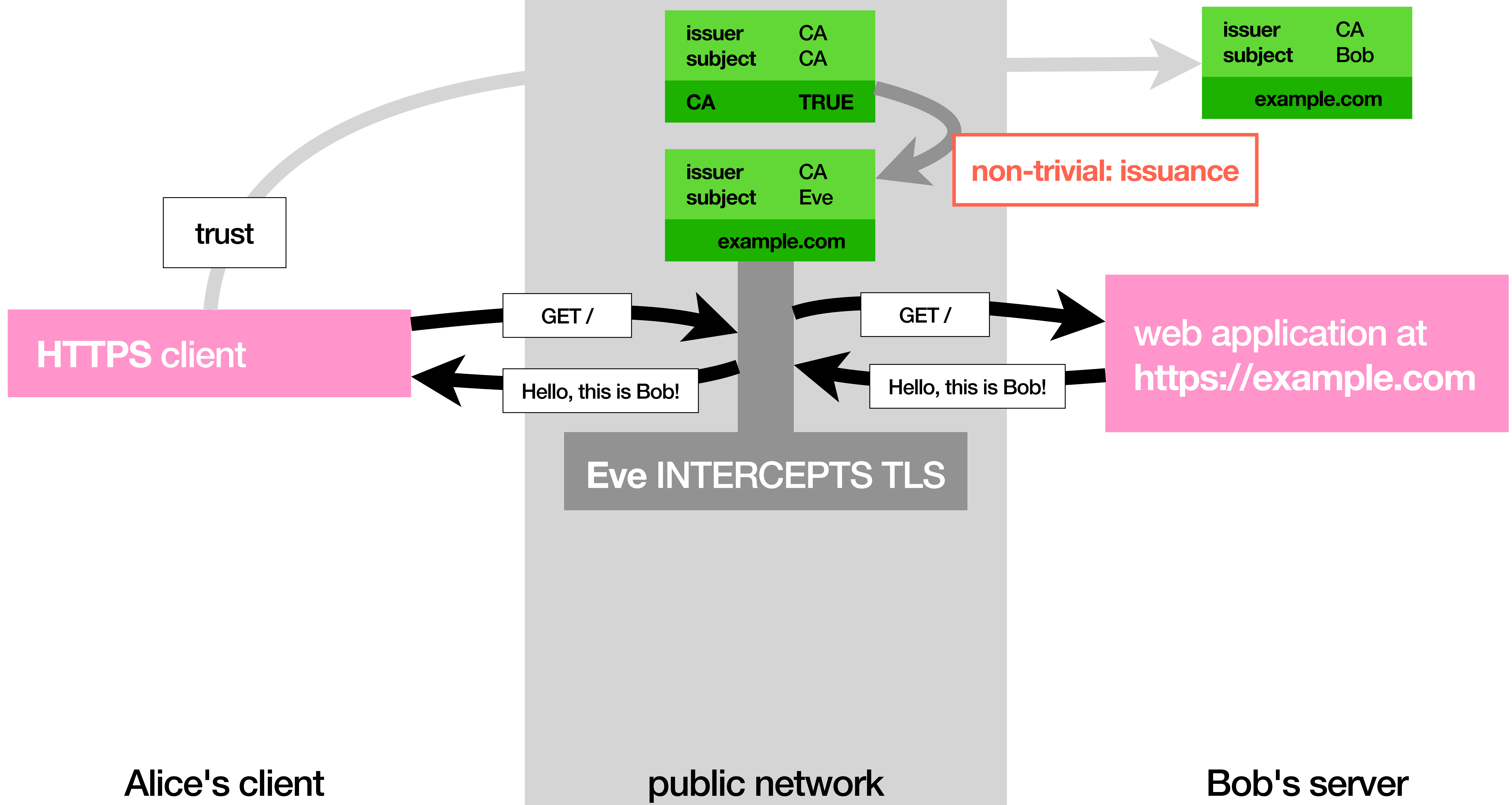
MITM tk2 (aka the now-be-afraid version)



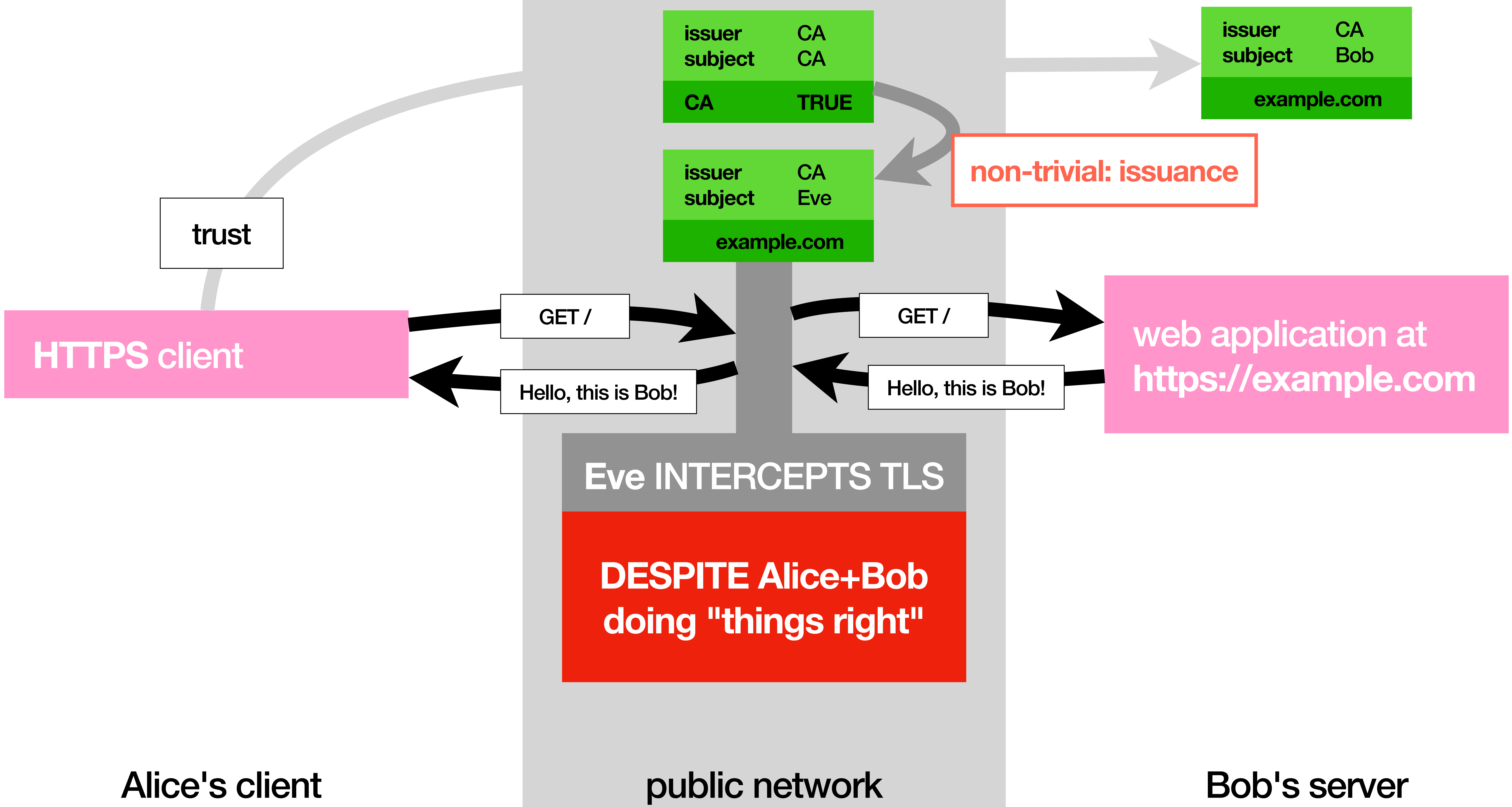
MITM tk2 (aka the now-be-afraid version)



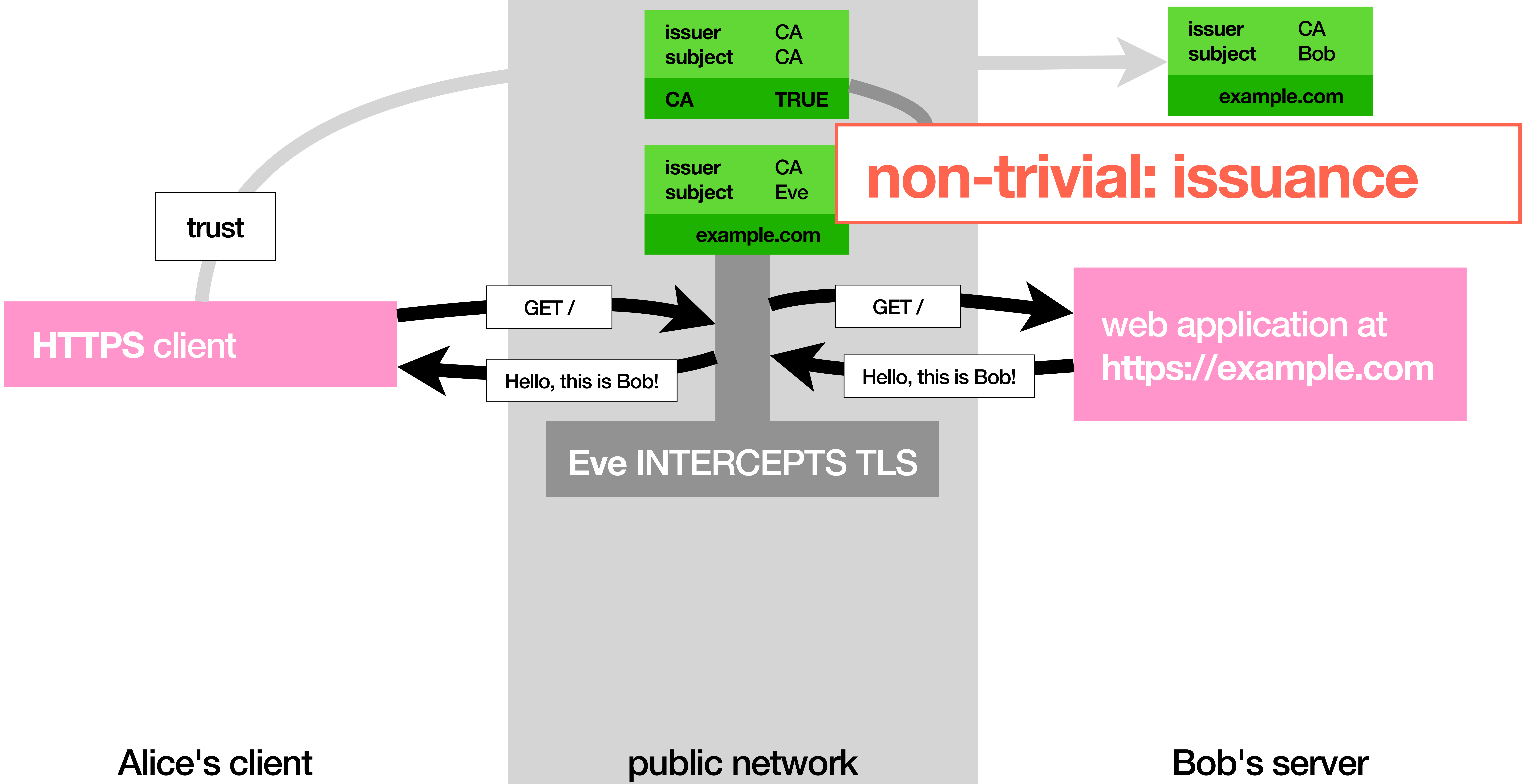
MITM tk2 (aka the now-be-afraid version)



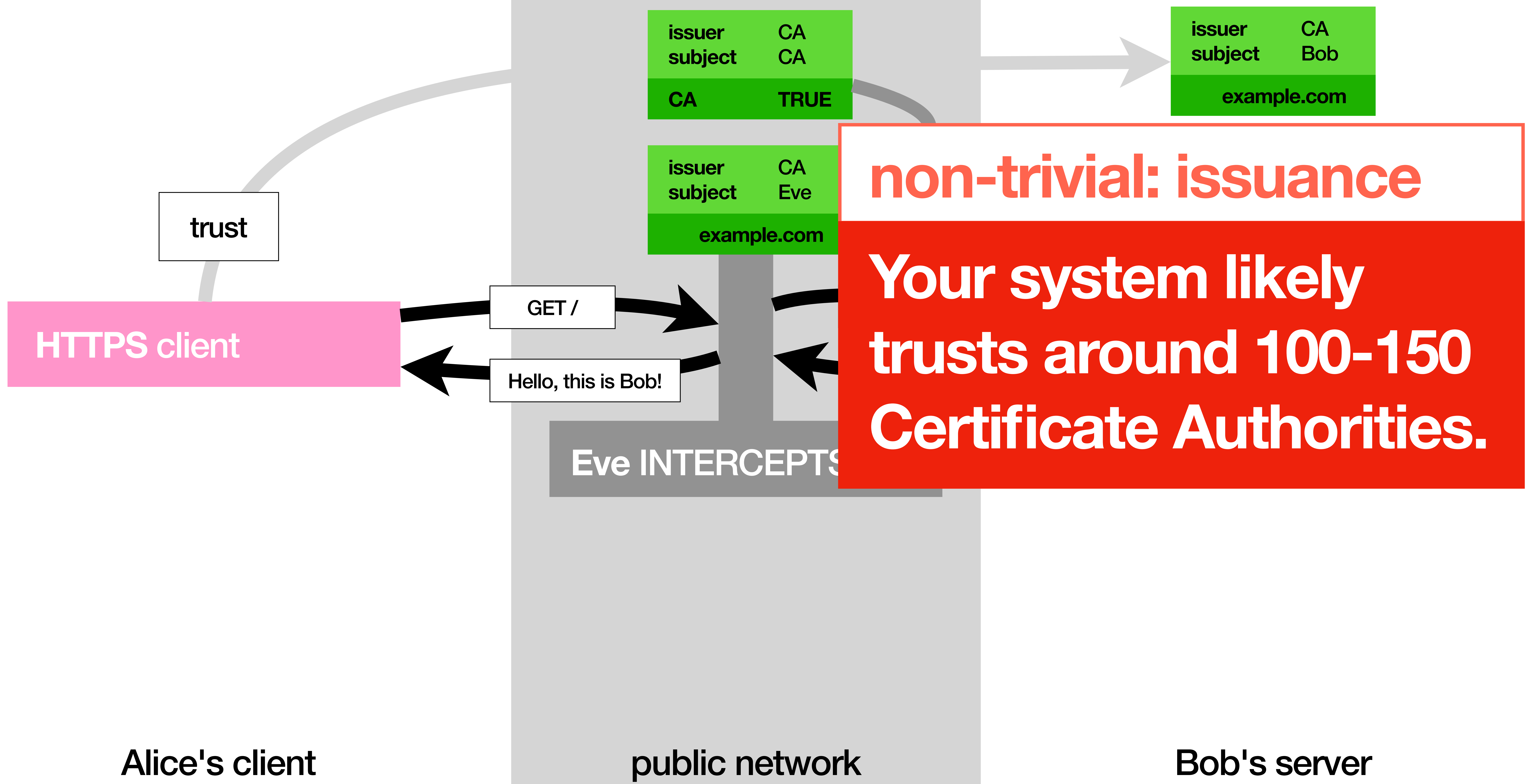
MITM tk2 (aka the now-be-afraid version)



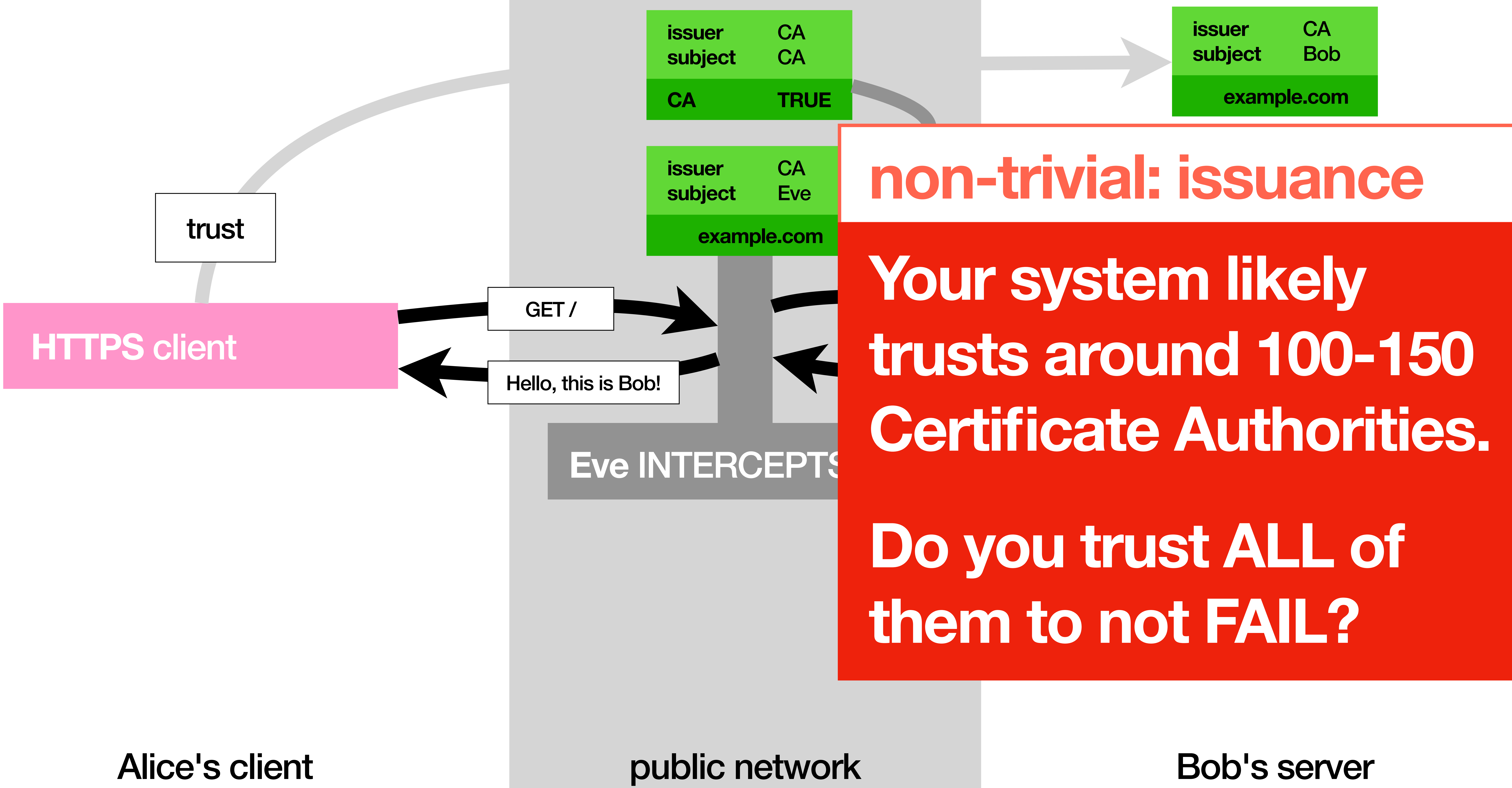
MITM tk2 (aka the now-be-afraid version)



MITM tk2 (aka the now-be-afraid version)



MITM tk2 (aka the now-be-afraid version)

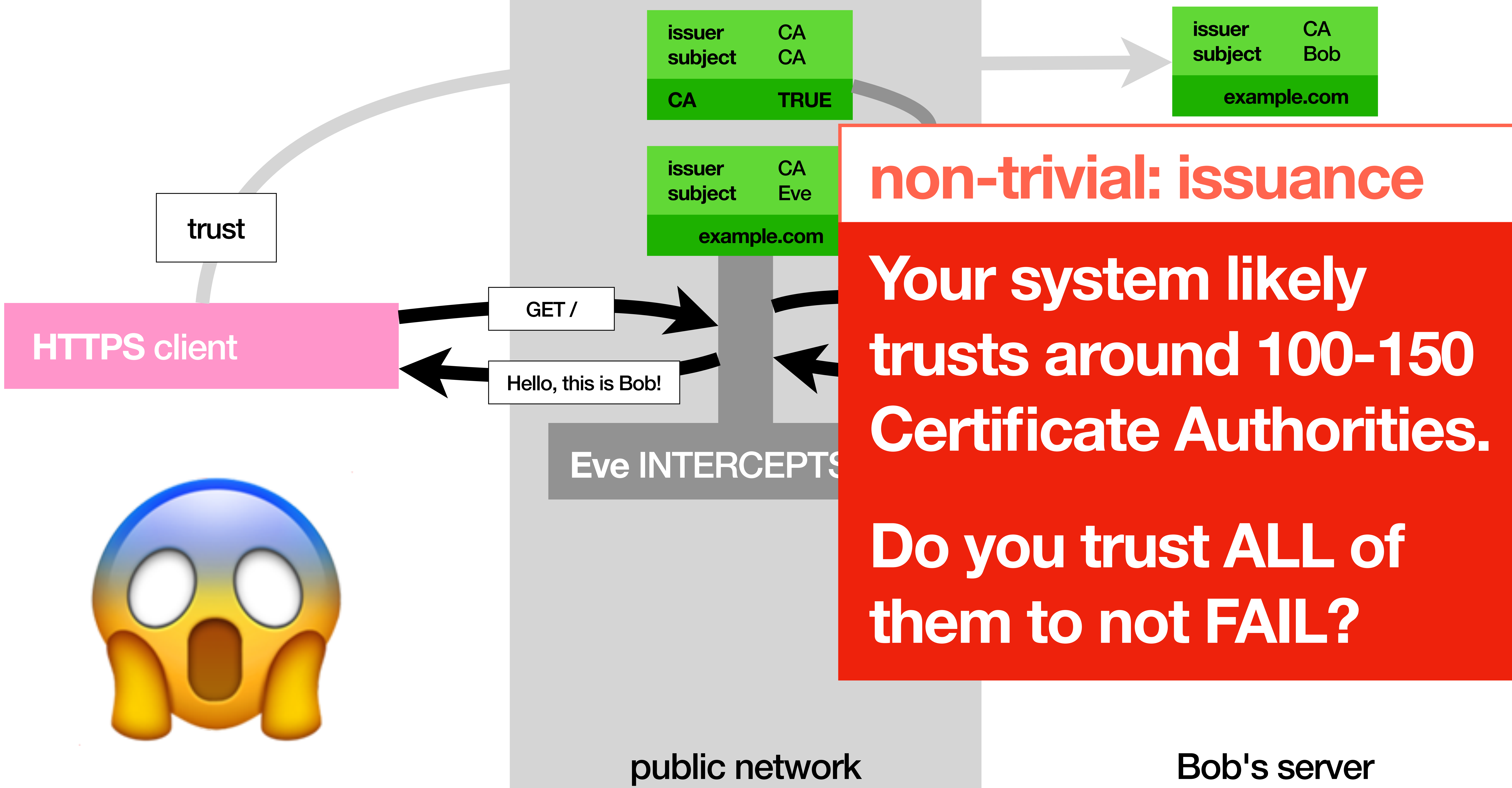


non-trivial: issuance

Your system likely trusts around 100-150 Certificate Authorities.

Do you trust ALL of them to not FAIL?

MITM tk2 (aka the now-be-afraid version)



non-trivial: issuance

Your system likely trusts around 100-150 Certificate Authorities.

Do you trust ALL of them to not FAIL?

MITM

MITM

who do you trust?

Breaking It

Breaking It

Exploring ways of breaking certificate validation.

Break It

Break It

who do you trust?

we're done

thanks

Trust Me,
I'm a Certificate Authority

PyCon PT 2026 Tutorial

Tiago Montes

DON'T Trust Me, I'm a Certificate Authority

PyCon PT 2026 Tutorial

Tiago Montes